STELLAR CYBER®

INVESTIGATIONS AND WORKFLOWS

INVESTIGATIONS AND WORKFLOWS 1
L00 - Introduction and Agenda 2
L00A-PRES: Intro and Agenda (03m:08s) 2
L01 - BUILDING A RISK MATRIX TO DIRECT WORKFLOW CREATION 3
L01A-PRES: Building a Risk Matrix to Direct Workflow Creation (22m:40s) 3
L02 - WORKFLOW TOOLS IN THE STELLAR CYBER UI 10
L02B-DEMO: Workflow Tools in the Stellar Cyber UI (32m:45s) 10
L03 - BUILT-IN INVESTIGATION VIEW 19
L03B-DEMO: Built-In Investigation Views (22m:00s) 19
L04 - THINKING ABOUT CYBERSECURITY WORKFLOWS 25
Part 1 L04A-PRES: Thinking About Cybersecurity Workflows (09m:00s) 25
Part 2 L04A-PRES: Thinking About Cybersecurity Workflows (11m:15s) 28
Part 3 L04A-PRES: Thinking About Cybersecurity Workflows (15m:30s) 32
L05 - BUILDING WORKFLOWS IN STELLAR CYBER - FOUNDATIONS 38
Part 1 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (14m:15s) 38
Part 2 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (11m:30s) 43
Part 3 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (06m:50s) 47
Part 4 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (06m:45s) 49
L06 - BUILDING WORKFLOWS IN STELLAR CYBER - IN PRACTICE 51
L06A-PRES: Building Workflows in Stellar Cyber - In Practice (15m:40s) 51
L07 - CASE INVESTIGATION 57
Part 1 L07B-DEMO: Case Investigation Part 1 (22m:17s) 57
Part 2 L07C-DEMO: Case Investigation Part 2 (18m:46s) 62
L08 - ALERT TRIAGE AND INVESTIGATION FUNDAMENTALS 67
L08A-PRES: Alert Triage and Investigation Fundamentals (28m:46s) 67
L09 - ALERT HANDLING 77
Part 1 L09B-DEMO: Alert Handling - Command Anomaly (23m:00s) 77
Part 2 L09C-DEMO: Alert Handling - DNS Tunneling (36m:38s) 82
Part 3 L09D-DEMO: Alert Handling - Privilege Escalation (28m:00s) 92

L00 - Introduction and Agenda

L00A-PRES: Intro and Agenda (03m:08s)

00:00-01:00
Welcome to the *Investigations and Workflows* module of the SOC Analyst Course in Stellar Cyber. In this lesson we're going to be talking about the basic and foundational concepts required to build workflows in Stellar Cyber and accomplish triage and investigation in your SOC effectively and efficiently. It's going to talk about theoretical concepts, and also show you the practical applications of using Stellar Cyber in your triage and investigation, and how to build workflows that achieve the outcomes that you set for your organization. We're going to get started with building a risk matrix to direct workflow creation. This is a theoretical and conceptual view of the things you need to think about when you want to consider aligning your organizational risk tolerance to your workflows to get the outcomes that your organization needs for you to achieve to keep your network safe. Then we'll talk about workflow tools in the Stellar UI.

01:00-02:00
These are going to take a look at the tools that are available to you to transfer knowledge between SOC analysts and other partner team members, and to memorialize the research that you've done so that other analysts can take a look at it and benefit from the research that you've already done. Next, we'll look at built-in investigation views. We'll look at the investigation views such as Kill Chain views, Case views, Alerts views, Threat Hunting views, all this in an effort to get you acquainted to be able to use the interface most efficiently to create your workflows. Then we'll talk about thinking about cybersecurity workflows in general. This is going to be a conceptual lesson that talks about all the different parties that are involved and the different types of escalations you might encounter. It's going to give you some basic knowledge for you to be the person who is able to create and contribute to building workflows in your SOC. Next, we're going to talk about building workflows in Stellar Cyber from a foundational point of view; who's involved. How it works. The tools in the user interface that allow you to transfer knowledge between team members and partners and management.

02:00-03:08
Then we're going to look at building workflows in Stellar Cyber in practice. These are practical considerations that you are going to want to be aware of to build effective and efficient workflows in your SOC. Next, we're going to do a deep dive into a Case investigation from start to finish looking at a sample Case that we will investigate from beginning to end. Then we'll take a look at Alert triage and investigation fundamentals. These will give you the knowledge to be able to create these workflows to maximize your efficiency as a SOC analyst. Last, we're going to have three demos of Alert handling. Each will approach Alert handling in a slightly different way. The first one is a command anomaly Alert, then DNS tunneling, and privilege escalation. Each of these will be a slightly different approach to how you handle Alerts and manage the flow of information between team members in a practical way. Now that we've taken a look at what's going to be in this module, let's move on to the next lesson and get started building workflows and conducting investigations.

L01 - BUILDING A RISK MATRIX TO DIRECT WORKFLOW CREATION

L01A-PRES: Building a Risk Matrix to Direct Workflow Creation (22m:40s)

00:00-01:00
Welcome to the *Investigations and Workflows* module of the Stellar Cyber SOC Analyst course. In this lesson we'll talk about building a risk matrix to direct your workflow creation. Each organization is going to have their own specific workflows, depending on their priorities and risk tolerances. We'll start out talking about thinking about risk, how we think about what risks are real threats in our environment, and which ones we don't necessarily care that much about. We'll talk about categorization of risks, how to pick the risks that you are very interested in versus the ones that you care less about. We'll talk about aligning workflows to your risk tolerance. There are lots of different workflow options within the Stellar Cyber UI, and we're going to talk about tailoring those options to your specific organization's needs. And lastly we're going to talk about enhancing and monitoring investigation. This is to look into the views and functions within the Stellar Cyber user interface that give you more efficient options to conduct your triage investigation. So let's get going.

01:00-02:00
Let's talk about thinking about risk. This lesson is going to be a conceptual session about how to build a risk matrix so that you can harness the power of all the different workflows that can be imagined and implemented within Stellar Cyber. It won't be what is where in the tool for workflow creation but rather how to think about building a workflow that works with your risk tolerances and security priorities. It'll highlight the idea that you really don't want to be deciding what course of action you should be taking in response to a breach or an attack while the attack or breach is going on. This method is guaranteed to get you behind and thwarting the attacker. It's likely the team will get bogged down in details or negotiations and waste time and energy figuring out sorting the path out of your mess. This inevitably will waste resources and cause further problems. So we're going to talk about ways to construct consistent and repeatable workflows that all analysts can be taught for various types of threats.

02:00-03:00
This is a best practice to ensure that your analysts are following the standard operating procedures and outcomes are consistent and as secure as possible. SOC work can be tedious. A solid standard of triage and investigation needs to be established. Each industry has unique requirements. Every organization is going to be slightly different in the way it approaches security within the organization. So each industry is going to have its own priorities, and we're going to talk about ranking those respective needs by priority. An example of some industries that have different priorities are the following:

- Finance. They might be concerned with enhancing the security of online transactions and protecting fraud to maintain customer trust and comply with regulatory requirements.

- In healthcare, by contrast, they may be interested in safeguarding patient data privacy through stringent access controls and encryption to comply with healthcare regulations like HIPAA.

03:00-04:00

- In retail, securing e-commerce platforms from data breaches and payment card fraud while ensuring compliance with PCI DSS standards are the highest priority.
- In manufacturing, protecting intellectual property and industrial control systems from espionage and sabotage to ensure operational continuity might be their highest goal.
- In the energy sector, strengthening the resilience of critical infrastructure against cyber physical attacks to maintain energy supply and grid stability is of utmost concern.
- In technology, defending against data breaches and ensuring the integrity of data and services given the high value of intellectual property and customer data is going to be the top of their concerns.
- In education, it may be that they need to safeguard student and faculty data and ensure the security of online learning platforms against all cyber threats.
- For the government, they may be most concerned about securing sensitive government data and critical infrastructure against nation state cyberattacks and espionage.

04:00-05:00

- Telecommunications companies are probably going to be more concerned about ensuring the integrity and availability of their communication networks and protecting their customer data against unauthorized access.
- And lastly, as an example, the transportation industry might be most concerned about protecting against disruptions to their logistics and operational technologies that are critical for safe and efficient transportation.

Most industry cybersecurity framework models provide a comprehensive matrix of tactics, techniques, and procedures, or TTPs, used by cyber adversaries. This offers cybersecurity analysts a structured way to understand and analyze threats. By mapping security measures against these frameworks, analysts can identify coverage gaps in their defenses, ensuring they are prepared for a wide range of attack vectors. It also facilitates the development of specific defense strategies against known threats by providing detailed information on adversary behavior and associated indicators.

05:00-06:00

These frameworks support the validation of security tools and processes enabling organizations to assess their effectiveness in detecting, preventing, and responding to cyber incidents. So in a SOC, unknown unknowns are what kept me as an analyst awake at night. I never wanted to be surprised at two AM by some attack that I didn't understand well, and had to hurry to try and understand before developing a response to this attack. No analyst–we've said this lots of times in this course–no analyst can know everything. So having a plan in place is a best practice for sure. And using a data aggregating tool like Stellar Cyber with advanced analytics allows for a much broader view of the network. Many teams in information security have platforms that allow them to see a very small piece of the entire network. It's in effect like looking at your network through a coffee straw. But with

Stellar Cyber you have all of these integrations so that you see a much broader view of your security posture.

06:00-07:00
It gives you a holistic view of multiple different security platforms. It also has the benefit of allowing you to see misconfigurations in other teams' platforms. And with the advanced analytics machine learning and artificial intelligence, modeling threats allow for a greater facility of analysis for analysts. So they in effect become the subject matter expert in the information security team.

We mentioned TTPs or tactics, techniques, and procedures. This is a general term used in cybersecurity to describe the behavior or methods of an attacker. It is similar to the concepts to what the MITRE ATT&CK framework catalogs. There are lots of different industry standards and we'll cover a few here. Some might consider the MITRE ATT&CK framework to be the industry standard for understanding modern cybersecurity threats. MITRE ATT&CK stands for adversarial tactics, techniques, and common knowledge.

07:00-08:00
It's not a risk-assessment framework but rather a knowledge base and model for cyber adversary behavior, reflecting the various phases of an adversary's attack life cycle, and the platforms they are known to target. However, if you were looking for frameworks that focus on understanding and mitigating cyber threats similar to the focus of the MITRE ATT&CK framework, there are several that you might find useful.

- The MITRE Cyber Resiliency Engineering Framework, or CREF, is another MITRE framework, focused on engineering systems to be more resilient against cyber attacks. It complements attack by providing guidance on designing systems that can anticipate, withstand, recover from, and adapt to adversarial conditions.
- The Lockheed Martin cyber kill chain framework is a method for identifying and preventing cyber intrusions activity. The model identifies what the adversaries must complete in order to achieve their objective.
- The Diamond model of intrusion analysis provides a structured method for analyzing intrusions. It focuses on the relationships between the adversary, the capabilities they use, the infrastructure they operate, and the victims they target.

08:00-09:00

- STRIDE is a model used to identify computer security threats. It stands for Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.
- OCTAVE, or Operationally Critical Threat, Asset, and Vulnerability Evaluation. This framework focuses on organizational risk and security practices. It helps organizations identify and prioritize their information security risks.
- Threat modeling. While not a single framework, threat modeling is a methodology used to optimize network security by identifying objectives and vulnerabilities, and then defining countermeasures to prevent or mitigate the effects of threats to the system.

These frameworks and methodologies, like MITRE ATT&CK, are designed to help organizations understand, analyze, and defend against specific types of cyber threats. They are often used in conjunction with broader risk-management frameworks to provide a comprehensive cybersecurity strategy.

09:00-10:00
Assessing cybersecurity risks is a critical aspect of managing the security posture of any organization. Several frameworks are also widely recognized and used for this purpose. Here's some of the best frameworks for assessing cybersecurity risks.

- The NIST cybersecurity framework, or CSF, was developed by the National Institute of Standards and Technology. This framework is widely used in the United States and globally. It provides a set of industry standards and best practices to help organizations manage cybersecurity risks.
- ISO/IEC 27001 is an international standard that provides specifications for an information security management system. It is designed to help organizations manage the security of assets such as financial information, intellectual property, employee details, or information entrusted by third parties.

10:00-11:00
- CIS Controls. The Center for Internet Security Critical Security Controls are a recommended set of actions for cyber defense that provide specific and actionable ways to stop today's most pervasive and dangerous attacks.
- COBIT, or Control Objectives for Information and Related Technologies, was developed by IS ACA. COBIT is a framework for developing, implementing, monitoring, and improving IT governance and management practices.
- FAIR, or Factor Analysis of Information Risk, is a quantitative risk-assessment methodology for understanding, analyzing, and quantifying cybersecurity risk in financial terms.
- PCI DSS, or Payment Card Industry Data Security Standard, is specific to organizations that handle credit card transactions. This standard helps in protecting payment systems from breaches and theft of cardholder data.

All of these frameworks are useful methods of creating a workflow and making sure that you are aware of the unknown unknowns. We say that you can't know everything.

11:00-12:00
There are zero-day attacks out there that you just can't prepare for. But having the awareness and the preparedness to take on these challenges is a best practice and is necessary in cybersecurity operations.

Once these risks are prioritized it's important to test detection and prevention via red teaming if at all possible. This allows you to make sure that the controls that you have implemented are going to work. It's imperative that you teach your analysts how to respond to different types of threats and have a plan in place to respond.

Categorization of Risk

One way to think about categorizing risks is to group them into their different risk-tolerance categories. You might think of it this way: There are things that I never want on my network and will block as much as possible. There are also things I want to see every time it happens even though it may generate some unimportant positives. Then there are risks I want to see if they rise to a certain level of anomaly. Things I see too much of and want to minimize.

12:00–13:00
All of those are ways to think about threats and managing them by priority.

Some things you might never want to see on your network and will always block will be ransomware, malware, phishing of all kinds, and brute-force attacks.

Some things you might want to see every time it happens even though it may generate some positives are credential dumping, port scanning, audit-log tampering, shadow copy deletion, and lateral movement, just to name a few. But it's important to know that sometimes this type of activity happens on your network and its legitimate business activity. We'll give some examples. In the case of credential dumping, when the system administrators extract credentials as part of a legitimate forensic investigation or for system-migration purposes, it's a perfectly legitimate business activity. It highlights the fact that who is doing this type of activity is one of the most important factors in understanding whether it's a threat. For port scanning, when IT professionals conduct internal port scans to assess network security or for network inventory management, it's an allowed activity.

13:00-14:00
For audit-log tampering, when authorized personnel modify or clear logs to protect privacy or manage storage in accordance with the organizational policy and compliance standards, that's totally legitimate behavior. For shadow copy deletion, when system administrators delete old or unnecessary shadow copies as part of routine maintenance to free up disk space it's an allowable activity. With regard to lateral movement when IT staff have to access multiple parts of a network using credentials to perform legitimate maintenance, troubleshooting, or network-management tasks, you may see Alerts that are not real positives. But otherwise when this activity is happening you want to see it to know if it represents an actual threat to your network. Some risks I want to see if they rise to a certain level of anomaly are odd logins, authentication from odd locations, suspicious scripts, account manipulation, and anomalous services and executables.

14:00-15:00
Let's take a look at these. For odd and anomalous login activity, when employees log in at unusual times due to different time zones, shift work, or to meet deadlines, this might reflect legitimate

business needs, but it's also something that needs investigation. Authentication from odd locations is when users authenticate from unusual locations because they are traveling, working remotely, or using VPN services that route through various global servers. Performing this analysis every day and knowing what users log in from which locations, in addition to having machine learning that tells you what the baseline for users is, makes you a subject matter expert to know who's doing what on your network. Suspicious scripts running. When IT professionals or developers run scripts for legitimate automation, testing, or system administration, it might be mistaken for malicious activity, or it very well could be malicious activity, depending on who is carrying it out.

15:00-16:00
Account manipulation is when administrators legitimately modify user accounts, permissions, or credentials as part of routine maintenance or in response to organizational changes, but account manipulation is also the way attackers will escalate their privileges and gain access to larger swaths of your network. Anomalous services and executables can be used when legitimate software updates are deployed across the network, introducing services and executables that deviate from the established baseline, but are benign. But they also are one of the major ways that hackers will infiltrate your system and gain access to things that they should not have access to. Because there are legitimate reasons to carry out these types of activity, it's important to distinguish the users and assets that typically carry out this activity, versus anomalous activity. Stellar Cyber's advanced analytics excel at making this distinction using machine learning and AI. And then we have plain false positives. We'll talk later on in a different module about how to minimize the Alerts that we don't want to see.

16:00-17:00
But there will always be false positives in any environment. In this case, it's up to the analyst to make the choice to minimize these Alerts or to just ignore them.

Let's talk for a minute about aligning your workflow to risk tolerance. Every environment is different, and there may be certain types of assets or information that you want to specifically be very cautious about attackers accessing. Some of the things that you might put on these lists or add tags to are your critical assets, maybe customer-information databases, possibly databases with proprietary information, business operations planning, technical plans, and things of that sort. It could be that you want to be very careful with your compliance-related data such as HIPAA, PCI, DSS, SOX, GDPR, or things of that nature. And business-essential applications may be something that you want to highlight to your analyst to make sure that you see clearly every time something suspicious happens to them.

17:00-18:00
Another way you might decide you want to tailor your workflows is to monitor users who carry higher risk. These users represent a higher risk on your network than your regularly privileged users. You may want to add tags to or put on lookup lists, the following set of users. Users who carry high privilege represent a higher risk because attackers want to get the privilege that these users have. They may compromise their credentials, escalate their privileges, and then they'll be able to carry out certain types of activities that they want to carry out, but that requires high privileges in order to do

so. Another set of users that carry very high risk is domain admins. For attackers, gaining domain admin privileges is one of the highest goals because these users carry privileges that go across the domain. They have very high privileges and are able to carry out some pretty dangerous activities.

18:00-19:00
System admins might be another group that you want to monitor more closely, as well as executives who have access to data that most people within the company don't have. Also contractors represent a risk in the sense that they may not have the high level of security or monitoring that your organization has, but they still have access to your network to accomplish their responsibilities. Likewise, employees with access to high-value data also represent a risk and may require enhanced monitoring.

Let's talk about how we carry out this enhanced monitoring and investigation. Some ways to enhance your monitoring and investigation are using tags, setting asset importance, setting user privilege level, and using lookup lists. In Stellar Cyber, analysts can use tags on users or assets to enhance security operations and incident response capabilities.

- Tags are labels or identifiers that can be assigned to users and assets within the network, allowing for more granular control and organization. Here's how Stellar Cyber utilizes these tags and the benefits they offer.

19:00-20:00

  - Categorization and organization: Tags enable the categorization of users and assets based on various criteria such as department, role, sensitivity level, or location. This organization helps security teams quickly identify and group related entities within the network.

  - Security policy enforcement: By tagging users and assets, Stellar Cyber allows for the tailored application of security policies. For example, assets containing sensitive information can be tagged accordingly and stricter security controls can be applied to these tags, ensuring enhanced protection, where it's most needed.

  - Incident response and analysis: Tags simplify the process of tracking and responding to incidents by enabling security teams to quickly filter and identify affected assets or users. For instance, if a tag represents a particular department experiencing a phishing attack, the security team can immediately focus their response efforts on that area.

20:00-21:00

  - Risk assessment and management: Tags can be used to indicate the criticality or compliance requirements of certain assets, aiding in the prioritization of security efforts. Assets with tags indicating higher value or regulatory scrutiny can be subjected to more frequent reviews and stringent security measures.

- Automation and efficiency: Automated playbooks can be set up based on tags to streamline security processes. For example, Alerts can be configured to trigger automatically for certain tagged assets, reducing manual oversight, and accelerating the detection and mitigation of threats.

So use of tags on users and assets offers a flexible, efficient, and effective way to enhance the visibility, security policy enforcement, incident response, and overall management of cybersecurity within an organization.

- Stellar Cyber allows users to set the importance of assets directly through its user interface, enhancing the prioritization and focus of security efforts on critical assets within the network.

21:00-22:00

- Accessing asset management: Users can navigate to the asset management section of the Stellar Cyber interface. This section displays a comprehensive list or overview of all the assets detected or managed by the system.
- Selecting an asset: From the list of assets, users can select a specific asset for which they want to set or adjust the importance. This selection can typically be done by clicking on the asset or choosing an option to edit its properties.
- Adjusting importance settings: Once an asset is selected, the user interface would offer an option to set or adjust the importance level of that asset. Options are low, medium, high, or critical.

- By allowing users to set asset importance, Stellar Cyber enables organizations to tailor their security posture and focus their resources more effectively on protecting critical assets. This feature facilitates a more strategic approach to cybersecurity management, ensuring that efforts are aligned with the organization's priorities and risk-management strategies.

22:00-22:40

- User privilege level works the same way. Important people in your network can have an elevated criticality to show threats more clearly.
- Lookup lists are ways that you can put assets or users on a list to incorporate them into your risk-management strategy.

In this lesson we took a look at how you should think about risk. We took a look at how you might categorize your risks. We talked about aligning workflows to risk tolerance, as well as enhancing and monitoring investigation. Thanks for attending the lesson. This lesson is complete. Thank you.

L02 - WORKFLOW TOOLS IN THE STELLAR CYBER UI

L02B-DEMO: Workflow Tools in the Stellar Cyber UI (32m:45s)

00:00-01:00
Welcome to the *Workflow Tools in the Stellar Cyber User Interface* lesson of the *Investigations and Workflows* training module. In this lesson, we're going to be talking about the various tools that exist in the Stellar Cyber user interface that facilitate efficient triage and investigation of security incidents. We'll be talking about data transfer management. We'll explore knowledge sharing and reporting in the tool. We'll talk about task assignment and tracking, as well as Case management, role-based access control. We'll explore the APIs and integration elements within the Stellar Cyber tool. We'll talk about threat intel sharing, playbook automation, Alert triage, and the various investigation tools within the platform. So let's get going.

Stellar Cyber integrates many workflow tools within its user interface to enhance efficiency, collaboration, and the overall effectiveness of security operations.

01:00-02:00
These workflow tools are designed to streamline processes, facilitate the management of security incidents, and enable security teams to respond to threats swiftly and accurately. The data transfer management features in Stellar Cyber allow security teams to track, manage, and respond to security incidents from detection through resolution. It includes features for categorizing incidents, assigning them to team members, tracking progress, and documenting the response. This ensures that every incident is addressed promptly and effectively, minimizing potential damage. Stellar Cyber incorporates several tools and features specifically designed to facilitate the exchange of information about security events between team members and security stakeholders. These tools aim to enhance collaboration, improve the speed and efficiency of incident response, and ensure that all relevant parties are informed and engaged in the security process.

02:00-03:00
Key tools and features for information exchange include knowledge sharing and reporting. These are features that enable the sharing of incident details and reports with relevant stakeholders. These can include automated email notifications, exportable reports, and dashboards that provide insights into the nature, status, and resolution of security incidents.

Let's talk about information sharing via reports. Reports are found under **Respond** and reports. And you'll see that there are lots of different kinds of prebuilt reports already in your system and custom reports that you can create yourself here, and they fall into these tabs. The **General** tab is just basically general reports that you might want to use to see activity on your network. You can clone these reports and customize them if you want.

03:00-04:00
It also contains reports related to PCI compliance. If you don't know what PCI stands for, it's the payment card industry data security standard and it's a set of security standards designed to ensure that all companies that accept, process, store, or transmit card information maintain a secure environment. This is mainly for retail or organizations that accept transactions to maintain compliance, and CIS compliance reports you can see here. CIS refers to adherence to the Center for Internet Security or CIS benchmarks and controls. It's a set of best practice security guidelines

designed to safeguard organizations against cybersecurity threats. It's developed by a global community of IT professionals, and these benchmarks cover a wide range of technologies including operating systems, middleware, software applications, network devices, and they offer specific recommendations for securing IT systems and data.

04:00-05:00
These refer to these types of protocols. Then we have HIPAA compliance, which is mostly going to pertain to healthcare. HIPAA stands for the Health Insurance Portability and the Accountability Act. It was passed in 1996. It's a Federal law designed to protect sensitive patient health information from being disclosed without their knowledge or consent. And it requires healthcare providers, health plans, healthcare clearinghouses, and business associates of those entities to implement physical security, network security, and process security measures. The aim is to essentially ensure the confidentiality, integrity, and availability of protected health information. Then you have reports related to license usage, you can look at your volume here. This is more of an administrator type of task probably, but to assess how much data you're ingesting and how much of your license are you using, these reports refer to that.

05:00-06:00
Then custom reports are the reports that appear that are made by users themselves, and you can create your own custom report if you want. And we'll talk a little bit about how to do that. The custom reports are built by creating your own dashboard. We will just simulate that real quick because it's covered in the dashboards lesson. We'll call this, "test." Our test dashboard here what we'll do is we'll edit this and we'll create a pie chart. And next and then All tenants across Alerts. We'll just give it a sample. Select **Next**.

06:00-07:00
Field well these are all just samples. This is not creating a real dashboard; that'll be covered in the dashboard lesson. Submit this. And then when we have this test dashboard, we can save it, and then we can go back into reports and see the custom reports and we'll search and here we find it. And we've got here. It doesn't contain any data but if you wanted to build a really elaborate dashboard, you could schedule a report, and send it to me. I'll choose the last twenty-four hours. I will send this every day at twelve PM. No asset tags. I'm going to save this report.

07:00-08:00
And then if we go into the reports, we can see that in our custom reports have it here, and we could schedule this report, or we can look at it in the reports, or we can export this report. These reports are all exportable as PDFs. We'll take a look at how to do that. If we export this one, it populates as a report this way and then we can download it ourselves. And that's how you generate custom reports.

Reports are very valuable tools to work into your workflows to share information with other security stakeholders. What you might find is when you work with a tool like Stellar Cyber that aggregates lots of different types of data and generates a lot of information and system intelligence on its own…

08:00-09:00

...that you may have other members in your information security team coming to you to say, “Hey, can you generate me a report on a weekly basis about login failures,” for example if your Windows security team wants to see that type of information and building these types of information because you are essentially a type of subject matter expert on your network because you're seeing this data in a holistic manner you're going to know things that other people don't. You just see the network in a different way. And they may come to you and say, “Hey, can you create me a custom report that shows me x data on a weekly or daily basis”? and it's really no problem for you to do that once you know how to create these reports. It's a very useful tool.

Another feature that facilitates knowledge sharing within the tool is the ability to share Cases and Alerts with other team members.

09:00-10:00
Here we'll take a look at this one, log4j. That's one that we all probably have heard of before. If I wanted to share this entire Case with a team member, I could just go here to share. An email client pops up directly in the UI and I can type in whoever I need to send this to. This could be an alias. This could be a person. There's a reply to. You don't necessarily have to fill that out if you don't want to. We'll share this, and we'll go in and show how they show up in the email in just a minute. But that will share the whole Case. Now if I wanted to share an individual Alert, for example, I could go here, click into one of the examples. Go to Actions, trigger an email. Likewise again, I will enter my email address.

10:00-11:00
It's important to add context in these emails. What's the subject here? That will send an email. The last way, we have to notify via email from within the tool is you can automate an email to be sent. Here we're going to look at a playbook that's already been built so that we don't have to go through that. That'll be covered in one of the other lessons. But let's look at how it looks if you want to set this up. We've got Cylance Optics Alarm MiniDumpWriteDump so this is some sort of data right that we don't want to see on our network. This complex query is going to catch these types of executables and that's the signatures of whatever this Cylance Alert is.

11:00-12:00
Down here we have actions. There's lots of different actions. We can email. We can send a Slack. We can send to a specific webhook or a legacy webhook, Firewall/Security Switch, create an Alert in the system, disable the user, or run a script. In our case, we want to create an email and then we'll put the recipients here. The subject is...the priority will be high. Include the Interflow. That includes all the JSON data that we saw before and we'll see how that looks in the email in just a minute. And then the email body is (types). Alright. Click **Submit**. I won't change this because this belongs to someone else, but if we set up this action so that if a certain criteria on your network is met, and this here uses a query actually. It says anytime this query has positive results I want you to trigger an email.

12:00-13:00
One thing to consider is be careful with that and be judicious in the way that you set this up because if you have tens of thousands of a certain kind of Alert and that's an email, that's going to quickly

clog up your Outlook or server or whatever email client you have. You have to be careful about this. Make sure that this is not something that's going to overwhelm your email server and cause problems. This would be for something if a partner team in your information security group came to you and said, "Hey, this new log4j thing looks pretty dangerous. We want to see anytime we see a signature that indicates that the log4j is happening, any vulnerabilities from that exploit can be exploited on our network, we want to see them." This is the way you set up email and it's a very effective way. We all understand email, very effective way to communicate with other security stakeholders about things going on that they need to be aware of.

13:00-14:00
We'll hop over now and see what these emails actually look like. This was the dashboard that I sent. It doesn't have anything now but it would be a comprehensive dashboard if you had a big dashboard built. This was the Alert that I sent. See it just sends the Interflow data, which is basically keys and values in JSON format. The entire Case sends a link back into the UI to that Case. That's a very useful tool. And then here's another Case that I sent. These are the ways that they appear in your emails when you send these emails via this.

Now let's talk a little bit about task assignment and tracking as part of your workflows and the tools that are built within Stellar Cyber to help you assign tasks and track those tasks...

14:00-15:00
...as well as track functions in your system. These tools are functionality to assign specific tasks to team members within the context of incident response or investigation. This ensures clear responsibility and allows for tracking of progress of each task contributing to the overall efficiency of the team. First and foremost we should look at the fact that there is automated Alerting and prioritization built into the system. Stellar Cyber automatically generates Alerts based on detected security events or anomalies, prioritizing them based on severity, impact, or other criteria. This helps in identifying which incidents require immediate attention and should be assigned first. When it comes to deciding which tasks need to be assigned to which analyst or to which team, there are lots of tools in this and we'll take a look.

15:00-16:00
Also, it should be noted that there is integration with ticketing systems built in. Integration with ticketing systems allows for the automatic creation of tickets in response to Alerts. This facilitates the assignment of tasks to specific team members or groups within a SOC. This integration ensures that task assignment is streamlined and that there's a clear workflow for addressing and tracking security incidents. Another thing we should keep in mind and we'll talk about how to assign tasks in just a minute but you should use the dashboards and reporting tools for tracking. We've looked at a little bit of that. Stellar Cyber provides dashboards and reporting tools that give SOC managers and team members visibility into the status of ongoing tasks and incidents. These tools can show which tasks have been assigned, their current status, who's working on them, and historical data about incident response times and outcomes. This real-time visibility is crucial for effective task management and for ensuring that incidents are resolved promptly and efficiently.

16:00-17:00
Then there are collaboration and communication tools. Effective task management and tracking also relies on good communication within the SOC team. Communication is key. Stellar Cyber offers features that integrate with communication tools. It's important to note that while Stellar Cyber is designed to automate and facilitate many aspects of SOC operations, your specific capabilities and methods for task assignment and tracking can depend on how the platform is configured and which integrations you have within the organization. This is going to vary slightly, but in general, we've seen some of the functionality and we'll explore that here.

In real terms, task assignment is going to happen at the Case and the Alert level, and it's pretty straightforward. You can assign a task to an analyst just by doing that. There's no apply button here that you have to press.

17:00-18:00
If you want to assign Alerts to an analyst, you have to click in to see the menu. There's no menu here, but when you click an Alert, you can assign it a status, an event tag, or an assignee, and for task assignment we'll assign it to an assignee. We'll use this person here. Apply that and then we see that this is the assignee. This is how you pass information back and forth. This process will be the same in the UI every time but it will vary depending on what your workflow dictates that you follow. Every organization will be slightly different as far as what the workflow is but within the UI you will encounter this in the same way. And likewise, we could go into a specific type of Alert for example like if you wanted to say this group is going to do all Mimikatz because Mimikatz is a very dangerous threat.

18:00-19:00
We want to assign it to someone we know is capable of doing it. We would assign all these to a specific person, and they would handle it. That's how task assignment generally happens within the UI.

Case management is probably one of the most important elements of investigations and workflows. There are two features here: Case Activity and Evidence Locker and these are attached to an individual Case. And what Case Activity does is it gives you a log of every single event that's happened. This one hasn't had a lot of activity, but it does go from start to finish. It tells you fourteen Alerts were added. Someone added me a note:

19:00-20:00
The change in status, the assignments, anything that happens to this Case including notes you may choose to integrate this into your workflow that you keep notes here. If someone notices something about a Case, put it here. If someone makes a change to a Case or notices that it's connected to another Case, these notes can go here. Any of these things can be edited, or if you put it in there yourself you can edit it. You may choose to keep notes on the Cases here, and that can keep everyone informed and on the same page with regard to what's going on with this Case activity. This can get pretty lengthy, but it's a very useful tool to keep everyone on the same page with what's going on in a Case.

20:00-21:00
Likewise, Evidence Locker, is a way that you can add files. If there is an exchange of emails you can add this here. You can add a .CSV, a PDF, or an email file in this Evidence Locker and that keeps track. Another thing that's really useful to do here is if you have research that's been done on a certain type of activity that's not really well understood by everyone. You could add these files here. I've done this before where I would do research into a certain type of file that was found, a malicious file. You can add all the details to even just add it in a Word document and export it as a PDF and upload it here. That keeps analysts from duplicating efforts. When a Case gets escalated, it allows all that work that's been done to be passed to the next level analyst that's going to be analyzing this Case.

21:00-22:00
This is a really important way you pass information back and forth between team members, between security stakeholders, between tier-one, tier-two, tier-three analysts. Also it serves as a really useful repository that if you gather all this information and put it into a repository like a Confluence or Google Docs, it prevents analysts from having to do all this research on their own. This can serve as a very useful tool to add evidence. You can make notes here as well if you like, if you choose to keep them here. So that you're not actually in the Case Activity because the Case Activity is a log of the changes that happen. It doesn't always get added by the analysts themselves. When an assignee is changed, when a status is changed, that generates automatically. If you want to keep this Case Activity from just being very long and full of things and maybe things getting missed, you can add notes here, and this doesn't generate automatic updates. It's only analyst-created so this might be a better place to keep your evidence here.

22:00-23:00
But adding these files is a really helpful way to keep everything in one place. It's all within the tool. You're not going to five ticketing systems or different information repositories to find information about this specific Case. It's all located in one central location. And it's a really helpful way to aggregate the information that's already been generated about a specific Case.

Another feature that doesn't necessarily affect daily operations for SOC analysts but is something that analysts should be aware of is the role-based access control features within Stellar Cyber. This keeps the data that you don't want to be seen by certain people unseen to them. RBAC mechanisms ensure that only authorized personnel can access sensitive information based on their role within the organization. This helps in safeguarding privacy and security while still enabling necessary information-sharing among team members.

23:00-24:00
RBAC is a method for regulating access to computer and network resources and it's based on the roles of the individual users within an enterprise. This means that access to various parts of the platform are controlled based on the roles assigned to users. These roles determine what information in which commands a user can access or execute within the system. For example, a network operation specialist might have access to network flow data and analytics tools, but not to confidential employee or personal data or financial information. Conversely, a security analyst might

have extensive access to threat intelligence and incident-response tools, but limited access to configuration settings of the platform. By implementing RBAC, Stellar Cyber ensures that users only have access to the information and functionality necessary for their specific job functions. This minimizes the risk of unauthorized access or data breaches. This approach not only helps in securing sensitive data, but also aids in compliance with various regulatory standards that require strict access controls.

24:00-25:00
Here we see the profiles that are built into this particular system, and we'll take a look at Analyst Training User. This gives access to the training user. You can see Interflow actions, create a filter, get help, access all these things. You can create Cases. You can create Alert types. You can visualize things. You can have access to all the investigation tools, all the response tools with the exception of deleting a report, or deleting playbooks. That might not be something that you want an analyst to have access to or webhook actions. You can't add those based on these settings. This is going to be more of an administrative task, but if you find that you're not able to accomplish a certain thing in the tool it may be that your role is limited so that you cannot do things like delete receivers or delete sensor profiles or delete log sources.

25:00-26:00
That's not something you'd want an analyst to be doing. All of these are able to be configured here by an administrator. This limits access to information or to capabilities that you don't want your tier-three analyst to necessarily have because they could accidentally delete something or delete access for someone and then they're not seeing the things or they're not able to access the functions that they need to do their job. They're not able to access functions that might hurt the system or limit access to other users. This is how RBAC works and this is just for your awareness so that you know that there are these configurations here. And that if you're not able to accomplish a certain task, it may be because you don't have access to that specific functionality.

26:00-27:00
Another feature in Stellar Cyber that is also more of an administrative function but that should be in the consciousness of SOC analysts in case these features help create a more-efficient workflow is API integrations with other tools. For example, Stellar Cyber's platform can integrate with other security tools, ticketing systems, and communication platforms like Slack and Microsoft Teams through APIs. This allows for the seamless exchange of information and Alerts between systems, facilitating broader collaboration across the security ecosystem. And some examples of these things that you might want to integrate into your workflow that the APIs can accomplish for you are creating, deleting, and listing connectors, lookup tables, reports, and security event filters. It can also retrieve detailed sensor information, Case information, Case observables, information on the configuration and hits of log filters and user activity logs for Stellar Cyber user accounts.

27:00-28:00
It can update Case information for you. It can create, delete, update, and list tenants and tenant groups. It can update tags, status, and comments for events. It can perform an Elasticsearch query on a specific index. It can reset user passwords, and it can add events to the security index either bulk

or standard. These are higher-level functions that may or may not be useful for an analyst to integrate into their workflow, but it's useful to have the knowledge of this in case you can use it in your daily operations.

Another really useful feature that we have here in this Stellar Cyber user interface is visualization and dashboard tools. These interactive dashboards provide a comprehensive view of the security posture, incidents, and Alerts. These dashboards can be customized to meet the needs of different stakeholders, providing them with relevant information at a glance.

28:00-29:00
Here we see one of them. We won't spend a lot of time talking about this because we discussed dashboards earlier, and because there is a lesson on visualizations and dashboards in this course, but anything that you wanted to visualize you could put into a visualization and have a ready dashboard so that you can take a look at any type of information in an analyst-friendly graphic view to show you this information. It helps to create these dashboards so that you can look at specific sets of information that you want to view on a daily or weekly basis without having to search it. You can have these metrics available for other security stakeholders or other teams, and it shows at a glance a lot of useful information that you can use as part of your workflow.

Another important feature is threat-intelligence sharing. This is the ability to incorporate and share threat intelligence among team members.

29:00-30:00
This can include details about indicators of compromise, tactics, techniques, and procedures of adversaries, and other threat intelligence that can inform and enhance security teams' response to incidents. An example here is the Mimikatz's credential dump. You can hop out into the MITRE ATT&CK technique, and share this here. We'll put this in the Evidence Locker. This allows sharing of information without having analysts duplicate efforts on the system or doing this research. It streamlines investigations and makes access to important information available to every user of the system. Sharing threat-intelligence information with other analysts is a valuable tool to integrate into your workflow.

30:00-31:00
One of the most effective tools in the Stellar Cyber toolkit is playbook automation. Automated playbooks are a core component of workflow automation, enabling security teams to define and execute response scenarios for common types of incidents automatically. These playbooks can perform a range of actions, from sending notifications and gathering additional information, to isolating affected systems, and applying security patches. Let's take a look at how this works. If we want to create a playbook, we can give it a name. Run it on an interval we choose. Choose our tenants or indices. Choose the rule type–either query or correlation rule. Then we can choose a query that we've created and add an action. If we see this type of behavior, this credential-dumping behavior, we can either send an email, send a Slack message, enable a webhook connection, trigger a firewall or security switch, create an Alert, disable a user, or run a script.

31:00-32:00
And so we can fill out all of these if an email is going out and then submit this and we will cover this in greater depth in the playbook lesson.

The last couple of functions we'll look at are Alert triage and investigation tools. The Alert triage options in the tool help in prioritizing Alerts based on severity, confidence score, and other criteria to ensure that the most critical Alerts are addressed first. It supports quick sorting, filtering, and searching of Alerts to streamline the triage process. This is treated in greater depth than other lessons. The triage of Cases and Alerts is one of the most important workflow concepts you should be aware of and be knowledgeable of in the tool. Because this is how you get investigations and triage done.

Lastly, investigation tools. In Stellar Cyber, their integrated tools for deep investigation to facilitate the examination of incidents and Alerts.

32:00-32:45
These include capabilities for querying historical data, analyzing network traffic, examining log files, and using threat intelligence to understand the scope and impact of a threat. These workflow tools are part of Stellar Cyber's Open XDR platform. It's designed to break down silos within security tool sets and provide a unified, efficient, and effective approach to security operations. By leveraging these tools, security teams can significantly improve their operational efficiency, reduce response times, and enhance their overall security posture. This lesson is complete. Thank you for watching.

L03 - BUILT-IN INVESTIGATION VIEW

L03B-DEMO: Built-In Investigation Views (22m:00s)

00:00-01:00
Welcome to the *Built-In Investigation Views in Stellar Cyber* in the *Investigations and Workflows* module of the SOC analyst course. In this lesson we're going to take a look at the different built in investigation views you can use in Stellar Cyber to build your workflows and accomplish the outcomes you're seeking by using the tools that are built into the platform. In this lesson, we're going to look at the different views not in the order in which you see them when you log into the platform. We're going to start with the views that yield the greatest impact to your investigation. So we'll start by looking at the cases view, and then we'll move on to the Alert view, then we'll take a look at the kill chain view you see when you first log in, and next top cases view and its impact in utility, then top risky assets view, threat hunting view and user behavior and asset analytics view One of the questions we get most is where do I get started?

01:00-02:00
And this lesson is intended to give you a layout or a roadmap to the UI to show you what options are there to perform investigations to guide the creation of workflows in your SOC. So let's get going.

There are several different options in the Stellar Cyber UI to conduct triage investigations. It might be logical to start with the homepage that you see here. And start from left to right **Top Cases**, **Kill Chain** view, **Top Risky Assets**, and then move into the views that appear in the top menu. Because it's most impactful to start with Cases, we'll start with the most impactful views first. Then we'll move on to other use case views that you might want to conduct investigation and triage in. Because Cases are aggregated and correlated Alerts that allow you to knock out many Alerts at one time, we'll take a look here. This is the Cases view.

02:00-03:00
We can minimize these charts on the right to get more real estate to look at, but this view is found under Cases, and it allows you to do triage of the Cases you're looking at in your given period. Here we can adjust the columns. Likewise if we would like to adjust the columns that we see in this view, we can go in, autosize all columns. We can move these around if we want to sort by score. We can click the Alert score and store high to low, low to high. As an analyst we can choose which Cases are the most important to our organization. In this case Mimikatz Credential Dump is always a dangerous event because it is a hacker tool and not typically used by IT professionals outside of red teamers. This is a way that you can take a look at these and see what the names of the Cases are. The names of the Cases are named by the highest-scored Alerts within the Case. It gives you an idea of what's going on in the Case pretty efficiently so that you can choose which Cases you want to investigate first.

03:00-04:00
This allows you to do quick triage to determine which Cases you want to investigate first. It may be that you set up a workflow that your analysts go top to low, highest score to lowest score, and investigate these in that way. If you have some sort of special use case that you want to investigate like, say you have a directive to look for data loss, you might want to investigate Proofpoint first. It's up to you when you create your workflows and we'll discuss workflows later on in the module. This is what the Cases view looks like. You can sort by any of these fields and it gives you an idea of the who, what, and how many Alerts you're looking at. It may be that you want to start with the Cases that have the highest number of Alerts as an indication of the severity of the Case, or it may be that you want to knock out the maximum number of Alerts first so that when you get down to triaging Alerts after you've triaged your Cases, there's less to work with.

04:00-05:00
That is the **Cases** view. Like we talked about before, all of this is configurable. You can sort by score, you can sort by any of these fields. You can add fields if you want. This is a very useful view to get the most impact out of your daily workflow in the SOC.

Now we'll move on to the Alerts view which is under the Alerts link in the top panel. If we don't see results, it's a best practice to clear all filters. You don't want to miss Alerts because you have a persistent filter. It's important to be aware of this because you don't want to miss these Alerts because you had a filter in a different view and it persisted. We'll close these filters, take a look at the Alerts view by autosizing all columns, and what this does is it sorts all of the Alerts in your system for the given time period, and this is for the past week, by Alert type.

05:00-06:00
You have all of these Alert types. And if your workflow dictates that you need to investigate these Alerts, you could go into each one of these and see all of the Alerts that exist with this Alert type. When you click through it, you get these charts that show you a high-level view of the fidelity of the Alerts and the events over time, as well as geolocation information. Then you can go in and sort these events by adding the columns that you want. You do that by showing the column for each of these depending on what needs to be seen and for each Alert type. Generally there will be a standard set template of data fields that you want to display. In this case, the default is not showing a lot of information. We want to go edit this and we can do that in one of two ways.

06:00-07:00
We can either add this type of activities relevant fields here and there are tons of fields here. You can choose the ones that are most relevant or the ones that contain data because all Alerts won't contain data in all fields. For a command and scripting interpreter documents, it's going to have its own set of fields and you perform that analysis by looking at each set of data and determining which fields are relevant to you. This is going to be different for every log source or data source that you have within your Stellar Cyber instance. It takes a little bit of work to get it exactly like you like it, and to know which fields are important and which fields can be left out, and which fields don't contain data. It's important to know that in the Alerts view, you have all of your Alerts grouped by Alert type. You view them by clicking **View**.

07:00-08:00
You can also edit I don't have permissions. You can also delete. I would advise extreme caution in deleting Alerts because these Alerts might be present in Cases as well. If you delete these Alerts as Alerts you're going to delete them out of the Case as well. Let's take a look at the suspicious logon events. Here you have a different set of charts. You have the event count, events over time by fidelity, events by fidelity, and then geolocation if there were geolocation enrichments here. A best practice for this is when you're going through these Alerts, to just take a second and check to see if any of these are involved in Cases and this one happens to be. You want to investigate it as a Case before you investigate it as an individual Alert because as we've said, looking at it as an Alert might be misleading in a way in the sense that it might be part of a larger breach or a larger attack. You can perform your investigation over all of the data and look at it in the timeline view under the Case and then see the broader narrative that is unfolding with this event.

08:00-09:00
It's important to also notice the relevant research resources here. You can click through, if you don't know what defensive evasion consists of, you can click here. We can take a look, read the general idea of what defensive evasion is. Likewise, if we don't know what using alternate authentication material consists of we can research this here. These are very valuable resources to help analysts understand what is going on out in the network. Likewise, pass the hash might not be something that everyone is familiar with. If you're not, you can go into the MITRE ATT&CK framework website directly from the UI and find exactly what's going on in your system so that you understand it. Misunderstanding is the enemy of effective investigations in any cyber tool.

09:00-10:00
This is a very useful way for you to understand what's happening with these Alerts. I would recommend researching these until you understand it and become the expert on what types of attacks are happening in your network and what they mean. It's very important that they are understood so that you can investigate them and achieve the outcome that you're seeking in your SOC. I should add that in the Cases and Alerts views, you have all these filters like we discussed in the UI module and you can add any filter that you wish to add in this view to get to the data that you are looking for and not be overwhelmed by data that you don't care about. Also the search field, the content search field we won't go deep into depth with that, but it's a very efficient way of finding the data that you need. It's easy to create a search from a specific field.

10:00-11:00
If you're interested in, say any potentially malicious Windows event logon information, you can either filter in this data, filter out, you can copy to a clipboard, or you can copy it as a query and paste it into the search field up here. This is what it looks like. It creates the query for you. This is a pretty extensive query. We'll see what this looks like. Let's click in here. Here we've got lots of these. We can investigate these one at a time. We could pivot into the Case that they're involved in if they are, and this one is as well. It looks like the same Case. We can evaluate this as a larger event rather than just a single Alert. We'll clear this search. That's persistent as well. It's important to know that if you don't clear that, you will be missing results.

11:00-12:00
Any of these you can pivot into and see all of these particular types of Alerts that are being triggered in your environment. This is part of a Case too. It's very important that you make sure that it's not in a Case if you're investigating Alerts one off. You can also search if you're looking for CLI tech support events. You can filter this out so that that's all you see. Then you could potentially create your own Case out of this and investigate this as a unit. That's the Alerts view.

Next, we'll move back to the homepage and examine the Kill Chain view. You're probably very familiar with this view as it's the biggest thing that you see in the interface when you log in to Stellar Cyber. We'll take a look at the different stages of the Kill Chain.

12:00-13:00
After we describe what these stages represent, we'll talk about how you can use this in your workflow. The **Initial Attempts** stage marks the beginning of an attack where adversaries try various methods to penetrate the network, such as phishing, exploiting vulnerabilities, or brute-force attacks. It's critical for early detection and response as stopping attacks here can prevent further stages of the Kill Chain developing. **Persistent Foothold** means after gaining initial access, attackers establish a persistent presence within the victim's environment often used in malware or stolen credentials. This stage is significant because it allows attackers to maintain access even after initial entry points are closed, posing a long-term threat to the network. **Exploration**: in this stage, attackers explore the network to understand its layout and identify valuable targets, such as data stores and administrative accounts.

13:00-14:00
The significance lies in the attacker's aim to escalate privileges and prepare for lateral movement, making it a critical point for detecting and stopping the progression of the attack. **Propagation:** attackers move laterally across the network, spreading their reach to control additional systems and increase their foothold. This stage is crucial for the attacker to gain access to key assets and for defenders to detect and contain the spread to minimize damage. **Exfiltration and Impact** is the final stage where attackers achieve their goal. Whether it is stealing sensitive data and exfiltrating it, or causing damage such as impacts like malware and ransomware. This stage underscores the importance of timely detection and response to prevent or minimize the loss of data, financial loss, and damage to reputation. If you have the workforce available to implement this workflow, you might want to assign analysts to investigate the Alerts in the most critical phases to your organization and typically that's going to be **Exfiltration and Impact.**

14:00-15:00
This is where the most damage is done. It may be that the initial attempts in your environment are largely failing and that's not the most important thing. However, it might be that initial attempts are the place that you want to focus your efforts to prevent attacks from taking place in the first place. According to your risk matrix, according to your risk tolerance, it may be that you want to assign users to tackle **Exfiltration and Impact** first thing every morning and take a look at the Alerts that are involved in this. Here we only have eight. That's a minimal disruption of your workflow if that's the first thing you have an analyst do every morning. This, just like any other Alert that we talked about, it's worth going in and seeing if this Alert is in a Case already and then maybe attack that Case instead of just the Alert.

15:00-16:00
This is what the Kill Chain does, and it's a useful workflow tool to get to the types of attacks and the methods that attackers are using, quickly. The next view we'll take a look at is the **Top Cases** view. These Cases are your most critical Cases that show up in your system given the time period that you set. Here we've got this past week. These are the most critical Cases that we've seen in the past week. It's not all of them, but it does show you the highest risk score Cases in one quick view. You can either use this to assess what your most-critical Cases are that you need to deal with on a given daily basis, or during the time period, we've got it set for this past week, so there are a lot. But you can expand these views, the most critical fields in the Case to see your most risky Cases and evaluate them. You can click through these.

16:00-17:00
If you wanted to create a workflow that had analysts go through these Top Cases via this Top Cases view, you could do it this way because you can click directly through these links to the Case itself and do your analysis here, and conduct your investigations here. You can go ahead and assign the status of **in progress** and assign it to an analyst. If that was a workflow you implemented then this is a totally valid way to attack the most critical Cases first and that's the value of the **Top Cases** view. But it's important to realize that these top Cases are also in the Cases view. If you sort by score you'll see the same Cases here. You could evaluate it through this view or you could do it directly in the **Top**

Cases view. One important note when you're dealing with Cases is that you want to make sure when you've got this marked **in progress** and assigned to an analyst that you also assign all of the Alerts within this Case to the same analyst or to different analysts depending on how your workflow goes, and make sure that these are assigned.

17:00-18:00
What this does for you is it assures that if you have other analysts working a different workflow, say you have a group of analysts that are working in Alerts and not Cases, you might find that they duplicate these efforts and maybe dismiss the Alerts accidentally or duplicate efforts. If you assign these, then they are showing that they are assigned to an analyst and that someone is taking care of that, and that will eliminate the duplication of effort. The next view we'll take a look at is the Top Risky Assets. What this is is it falls in line with the asset analytics that we discussed in the user behavior and asset analytics. It shows you the highest risk score assets within your environment. It gives you a different view. It shows you the stages of the Kill Chain where these events are going on, and tells you what's going on on any individual asset.

18:00-19:00
You can likewise take a look at this Asset Detail view and see what this is to do this analysis the same way we discussed in the user behavior and Asset Analytics lesson. This shows you the assets that you need to potentially investigate, and you can look at them and see if they are in a Case first, and this one is, so I would advise to attack the Case itself rather than go do all the analysis on the asset on its own because if you look at it in the context of the Case it's in, it's going to give you a more complete narrative, a more complete picture of what the actual attack or breach looks like. That's the best practice. The last two investigation views that we're going to take a look at are **Threat Hunting** view and **User Behavior and Asset Analytics** view. And we won't spend a ton of time on these two topics, primarily because they're covered in other lessons, the *Threat Hunting* lesson and the *User Behavior and Asset Analytics* lesson.

19:00-20:00
I want to point out the difference in these views and how you can use them in creating workflows. With regard to threat hunting, it's under **Investigate** and **Threat Hunting**. You have these useful visualizations here, but what you also have is a list of all Alerts and they're not grouped as in the Alerts view. They're not grouped as they are in this **Alerts** view. This is all the Alerts. If you got through your Cases investigations and wanted to examine all the Alerts that are remaining outside of the Cases, you could sort this by score and get through whatever your workforce and your workflow allows you to get through. You might trim this down. You might do this daily so that you don't have an overwhelming amount of results.

20:00-21:00
This view gives you every single Alert and then you're able to either search and filter in here, or you could run a query here and find exactly the data that you want to see. You might choose to sort them by Alert score. You might choose to conduct some sort of filter or search to group the types of Alerts that you're looking for together. This is a view that contains all your Alerts that are still open and you can attack them by grouping them together or filtering however you wish. That is how you could

potentially integrate this workflow into your overall workflow. Also, we took a look at the asset analytics. This is a valuable tool to click into the assets that contain the highest risk. You might want to attack it in a similar way to filter by risk score maybe, and have your analyst look at the most risky assets in your environment.

21:00-22:00
User Behavior and Analytics is likewise the same way. You can go look at your riskiest users and analyze the riskiest users in this way. One at a time and you can filter you can add columns. This is a valid workflow to look at the riskiest users if you have the bandwidth within your SOC to attack it that way. These are the primary built-in investigation views and how they work. These have been presented in order of impact, but it may be more impactful for you to potentially move **Threat Hunting** view or **User Behavior and Asset Analytics** view up in the chain for your analyst to conduct these types of workflows and that depends on your priorities within your organization. This concludes this lesson. Happy hunting. This lesson is complete. Thank you for watching.

L04 - THINKING ABOUT CYBERSECURITY WORKFLOWS

Part 1 L04A-PRES: Thinking About Cybersecurity Workflows (09m:00s)

00:00-01:00
Welcome to the *Thinking About Cybersecurity Workflows* lesson of the *Investigations and Workflows* module. In this lesson we're going to take a look at some cybersecurity workflow concepts that are not necessarily tied directly to Stellar Cyber itself, but are general, foundational concepts that need to be considered and analysts need to be aware of when thinking about building workflows for your SOC. The topics we're going to cover today are understanding the threat landscape, Alert prioritization, asset and network mapping, integration of tools and technologies, incident response plans, roles and responsibilities for SOC analysts, role-based access control, scalability and flexibility, compliance and legal requirements, training and simulations in the SOC, continuous improvement for SOC analysts and SOC procedures, communication plans, threat intelligence integration, threat hunting, continuous training and awareness, incident documentation reporting, and stakeholder communication.

01:00-02:00
Let's get started. The SOC team should have a comprehensive understanding of the current threat landscape, including common attack vectors, potential internal and external threats, and specific risks to the organization. This understanding helps in designing workflows that are proactive rather than just reactive. Staying informed about current cyber threats is crucial for cybersecurity professionals and organizations alike. While there are numerous sources of information, three of the most respected and reliable sources for up to date and comprehensive cyber threat intelligence are:

- The Cybersecurity and Infrastructure Security Agency (CISA). As an agency of the United States Department of Homeland Security, CISA provides timely information on current threats, vulnerabilities, and security updates.

02:00-03:00

Its Alerts and advisories are invaluable for organizations looking to protect their infrastructure from emerging threats. CISA's website and mailing lists offer a wealth of resources, including best practices, mitigation strategies, and detailed analyses of threat actors and their tactics, techniques, and procedures.

- The MITRE Corporation. Known for its MITRE ATT&CK framework, MITRE provides detailed information on cyber adversaries TTPs. The attack framework is a globally accessible knowledge base of adversary tactics and techniques, based on real-world observations. This resource is instrumental for cybersecurity professionals in understanding how adversaries operate and developing effective defense strategies. In the User Interface lesson, we covered the integrations of the MITRE ATT&CK framework within the UI so that each Alert and Case you click on has links directly out into the wider web page to help you do research on what threat you're facing.

03:00-04:00

- Threat Intelligence Platforms or TIPs. Threat intelligence platforms such as Recorded Future, FireEye threat intelligence, or CrowdStrike Falcon intelligence offer real-time threat-intelligence feeds, reports, and analyses. These platforms leverage advanced analytics, machine learning, and a broad range of sources to identify and contextualize cyber threats in addition to the resources and functionalities provided in Stellar Cyber.

Subscribing to one or more of these threat-intelligence platforms can provide organizations with actionable intelligence, helping them to stay ahead of potential threats. In addition to these resources, participating in cybersecurity forums and attending conferences can also provide valuable insights into the latest cybersecurity trends and threat intelligence. Engaging with the cybersecurity community through social media, blogs, and newsletters from reputable sources can complement the information obtained from the above-mentioned platforms.

04:00-05:00

Alert prioritization. SOCs should implement an Alert triage process to prioritize Alerts based on their severity, context, and potential impact on the organization. This helps SOC analysts focus on the most critical issues first.

- Streamlined response. Stellar Cyber facilitates Alert triage through several key features and capabilities designed to streamline the process of identifying, prioritizing, and responding to security Alerts. Alert triage in cybersecurity is crucial for effectively managing the volume of Alerts generated by various security tools, and this helps analysts to focus on the most critical issues first. Here's how Stellar Cyber supports this process.

- Aggregation and normalization. Stellar Cyber aggregates data and Alerts from multiple sources across the security infrastructure. By normalizing this data into a consistent format, the platform makes it easier for analysts to assess and compare Alerts from different tools, reducing the complexity of managing a heterogeneous security environment.

05:00-06:00

- Artificial intelligence driven analytics. Stellar Cyber leverages artificial intelligence and machine learning to analyze the aggregated data for suspicious patterns, anomalies, and indicators of compromise. This analysis helps in reducing false positives and highlighting Alerts that are most likely to represent genuine threats, thereby prioritizing them for further investigation.

- Threat intelligence integration. Stellar Cyber integrates with the various threat-intelligence sources enriching Alerts with context about known threats, attackers, and vulnerabilities. This additional context is critical for assessing the severity and potential impact of an Alert, enabling a more effective triage and prioritization process.

- Automated correlation and grouping. Alerts that are related to the same Case or attack campaign are automatically correlated and grouped. This reduces the number of items an analyst needs to review by presenting a consolidated view of related Alerts. This helps to identify and prioritize the broader threat landscape over isolated incidents.

06:00-07:00

- Customizable workflows. Stellar Cyber allows organizations to customize workflows and playbooks for responding to different types of Alerts. This ensures that once an Alert is triaged, the response is swift and aligned with the organization's specific policies and procedures.

- User and entity behavior analytics. Stellar Cyber employs UEBA to establish baseline behaviors for users and entities within the network. Deviations from these baselines can trigger Alerts that due to their contextual significance may be prioritized during the triage process.

- Visualization and dashboards. Stellar Cyber provides comprehensive dashboards and visualizations that offer an at-a-glance overview of the security posture and Alert status. These tools aid analysts in quickly understanding the scope and scale of threats. This facilitates faster triage and faster decision making.

07:00-08:00

By integrating these features, Stellar Cyber enhances the efficiency and effectiveness of Alert triage processes within the security operation centers, enabling teams to respond to true threats more quickly while minimizing the distraction of false positives and low priority Alerts.

Asset and network mapping. Knowing what needs protection is as critical as knowing how to protect it. An accurate and up-to-date inventory of all assets including their criticality and the data they hold, helps in prioritizing responses. Network mapping aids in understanding how information flows and where potential vulnerabilities might exist.

- Comprehensive visibility. The Stellar Cyber security operations platform is designed to provide comprehensive visibility into an organization's assets and network infrastructure. This is crucial for effective cybersecurity management. Assets and network mapping are foundational elements that enable security teams to understand what devices and systems are present in their environment and how they are interconnected.

08:00-09:00

Here's how Stellar Cyber facilitates asset network mapping.

- Discovery and inventory. Stellar Cyber automatically discovers and catalogs all assets within an organization's network including servers, work stations, mobile devices, and IoT devices. This inventory process is essential for asset mapping as it identifies the devices that need to be protected and their characteristics, such as operating systems, installed software, and open ports.

- Network traffic analysis. By analyzing network traffic, Stellar Cyber can map out how assets communicate with each other and their external systems. This network mapping allows security teams to see the flow of data across their environment. This network mapping allows security teams to see the flow of data across their environment, identify potential choke points, and detect unusual patterns of communication that may indicate a security threat.

Part 2 L04A-PRES: Thinking About Cybersecurity Workflows (11m:15s)

00:00-01:00

- Segmentation and grouping. The platform allows for the segmentation and grouping of assets based on various criteria, such as function, location, or sensitivity. This organizational feature aids in managing security policies and controls more effectively as it enables tailored protection strategies for different asset groups.

- Integration with existing tools. Stellar Cyber can integrate with other security and IT management tools to enrich its asset and network maps. By pulling data from, for example, vulnerability scanners or configuration management databases, Stellar Cyber can provide a more comprehensive view of the security posture of each asset.

- Continuous monitoring. Assets and network landscapes are dynamic with changes occurring frequently. Stellar cyber's platform continuously monitors the network for new devices, changes to existing devices, and alterations in network topology ensuring that the asset and network maps remain accurate and up to date.

01:00-02:00

By providing these capabilities, Stellar Cyber enables organizations to maintain an accurate and detailed understanding of their digital infrastructure. This insight is critical for identifying vulnerabilities, responding to incidents, and planning security measures that are appropriately tailored to the organization's specific environment.

Integration of tools and technologies. SOCs use a variety of tools including:

- SIEMs
- Intrusion detection systems, and
- Threat intelligence platforms

Effective workflows require seamless integration of these tools to automate data collection, analysis, and response actions as much as possible. This reduces manual effort and speeds up response times. Stellar Cyber integrated much more than this. In addition, Stellar Cyber is capable of integrating much more than these types of platforms. For more information on the architecture of the Stellar Cyber platform, see the *What is Open XDR* module of this course.

02:00-03:00

- Artificial Intelligence and Machine Learning. Stellar Cyber helps to automate your workflow by leveraging advanced artificial intelligence and machine-learning algorithms to analyze security data across the network in real time. This identifies threats and anomalies efficiently. It integrates with a wide array of security tools and systems, orchestrating coordinated responses to detected incidents without requiring manual intervention for every Alert. This helps streamline the process of threat detection, analysis, and response. Also this automation not only accelerates the SOC's operations, but it significantly reduces the chances of human error, ensuring a more consistent and effective cybersecurity posture.

Incident response plans. A well-defined IRP is essential. It should outline clear procedures for detecting, analyzing, containing, eradicating, and recovering from incidents. Each phase of the incident response should have associated workflows detailing the specific steps to be taken, who is responsible, and the expected outcomes.

03:00-04:00

- Predefined and organized approach. An incident-response plan is a critical component of security operation center operations. It serves as a predefined and organized approach to addressing and managing the aftermath of a security breach or cyber attack. The importance of having such a plan in place includes:
    - Preparedness. It ensures that the SOC team is prepared to swiftly and effectively respond to incidents, minimizing the time it takes to address threats.
    - Reduced impact. By having clear procedures to follow, the SOC can mitigate the impact of security incidents on the organization, potentially saving significant costs and protecting the organization's reputation.

- Efficiency and consistency. An incident-response plan that provides a consistent protocol for the team to follow reduces confusion and ensures that every member knows their role and responsibilities. This leads to more efficient handling of incidents.

04:00-05:00

- Compliance. Many industries have regulatory requirements that include having an incident-response plan. It helps in maintaining compliance with these regulations, and avoids potential legal and financial penalties.

- Continuous improvement. Regularly testing and updating the incident-response plan based on new and lessons learned from past incidents ensures the SOC evolves and improves its defense mechanisms over time. In essence, an incident-response plan is fundamental to the operational effectiveness of a SOC. It enables it to protect the organization's information assets against the ever-evolving landscape of cyber threats.

Speaking of roles and responsibilities, clearly defined roles and responsibilities ensure that team members know their specific duties during an incident. This clarity helps in reducing confusion and overlap of efforts during high-pressure situations.

05:00-06:00

Cybersecurity operations within an organization typically encompass a range of roles, each with specific responsibilities aimed at protecting the organization's digital assets from threats. Every SOC is going to be different and every information security team is going to be different in its size and scope and capabilities. This list contains a sample of roles that you might encounter in the SOC.

- The Chief Information Security Officer or CISO. The CISO is a senior-level executive responsible for establishing and maintaining the enterprise's vision, strategies, and program to ensure information assets and technologies are adequately protected. They make high-level decisions related to cybersecurity policies and strategies.

- The SOC manager. The SOC manager oversees operations of the SOC, managing the team and resources dedicated to monitoring and analyzing the organization's security posture on an ongoing basis. They ensure that potential security incidents are correctly identified, analyzed, defended, investigated, and reported.

06:00-07:00

- Cybersecurity analysts. Cybersecurity analysts work within the SOC to monitor and analyze the organization's security systems for any sign of compromise. They investigate security Alerts, and they implement protective measures. They are pivotal in identifying, assessing, and mitigating vulnerabilities and threats. You may have different tiers within your SOC. Typically it's tier one, two, and three. A tier-three analyst will do triage and then up to tier one will do the advanced analysis on threats in your network.

- Incident responder. It might be that you have enough resources to have a dedicated incident responder. An incident responder is a specialist who steps in after a security breach or cyber attack has been identified. Their role is to manage the response, including containment, eradication of threats, recovery of systems, and mitigation of damage. They also work on lessons learned and improving future response efforts. This might also be called a tier-one analyst.

07:00-08:00

- Threat hunter. Threat hunters proactively search through networks to detect and isolate advanced threats that evade existing security solutions. They use knowledge of the latest cybersecurity trends and threats to anticipate and neutralize threats before they result in breaches.

- A vulnerability analyst or penetration tester. These professionals are tasked with identifying, assessing, and prioritizing vulnerabilities in network systems. Penetration testers or pin testers as you may hear, attempt to breach computer and network protections as a way to find and fix security vulnerabilities.

- Security architect. A security architect designs, builds, and oversees the implementation of network and computer security for an organization. They are responsible for creating complex security structures and ensuring they work.

- Compliance officer. It may be that you have a compliance officer on your team. They often work closely with the CISO.

08:00-09:00

The compliance officer ensures that cybersecurity policies and procedures are designed to comply with relevant laws, regulations, and policies. They are responsible for auditing and ensuring that the organization adheres to external regulatory requirements and internal policies.

Each of these roles contributes to a comprehensive cybersecurity strategy, which is aimed at safeguarding the organization's information systems and data from cyber threats, and ensuring the business's continuity in the face of incidents. The exact titles and responsibilities for these roles may vary depending on your organization, and may vary by an organization's size, industry, or specific needs.

Role-based access control, or RBAC. RBAC defines access controls and permissions based on roles within the SOC to ensure that team members have access only to the resources necessary for their duties. It's a form of assigning least privilege. This minimizes the risk of internal threats and data breaches.

09:00-10:00

As we talked about in the *Workflow Tools in the Stellar Cyber User Interface* lesson, this is essential to keep data secure and only in the hands of those who need it. Outside of the SOC, it's probably a

good idea to make friends with the Windows security team or the Active Directory team that assigns permissions and access. This way you're able to reach out to that team and ask them if a user has permission to a certain system or not. Knowing what permissions users have, is a critical piece of understanding what user should or should not be accessing.

Scalability and flexibility. Cyber threats are constantly evolving. Workflows should be designed to be both scalable and flexible. This means they can be adapted or expanded in response to new threats, technologies, or changes in the organization's structure or priorities.

- Scalability. The Stellar Cyber platform enhances scalability in cybersecurity operations through its distributed architecture and flexible deployment options. This accommodates the growing volume and complexity of data as organizations expand.

10:00-11:15

- Artificial Intelligence and Machine Learning. The Stellar Cyber platform leverages advanced artificial intelligence and machine learning algorithms to automate threat detection and response processes. This enables security teams to efficiently manage an increasing number of Alerts without proportionally increasing staff.

- Seamless Integration. The platform integrates seamlessly with existing security tools and infrastructure. This allows organizations to add new technologies and data sources without disrupting their operations.

- Normalize and Correlate Data. Additionally, Stellar Cyber's ability to normalize and correlate data from disparate sources ensures that as an organization's digital environment grows, its security operations can scale accordingly, maintaining a high level of protection without compromising performance.

- Compliance and legal requirements. Workflows must align with regulatory compliance and legal requirements relevant to the organization's industry and geography. This includes considerations for data privacy, breach-notification laws, and industry-specific security standards.

Part 3 L04A-PRES: Thinking About Cybersecurity Workflows (15m:30s)

00:00-01:00

Cybersecurity compliance issues often stem from the need to adhere to various regulations and standards designed to protect sensitive information. For organizations, navigating these regulations can be challenging, but failing to comply can lead to significant penalties, data breaches, and loss of reputation. Here are four of the cybersecurity compliance issues that organizations frequently face.

- Data protection and privacy. Regulations such as general data protection regulation, or GDPR in the European Union and the California Consumer privacy act, or CCPA, in the United states impose strict rules on how personal data must be handled and protected. Organizations must ensure that they have adequate controls in place to secure personal

data, provide transparency about how the data is used, and allow individuals to control their information. Failing which they can face hefty fines.

01:00-02:00

- Industry-specific regulations. Many industries have specific compliance requirements designed to protect sensitive information. For example, the health care sector must comply with the health insurance portability and accountability act, or HIPAA, in the US. This safeguards medical information. Similarly, financial services organizations are subject to the payment card industry data security standard, or PCI DSS, and regulations like the Sarbanes Oxley Act, or SOX, which dictate how financial data must be handled and reported.

- Security incident reporting and response. Laws and regulations increasingly require organizations to report cybersecurity incidents within a specific time frame. For instance, GDPR mandates notification of personal data breaches to the relevant supervisory authority within seventy two hours of becoming aware of the breach. Failure to promptly report breaches or to have an effective incident-response plan can result in fines and other penalties.

02:00-03:00

- International data transfer. Organizations operating across borders face complex compliance challenges. Especially when transferring data between countries with different privacy laws. The invalidation of the privacy-shield framework and the ongoing scrutiny of standard contractual clauses complicates compliance with international data transfer requirements under GDPR and other privacy laws. To navigate these compliance issues, organizations need a robust cybersecurity framework that includes strong data-protection measures, regular compliance audits, employee training on data privacy, and a clear understanding of the regulatory landscape affecting their operations. This approach helps minimize the risk of noncompliance and ensures the organization can respond effectively to legal and regulatory changes.

03:00-04:00

Training and simulations. Regular training and simulation exercises, such as tabletop exercises, and red team/blue team activities are important for ensuring that the SOC team is prepared and workflows are effective. These exercises can identify gaps in the workflows and areas for improvement. A cybersecurity tabletop exercise is a discussion-based session where team members walk through various cybersecurity scenarios to assess the effectiveness of their incident-response plan and identify areas for improvement. Here is a brief example of such an exercise. The scenario is your organization faces a sophisticated phishing attack leading to the compromise of sensitive customer data. The attackers have gained unauthorized access to the company's customer relationship management system, or CRM. and have exfiltrated a significant amount of personally identifiable information or PII. Participants in this exercise could include some of the following roles: CISO, IT security team, legal counsel, public relations manager, customer service manager, and representatives from the affected business units.

04:00-05:00

The exercise phases for these tabletop exercises could include the following:

- Detection. The IT security team explains how the phishing attack was detected, the initial steps taken, and how the breach was confirmed. Participants discussed the effectiveness of the detection mechanisms and the timeline of events.

- Containment. The team discusses the actions taken to contain the breach, including isolating affected systems, revoking access permissions, and implementing additional security measures to prevent further data loss. They evaluate the immediate response actions for effectiveness and timeliness.

- Eradication and recovery. Participants outline the steps to remove the threat from the compromised systems, such as removing malicious files, resetting passwords, and patching vulnerabilities. They then discuss the recovery process to restore affected services and data from backups, ensuring no remnants of the attack remain.

05:00-06:00

- Notification and communication. The legal counsel reviews legal and regulatory obligations regarding breach notification, while the public relations manager presents the communication plan to the stakeholders, including affected customers, partners, and the media. The discussion focuses on the timing, messaging, and channels for effective and compliant communication.

- Lessons learned and improvement. The group identifies lessons learned from the incident and the exercise itself, highlighting areas for improvement in the incident-response plan, employee training, technical defenses, and communication strategies. Action items are assigned for follow-up.

- The goal of this tabletop exercise is not only to rehearse the response to a specific scenario, but also to foster a culture of preparation, collaboration, and continuous improvement in the organization's cybersecurity posture.

06:00-07:00

Continuous improvement. Cybersecurity is not a set and forget operation. Regular reviews of incident response activities, lessons learned sessions, and audits of the workflows and tools in use are necessary for continuous improvement. Metrics and key performance indicators should be established to measure the effectiveness of workflows and identify areas for enhancement.

Communication plans, effective communication both within the SOC team and with external stakeholders, that is, executive management, Legal HR, is critical, especially during a security incident. The workflow should include communication protocols, specifying what information is communicated to whom, and at what frequency. It could be argued that effective communication is the most important part of SOC operations because having the right stakeholders involved during an incident is incredibly important to SOC operations.

Threat intelligence integration. Threat intelligence integration means that real-time threat intelligence is used to keep the SOC team informed about the latest threats and vulnerabilities.

07:00-08:00

This includes proactive threat hunting and helps in prioritizing responses based on current threat landscapes. The Stellar Threat Intelligence platform automatically integrates its own threat intelligence into its architecture, collecting, parsing, and distributing dynamic threat intelligence for multiple third-party feeds. Additionally, Stellar Cyber provides commercial and noncommercial threat-intelligence feeds from organizations such as Proofpoint, DHS, OTX, OpenPhish, and PhishTank. The threat intelligence tool normalizes and prioritizes the feeds before distributing them to all deployed Open XDR platforms. Stellar Cyber also allows integration of third-party threat intelligence feeds that are a custom indication of compromised files.

08:00-09:00

Threat hunting. Threat hunting is a critical part of SOC operations. Workflows can be automated for repetitive tasks to enhance efficiency and reduce response times. Stellar Cyber's correlation search and threat hunting library are key components designed to enhance the detection of complex threats and facilitate proactive security investigations.

- Correlation Search. The correlation search functionality allows the platform to automatically analyze and correlate data across various sources and time frames. By applying complex algorithms and patterns, it identifies relationships and anomalies that may indicate a security threat such as coordinated attacks or stealthy movements within the network that single point analyses might miss. This capability significantly reduces false positives, and helps in pinpointing real threats by understanding the context and sequence of events across the entire digital environment.

- Threat Hunting Library. Meanwhile, the threat hunting library in Stellar Cyber's platform provides a repository of predefined hunting queries and scenarios.

09:00-10:00

Based on known threat behaviors, tactics, techniques, and procedures, or TTPs. Security analysts can use this library to proactively search for indicators of compromise and potential threats that haven't triggered Alerts. This repository is continually updated to reflect the evolving threat landscape, enabling analysts to stay ahead of attackers by leveraging the latest intelligence and hunting methodologies.

- Playbooks. Stellar Cyber's playbooks automate the response to cybersecurity incidents by defining a series of predetermined actions and procedures that are executed when specific criteria or triggers are met. These playbooks are designed to streamline the detection, investigation, and remediation processes, reducing the time and manual effort required to respond to threats and ensuring consistent and efficient operational workflows.

Together, Stellar Cyber's correlation search, threat hunting library, and playbooks empower security teams to detect more threats faster and with greater accuracy, moving from a reactive security posture to a more proactive and predictive approach.

10:00-11:00

Continuous training and awareness. Continuous training and awareness keeps the SOC team trained and aware of the latest cybersecurity practices, tools, and threats. Regular training sessions, simulations, and red-team exercises can help in maintaining a high level of preparedness. Cybersecurity operations teams stay informed about current threats and conduct training for their members through a multifaceted approach, combining continuous education, information sharing, and practical exercise through threat intelligence feeds and platforms.

- Online forms and social media. Participating in online security forums, mailing lists, and social media groups allows team members to exchange knowledge and experiences with a broader community. These platforms can be excellent sources of information on new vulnerabilities, exploits, and defensive tactics.

- Internal training sessions and workshops. Organizations often conduct regular internal training sessions and workshops to keep their teams up to date on their own security policies, procedures, and the specific technologies that they use. These sessions may cover new security tools, incident-response strategies, and updates to compliance requirements.

11:00-12:00

- Hands-on exercises. Practical exercises such as tabletop simulations, red/blue team exercises, and penetration testing are integral to training. These exercises simulate real-world scenarios and attacks providing team members with hands-on experience in detecting, responding to, and mitigating cyber threats.

- Certifications and continuing education. Encouraging or sponsoring team members to pursue professional cybersecurity certifications and continuing-education courses is another way for teams to maintain a high level of expertise. Certifications from organizations like ISC2, ISACA, CompTIA, and others are widely recognized and can help professionals stay current with the evolving landscape of cybersecurity

12:00-13:00

By leveraging these strategies, cybersecurity operations teams can stay ahead of the curve, enhancing their ability to protect their organizations against sophisticated and evolving cyber threats.

Incident documentation and reporting. This means maintaining detailed records of all incidents, including detection methods, response actions, and lessons learned. This documentation is crucial for post-incident analysis, compliance, and continuous improvement of the SOC's processes. Cybersecurity operation centers manage incident documentation and reporting through systematic

approaches to ensure accuracy, compliance, and effectiveness in their response to security incidents. Here are three key ways to achieve this.

- Centralized incident management. SOCs need to use a centralized incident management platform that allows for the logging, tracking, and analysis of security incidents in real time. This facilitates the aggregation of incident data from various sources, ensuring comprehensive documentation.

13:00-14:00

We talk extensively about this in the workflow tools in Stellar Cyber and Case management lessons of this course. Stellar Cyber's Case Activity and Evidence Locker are two main ways to house incident documentation and manage it in a single location. They also provide features for categorizing incidents, assigning severity levels, and maintaining detailed records of the incident response process, including actions taken, decisions made, and the rationale behind them.

- Standardized reporting templates and protocols. To maintain consistency and completeness in incident reporting, SOCs often employ standardized reporting templates and follow strict protocols for documenting incidents. These templates ensure that all relevant information is captured, such as the date and time of detection, the nature of the incident, affected systems, impact assessment, response actions, and lessons learned.

- Standardized protocols also guide the timing and procedure for internal and external reporting, ensuring compliance with regulatory requirements, and facilitating communication with stakeholders.

14:00-15:00

- Post-incident reviews and lessons learned. After resolving an incident, SOCs conduct post-incident reviews to analyze the incident-handling process, document lessons learned, and identify areas for improvement. These sessions are critical for refining incident-response strategies and updating policies and procedures. The insights gained are documented and incorporated into training materials, playbooks, and policies to improve future incident-response efforts and cybersecurity resilience.

By employing these methods, SOCs ensure that incident documentation and reporting are thorough, systematic, and leveraged to enhance the organization's cybersecurity posture over time.

Stakeholder communication. It's important to establish clear communication channels and protocols for internal and external stakeholder communication during and after an incident. Keeping stakeholders informed is essential for managing expectations and coordinating response efforts.

15:00-15:30

These concepts are explored in the workflow's lessons of this module. Every organization is different and has different resources available to them. It is very important that security stakeholders and their

capabilities be identified and a list of contact information for these individuals or groups be made available to all SOC personnel. This lesson is complete. Thank you for watching.

L05 - BUILDING WORKFLOWS IN STELLAR CYBER - FOUNDATIONS

Part 1 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (14m:15s)

00:00-01:00

The next lesson in the *Investigations and Workflows* training module is *Building Workflows in Stellar Cyber - Foundations*. Welcome to the *Building Workflows and Stellar Cyber - Foundation*s lesson of the investigations and Workflows training module. Today we're going to look at some foundational concepts related to building workflows in your SOC. Our agenda goes as follows. First we're going to be talking about defining objectives in your SOC to achieve the outcomes that you desire. Next we're going to talk about mapping out your workflow structure to talk about how the data will flow from investigation and triage into remediation or knowledge sharing with other partners. Next we'll talk about partner roles and responsibilities and the relevant parties that represent the security stakeholders that need to be informed in the case of a breach or incident.

01:00-02:00

Then we'll talk about integrating and collecting data in your Stellar Cyber platform. Next we'll talk about Infosec partner platform management. Here we'll talk about all the teams that you might interact with that manage the platforms that you integrate into Stellar Cyber. They're valuable partners to have and it's important to know who these people are so that you can follow-up on actions needed to remediate threats. Next we'll talk about detection mechanisms, automated responses, we'll talk about proactive threat hunting. We'll discuss the importance of testing your workflows to make sure that what you are trying to build actually works. Then we'll talk about training and monitoring. Lastly, documentation. Now that we have an idea of what we're going to cover, let's get started.

02:00-03:00

To define cybersecurity objectives and requirements in a given industry, you need to start by conducting a thorough risk assessment to identify specific threats and vulnerabilities relevant to your industry or institution. Next, you need to align these findings with industry-specific regulatory and compliance requirements, such as HIPAA for healthcare, or PCI DSS for payment card processing. This ensures all legal and operational standards are met. Finally it's necessary to establish clear cybersecurity goals that include protecting critical assets, ensuring data integrity and availability, and maintaining confidentiality while also defining measurable outcomes to assess the effectiveness of the cybersecurity program. First, it's important to identify your key assets. You need to determine what critical data, systems, or services need protection. Stellar Cyber automatically catalogs assets on a network by continuously scanning the network traffic and identifying connected devices and their characteristics.

03:00-04:00
It utilizes advanced algorithms to classify these assets based on types such as servers, workstations, IoT devices, and more. The system also collects metadata from each asset, including operating system versions, installed software, and configurations. This detailed asset inventory is dynamically updated to provide real time visibility and aid in security monitoring and decision making. You need to assess your risks. You need to understand the specific threats and vulnerabilities affecting your organization. To best assess cybersecurity risks specific to your industry, start by conducting a comprehensive risk assessment that identifies and evaluates all potential cyber threats and vulnerabilities. Focus on industry-specific threats by analyzing recent breaches, threat intelligence reports, and guidance from industry-specific regulatory bodies. Involve stakeholders from the various departments within your organization to understand the unique processes and technologies that may be targeted by cyber criminals.

04:00-05:00
It's a best practice to regularly review and update your security measures and risk assessments to adapt to evolving threats and incorporate new technologies and practices relevant to your industry. See the *Building a Risk Matrix to Direct Workflow Creation* lesson in this module for more on this topic.

Compliance needs. It's important to consider any regulatory compliance requirements that will impact your cybersecurity strategies. Here's a list of several prominent cybersecurity compliance framework requirements, each with a brief description indicating the industry it primarily applies to. The following list primarily applies to North American SOC operations, but you need to do some research on the country in which you operate and the industry in which you operate, and make sure that you're aware of any compliance requirement frameworks that are applicable to your country.

05:00-06:00
- PCI DSS, or payment card industry data security standard. This standard applies to any organization that processes, stores, or transmits credit card information, focusing on securing credit transactions and protecting cardholder data.
- HIPAA or the health insurance portability and accountability act. This pertains to the healthcare industry. It ensures the protection of patient data and confidentiality in healthcare transactions.
- SOX or the Sarbanes Oxley Act, This is relevant for publicly traded companies, focusing on protecting shareholders and the general public from accounting errors and fraudulent practices in enterprises.
- GDPR, or general data protection regulation. This applies broadly across industries in the European Union and to entities outside of the EU that handle EU resident's personal data, emphasizing the protection of personal data and privacy.

06:00-07:00

- FISMA, or the Federal Information Security Management Act. This targets US Federal agencies, mandating the development, documentation, implementation of an information security and protection program.

- NERC CIP, North American Electric Reliability, Critical Infrastructure Protection. This applies to the power utility industry in North America, focusing on protecting critical electric infrastructure from physical and cyber threats.

- ISO/IEC 27001. This standard is industry agnostic. It provides requirements for an information security management system to help organizations secure their information assets.

- CMMC or cybersecurity maturity model certification. This is designed for defense contractors in the United States. This framework measures the cybersecurity maturity of a company and ensures the protection of sensitive defense information.

07:00-08:00

- GLBA, or the Graham Leachley Bliley Act. This applies to financial institutions. It's aimed at protecting the privacy of consumer financial information and regulating the collection and disclosure of financial data.

- And lastly, CCPA or the California Consumer Privacy Act. This is relevant to businesses operating in California or handling the personal information of California residents. It focuses on enhancing privacy rights and consumer protection.

All these are good example frameworks by which you can build your workflows to make sure that you are compliant with the requirements in your country for your industry and they also provide best practices for securing networks and maintaining the integrity and availability of your information securely.

Mapping out your workflow structure. You should make a plan whereby you have tiered analysts and experts in certain areas conducting the operations that are appropriate for them.

08:00-09:00

You should also be aware of your information security stakeholder partners and have their contact information readily available. It's also important to pay attention to the incident-response phases. You should outline the phases of your incident response plan, typically including preparation, detection, analysis, containment, eradication recovery, and post incident analysis. A security operation center should begin planning an incident response plan by first identifying and prioritizing potential threats, specific to their organization's industry and infrastructure. You should then establish clear roles and responsibilities for the incident response team, ensuring all members understand their tasks during various types of security incidents. The plan should include procedures for detecting, analyzing, containing, eradicating, and recovering from security incidents. It should contain detailed steps and protocols for each phase. It's crucial to integrate communication strategies within the plan to ensure timely information sharing with stakeholders and regulatory bodies as it's required.

09:00-10:00
Finally, regular drills and simulations should be conducted to test the effectiveness of the incident-response plan with results used to refine and improve the procedures continuously.

Rolls and responsibilities. It's important to define who is
for each step within the workflow. This includes security analysts, IT staff, and management. Here are some typical roles involved in security operation center operations along with a brief description of each role.

Your unique organizational personnel resources may not allow for the staffing of all these positions, but consider the following list a primer of roles and responsibilities that you might find in a typical information security group.

- SOC Manager: The SOC manager oversees the entire SOC, managing the team, defining security strategies, and ensuring alignment with the organization's cybersecurity policies.

10:00-11:00

- Incident Responder: This person handles security breaches and attacks by performing immediate containment, eradication, and recovery tasks to minimize the impact on the organization.
- Threat Hunter: This person proactively searches through networks and datasets to detect and isolate advanced threats that evade existing security solutions.
- Security Analyst: They monitor network traffic and analyze Alerts to identify potential security threats and vulnerabilities.
- Forensic Analyst: This person specializes in investigating and analyzing evidence from cyber attacks and breaches to understand the source, method, and impact of the intrusion.
- Compliance Auditor: They ensure that all operations comply with relevant laws, regulations, and standards by regularly reviewing and auditing the security practices and procedures.

11:00-12:00

- Network Engineer: This person focuses on the security and operation of the network infrastructure. They manage firewalls, switches, routers, and other networking devices from a security perspective.
- Cyber Intelligence Analyst: They gather intelligence from various sources to inform the SOC of potential or emerging threats and vulnerabilities. This aids in proactive defense measures, and
- Security Architect: This person designs robust security structures to protect systems from threats and is often involved in building and maintaining the SOC cybersecurity infrastructure.

Partner roles and responsibilities. It's possible that you will be required to interact with the following groups:

- The security operation center team: They monitor, detect, investigate, and respond to cybersecurity incidents and threats in real time.
- The cyber incident response team: They specialize in managing the response to security breaches including containment, eradication, recovery, and post incident analysis.
- Threat intelligence team: They gather, analyze, and disseminate information on current and potential threats to inform the organization's security strategies.
- The vulnerability management team: They're responsible for identifying, classifying, remediating, and mitigating vulnerabilities in software and systems.
- The security compliance and audit team: They ensure that the organization adheres to relevant security standards and regulations. They perform internal audits to measure compliance.
- Application security team: They specialize in ensuring that all corporate applications are secure from design to deployment, often incorporating secure coding practices.

13:00-14:00

- The identity and access management team: They manage user identities and control access to ensure that employees have appropriate access rights to systems and data.
- The security awareness and training team: They develop and deliver training programs to educate employees about security best practices and emerging threats.
- The data protection team: They focus on securing enterprise data across platforms and locations, including data at rest, in transit, and in use.
- The security architecture team: They design and implement security frameworks and architectures that support the organization's overall security posture, and lastly
- The forensic analysis team: They investigate cybersecurity incidents to uncover the root cause and gather evidence for potential legal actions.

All these groups are important to know because you may have to lean on them to get information or to document your processes so that you can pass this information on, or secure it for reference later on.

14:00-14:15

It may not be that your organization has all these teams or they may even have more teams than this. It's very important to know that these types of teams exist, and you should leverage them for their experience and expertise.

Part 2 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (11m:30s)

00:00-01:00
Let's talk about configuring data collection and integration. We'll start with data sources. One of Stellar Cyber's major strengths is the ability to integrate various data sources into one platform. These include data from network devices, endpoints, cloud environments, and third-party intelligence feeds among others. We'll talk about these data sources in the next slide.

Normalization and enrichment. It's important that data from different sources is normalized to allow for effective analysis. Stellar Cyber automatically normalizes data into a common format. Stellar Cyber's Interflow technology serves as an advanced data-processing system that normalizes and enriches incoming security data from various sources across the network. This process involves converting disparate data formats into a consistent and uniform format, making it easier to analyze and correlate information across different types of security events.

01:00-02:00
Additionally, Interflow enhances the data by appending contextual information, such as threat intelligence, geolocation, and asset details, which aids in creating a more comprehensive security perspective. These capabilities allow security analysts to effectively detect, investigate, and respond to threats by providing a holistic view of network activities in a streamlined and actionable manner. These features enhance your workflow because you are creating a workflow out of lots of different log sources, lots of intelligence created within the Stellar Cyber platform. All these work to your advantage because it presents a more comprehensive narrative that other teams may not have. I mentioned earlier that looking through just one platform, say your IAM platform, your EDR platform, your DLP platform, is like looking at your network through a coffee straw. You can't see much of it at one time.

02:00-03:00
This allows you to integrate a workflow that specializes in seeing the whole picture through all the different data sources that you have coming into Stellar Cyber normalized into a way that they can all be integrated together and presenting it all in one picture. It's a really comprehensive way to build effective workflows. One of the things that you will find as a SOC analyst that is working in a platform that integrates all these different types of information is that you become a subject-matter expert on your network in general. People will come to you and say, “Hey, can you present me a report or a dashboard that shows me all this information?” that they may or may not have ready access to but that you'll be able to present to them in a way that shows a comprehensive view of all the different platforms that are being ingested in the Stellar Cyber simultaneously. In this slide we're going to take a look at the different types of data that comes in. This is not a complete list but it is a list of the important ones.

03:00-04:00
We're looking at SIEM and this is going to be a SOC-based task probably. But the SIEM is important in that it provides real-time analysis of security Alerts generated by applications and network hardware.

You may have Stellar Cyber as your next-gen SIEM or you may have another SIEM platform that's being ingested into Stellar Cyber. Either way, it's a critical piece of the security architecture.

- Endpoint detection and response, or EDR. This monitors in response to threats on endpoints such as laptops, desktops, and mobile devices. It provides advanced threat detection, investigation, and response capabilities.

- Network detection and response, or NDR. This focuses on network traffic to detect and respond to threats across the network environment. You can use Stellar Cyber for your NDR or there may be another platform that's integrated into your Stellar Cyber platform. Either way, network detection and response is critical to your security posture.

04:00-05:00

- Vulnerability-management systems. These scan, identify, and help mitigate vulnerabilities within an organization's network and software systems.

- Firewall-management platforms. These manage and monitor firewall rules and policies to ensure network security and prevent unauthorized access.

- Intrusion detection system or intrusion prevention system (IDS, IPS). These detect and prevent suspicious activity within the network potentially blocking harmful traffic.

- Host-intrusion and network-intrusion detection systems function in the same capacity. Your group might call it “HIDS” or “NIDS,” host-intrusion detection and network-intrusion detection.

- Identity and access management, or IAM. These manage digital identities and specify user roles. They ensure that individuals have appropriate access to technology resources.

05:00-06:00

- Data loss prevention, or DLP. These products monitor, detect, and prevent data breaches and data exfiltration by ensuring that users do not send sensitive or critical information outside the corporate network. This is a critical system. You will probably interact with it quite a bit, because data loss is so important to organizations. They want to prevent that.

- Cloud Access Security Broker, or CASB. This provides security-policy enforcement and protects organizations cloud-based applications and services.

- Threat-Intelligence platforms. Whether outside of Stellar Cyber or with the native threat-intelligence information that comes into Stellar Cyber, these collect, aggregate, and analyze threat data from various sources to provide actionable intelligence.

- Email security platforms. These protect against phishing, malware, and other threats that use email as an attack vector.

06:00-07:00

- Web security gateways. These monitor and control traffic coming in and out of an organization over the web, blocking malicious activities and websites.
- Mobile device management, or MDM, as well as mobile application management or MAM. These secure and manage mobile devices and applications across an organization.
- Encryption stakeholders or tools. These provide data-encryption solutions to secure sensitive data at rest and in transit.
- Configuration management database, or CMDB. This manages information on all the hardware and software assets and their configurations across the IT environment.
- Penetration testing tools. These simulate cyber attacks against your computer system to check for exploitable vulnerabilities.
- And lastly, cybersecurity training platforms. These educate employees about cybersecurity best practices and how to recognize potential security threats.

07:00-08:00
All these platforms play a critical role in forming a robust cybersecurity posture. They enable comprehensive protection against a wide array of cyber threats. Each platform contributes to a layered security strategy and ensures that the organization's data and systems are protected from multiple angles. Any or all these may be incorporated into your workflow. You may choose to prioritize data-loss protection or you may choose to prioritize EDR events in your environment. It depends on what your organization feels is the most important threat that you need to mitigate and detect and protect against. All these things you need to be aware of because they are going to play a part in your workflow-creation strategy. Setting up detection mechanisms. Stellar Cyber functions as a value-adding detection mechanism for cyber threats by employing a comprehensive approach that integrates various data inputs from across the network, including endpoints, servers, and cloud environments.

08:00-09:00
It utilizes advanced analytics, machine-learning algorithms, and behavioral-detection techniques to identify anomalies and potential threats that deviate from normal operations. After a threat is detected, the system Alerts security analysts and provides detailed contextual information, enabling rapid assessment and response to mitigate the impact of the threat. Outside of the functions in Stellar Cyber itself, which provide a robust array of detection tools, some considerations need to be addressed from an official point of view.

Rules and policies. You need to configure detection rules based on known threats, anomalous behaviors, and compliance requirements. Stellar Cyber allows for the customization of rules to fit specific organizational needs. If you intend to be part of the creation of these rules and policies, it's important to have input and **buy in** from the following potential key stakeholders.

09:00-10:00

The creation of cybersecurity rules and policies is most often a collaborative effort involving several key roles and departments. These may potentially include:

- The Chief Information Security Officer, or CISO. The CISO is usually the primary leader responsible for overseeing the development of cybersecurity policies and ensuring they align with the organization's overall security strategy and business objectives.
- The InfoSec team. This team led by the CISO, includes security analysts, managers, and other cybersecurity professionals who provide technical expertise and operational insights necessary for crafting effective policies. The workflows you develop should be designed to get the positive outcomes you want to adhere to these policies.
- Your IT group. The IT department works closely with the information security team to ensure that the policies are practical and can be implemented within the existing IT infrastructure.

10:00-11:00

- Legal and compliance departments. These departments ensure that cybersecurity policies comply with relevant laws, regulations, and industry standards, helping to manage legal risk associated with information security.
- Executive management. Senior management, including the CEO and other executives, must endorse these policies to ensure they have the authority and resources necessary for implementation and enforcement across the organization.
- Human resources. Human resources often collaborates in the creation of policies that deal with employee behavior, data-handling practices, and security training programs. These stakeholders ensure that the cybersecurity policies are comprehensive, enforceable, and align with the business's risk-management strategies and they are important stakeholders to include in the creation of your workflows.

Machine-learning models. Stellar Cyber's machine learning capabilities are leveraged to detect unusual activities that may indicate sophisticated attacks.

11:00-11:30

It uses machine learning to enhance threat detection by analyzing a vast amount of network and security data to identify patterns and anomalies indicative of malicious activities. These machine-learning algorithms are trained on historical security data and real-time input to continuously improve their accuracy and effectiveness in detecting known and emerging threats. This allows Stellar Cyber to provide proactive and predictive security measures, significantly reducing the time to detect and respond to potential threats across an organization's digital environment.

Part 3 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (06m:50s)

00:00-01:00
Automated responses. Stellar Cyber facilitates the creation of playbooks. You should develop and implement playbooks in Stellar Cyber that automate responses to common types of security incidents. These can include steps like isolating a compromised device, blocking IP addresses, or notifying team members. Stellar Cyber facilitates automated playbooks by enabling security teams to predefine response actions for various types of cyber threats. This streamlines the incident-response process and should definitely be integrated into your workflows. These playbooks are integrated into the Stellar Cyber security platform allowing for automatic execution of specified actions, such as isolating affected systems, blocking malicious IP addresses, or sending Alerts when certain conditions are met. This automation not only speeds up the response time, but also ensures consistency and accuracy in handling security incidents. This reduces the risk of human error.

01:00-02:00
These actions are crucial to integrate into your workflow. Doing so saves analysts time and energy following up on known events that occur frequently.

Alert configuration. You should set up Alerts to ensure that the right people are notified promptly about potential security incidents.

Stellar Cyber's platform facilitates sending notifications to other team members through its integrated communication and Alerting system, which can be customized based on specific security events or thresholds. The system allows for configuration of various notification methods, including email or through integrated third-party communication tools like Slack. This ensures that team members receive timely and relevant Alerts, enabling a swift and coordinated response to potential security incidents. Be sure to consider the relevant stakeholders. The individuals and groups in the previous slides are a good reference for deciding who needs what types of Alerts from the SOC.

Implement threat-hunting protocols.

02:00-03:00
Proactive searches. You should integrate these into your workflows, and use Stellar Cyber's tools to conduct proactive threat hunting. You should look for hidden threats that bypass initial detection layers. Stellar Cyber enhances proactive cyber threat hunting by utilizing advanced analytics and machine learning to sift through network traffic and logs.

It identifies anomalies and potential threats that may evade traditional detection methods. The platform aggregates and correlates data from various sources, providing a comprehensive view that enables security analysts to pinpoint suspicious activities and investigate them thoroughly. Additionally, Stellar Cyber offers tools for deep-dive investigations and historical data analysis, allowing threat hunters to uncover hidden patterns and preemptively address security issues before they escalate. Personnel resources will weigh heavily in how much energy can be devoted to

proactive threat hunting. Staying current on the evolving threat landscape and dedicating analysts to the pursuit of new and novel threats is a best practice and is worth the resources dedicated to it in most cases.

03:00-04:00
Historical data analysis. You should regularly analyze historical data for patterns that could indicate slow-building threats or breaches.

Stellar Cyber facilitates the analysis of historical data by providing a centralized storage and retrieval system that archives various types of security data such as logs, events, and network flows. The platform uses powerful querying and visualization tools that we discuss in other lessons that enable security analysts to efficiently sift through historical data, identify trends, and conduct root-cause analysis of past incidents. This capability allows organizations to learn from previous security events, refine their defensive strategies, and enhance the overall security posture by understanding and mitigating recurring threats.

Reviewing and testing the workflows. Simulation. You should test workflows with simulated attacks to see how your organization responds and to refine the workflows as necessary.

04:00-05:00
Cybersecurity teams should use simulation exercises such as penetration testing and red team/blue team drills to realistically mimic potential cyber threats and attacks. This provides a practical context for honing security skills.

These simulations should be designed to cover a variety of scenarios from common phishing attacks to sophisticated state-sponsored hacking, to ensure the team can respond to a wide range of threats. During these exercises, teams should practice detecting, containing, and mitigating attacks using their existing tools and protocols, which helps to identify gaps in the response strategies and infrastructure. After each simulation, it's crucial to conduct thorough debriefings to discuss what was learned, what went well, and what could be improved. To foster a culture of continuous learning and adaptation, regularly scheduled simulations keep security teams sharp, proactive, and ready to handle real-world security challenges effectively.

05:00-06:00
Feedback loops. After testing, you should gather feedback from all the stakeholders and adjust the workflows accordingly. Cybersecurity teams can improve feedback loops with other security stakeholders in the following three ways.

1. Regular collaboration meetings. You should establish regular meetings with key stakeholders including IT, legal, compliance, and executive teams to discuss current security postures, recent incidents, and ongoing threats. These meetings should be designed to exchange information, gather feedback, and align security measures with business objectives. Utilizing collaborative platforms and tools can further facilitate ongoing dialogue and real-time updates.

2. Shared dashboards and reporting. You should implement shared dashboards that provide real-time insights into security metrics, incident reports, and the status of ongoing investigations. These dashboards should be accessible to all relevant stakeholders and designed to easily be understood, allowing for quick data-driven decisions and feedback.

06:00-06:50

Regular reports summarizing security status, incident outcomes, and recommendations for improvements can further enhance communication, and

3. Post-incident reviews of findings. You should conduct comprehensive post-incident reviews involving all stakeholders impacted by security incidents. These reviews should assess the effectiveness of the response, identify lessons learned, and determine actionable improvements. Encouraging an open feedback culture where stakeholders can contribute insights and suggestions without blame fosters continuous improvement and strengthens the overall security strategy.

By implementing these practices, cybersecurity teams can create robust feedback loops that enhance organizational responsiveness and resilience against cyber threats.

Part 4 L05A-PRES: Building Workflows in Stellar Cyber - Foundations (06m:45s)

00:00-01:00

Train your team. Regular training. You should conduct training sessions to ensure that all team members understand their roles within the workflows and are familiar with the tools and procedures they will use. Cybersecurity operations teams should conduct regular training to ensure that all members are updated on the latest threats, technologies, and defense strategies. Training sessions should include hands-on simulations, such as red team/blue team exercises, and scenario-based drills to provide practical experience in detecting, responding, and mitigating cyber incidents. Additionally, these trainings should be supplemented with continuous learning opportunities such as webinars, workshops, and industry conferences to keep the team informed about new vulnerabilities and emerging best practices.

Continuous learning. You should keep your team updated with the latest cybersecurity trends, threats, and best practices.

01:00-02:00

Continuous learning is crucial for cybersecurity teams to stay ahead of rapidly evolving threats. Here are three of the best approaches for facilitating this ongoing education.

1. Structured training and certification programs. SOC leaders should encourage team members to pursue advanced cybersecurity certifications and training programs regularly. These can include certifications from organizations like ISC squared, CompTIA, or SANS Institute, which offer courses in areas such as ethical hacking, forensic analysis, and security

management. These structured learning paths ensure that team members have up-to-date knowledge and skills aligned with industry standards.

2. Participation in cybersecurity conferences and workshops. Actively participate in cybersecurity conferences, seminars, and workshops. These events are valuable for learning from industry leaders, discovering the latest research and networking with peers. They also provide insights into new security technologies, strategies, and trends, which can be brought back and integrated into the team's operational practices and workflows.

02:00-03:00

3. Regularly scheduled knowledge-sharing sessions. Implement a regular schedule of internal knowledge-sharing sessions where team members can present on topics they have researched, recent challenges they've faced, or new tools they have tested. Additionally, if there's a new type of attack that occurs on your network, if someone does the research and mitigation and response to that threat, they should give a presentation and talk about what that threat is. We talked about that in some of the other lessons about how important documentation is, whether it be in the Case that you're working, or whether it be in some sort of comprehensive repository to serve as a reference for analysts to not have to re-create the work that's been done by other analysts in the SOC. Rather they can go directly to this repository that you've created and find out information about a specific type of threat, like DNS tunneling, or phishing attacks, or any any type of threat on your network.

03:00-04:00

This encourages a culture of learning and information exchange within the team, ensuring that valuable insights and skills are disseminated across the organization.

These methods foster a proactive learning environment within cybersecurity teams, enabling them to adapt to the dynamic nature of cyber threats and enhance their defensive capabilities.

Monitoring and optimizing. Continuous monitoring. You definitely should use Stellar Cyber's dashboard and reporting features to continuously monitor the effectiveness of your cybersecurity workflows.

Iterative improvements. You should regularly review and refine the workflows based on new threats, technological advances, and organizational changes.

Document everything. You definitely should maintain comprehensive documentation of all workflows, policies, and procedures. In addition, you should document, as I just spoke about, the attacks that you actually have seen and done work on.

04:00-05:00

This not only gives a reference to other analysts, but it also tells them who the subject-matter expert is on this type of attack. This documentation should be readily accessible for training, compliance audits, and doing incident response.

Stellar Cyber facilitates the documentation of security incidents through its platform. It's designed to streamline the incident-response and documentation process. The system automatically captures and logs detailed information about detected incidents including the time of detection, the nature of the threat, impacted systems, and the steps taken for mitigation.

This data is centrally stored, allowing for easy access and review. Additionally, the platform provides tools for security analysts to add manual notes and observations and documents you can attach. This further enriches the incident logs themselves. These features not only ensure thorough documentation for compliance and auditing purposes, but also enable effective analysis and review to improve future security measures.

05:00-06:00
Stellar Cyber's Evidence Locker is a crucial feature designed to facilitate comprehensive documentation of security incidents, enhancing the analysis and reporting processes. It serves as a centralized repository where all relevant data associated with the security incident is securely stored. This includes snapshots of network traffic, user activity logs, system events, and other forensic evidence captured during incident detection and response.

The Evidence Locker allows security analysts to tag and categorize evidence for easy retrieval, supporting a structured investigation process. Use this feature to your advantage. It ensures that the evidence is preserved in an immutable format, which is critical for maintaining the integrity of data for legal or compliance purposes. By providing a reliable and accessible storage solution for incident-related data, Stellar Cyber's Evidence Locker streamlines post incident reviews and aids in the accurate reconstruction of security events for detailed analysis and reporting.

06:00-06:45
This concludes this foundational lesson on how to think about creating workflows. It attempted to give some context of who you need to involve in these workflows, because the SOC is not a self-contained entity. There are other stakeholders within your organization that need to have input on these processes and workflows that you develop. This foundational lesson was intended to give you the context by which you should think about creating these workflows. In another lesson we'll talk about the hands-on application of building these workflows within your group. Thanks for attending. This lesson is complete. Thank you for watching.

L06 - BUILDING WORKFLOWS IN STELLAR CYBER - IN PRACTICE

L06A-PRES: Building Workflows in Stellar Cyber - In Practice (15m:40s)

00:00-01:00

Welcome to the *Building Workflows in Stellar Cyber - In Practice* lesson of the *Investigations and Workflows* training module. In this lesson we're going to talk about real-world terms of creating workflows and how you should take things into consideration to get things done to achieve the outcomes you want. We're going to talk in this lesson about experiences from my personal experience working in and with SOCs, and talk about the best practices within Stellar Cyber to operate the most efficiently within your SOC to get the most done.

First we're going to talk about evaluating your personnel capacity because every organization is going to have a different capacity for triaging and investigating Alerts. They're going to have different numbers of personnel. They're going to work with different teams and we'll talk about all that.

We're going to talk about assessing your risk tolerance in order to create a reasonable baseline for how much triage and investigation you can get through on a daily basis.

01:00-02:00
We're going to talk about ongoing monitoring of operations and threats to continuously circle back and make sure that you are doing your most efficient work and achieving the outcomes the most consistently.

We'll talk about sharing knowledge, which is really the most important part in workflows is sharing the knowledge with the people who need to know. That involves communication so we'll talk a little bit about that.

Then resolving your investigations so that you have your desired Cases and Alerts triageable so that you get through all of the things so that you don't miss any threats and cause problems for your organization. Let's get going.

First, we're going to talk about assessing our scope. Every SOC is going to have a different number of people. Some SOCs are gigantic. Some are just one or two people. Depending on how many people you have in your SOC is going to influence your workflows.

02:00-03:00
You have to align your workforce to how much you're able to triage and investigate on a daily basis so that you accept what risks you can't get to, but you cover as much as you possibly can. To that note we are aligning our risk tolerance to that. If we definitely want to see and we talked a little bit about thinking about workflows in another lesson, you want to see the things that you want to see every time. You want to assess how much of the non essential Alerts you're able to get to, and you want to align this risk tolerance to your workflows so that you're triaging all of the things you need to see and you can minimize and accept the risk for some Alerts that you just can't get to, if that's the situation. Then we want to define our outcomes. Every organization is going to have a different set of outcomes that they want to achieve. It could depend on the industry that you work in. It could depend on how much workforce you have. It could depend on the level of knowledge and expertise of your team.

03:00-04:00
All these things need to be considered when you are designing the way that you go in and triage your Alerts and Cases on a daily basis.

We always want to meet those outcomes. Some of the ways that we can meet those outcomes depends on how much workforce you have, how many resources you have. You want to assign analysts to do threat hunting and those are going to be typically your threat hunters and incident responders. You want to decide who is going to be triaging things, how things are going to get escalated, and put a plan in place that's followed without fail so that you achieve the same outcomes in every Case.

You want to have a workflow where you set up someone to evaluate the resolved incidents. You always want to keep an eye on the knowledge and the effectiveness of your analysts. Going back and looking at closed Cases and Alerts gives you that confidence that you are covering the things that you need to do.

04:00-05:00
Typically this will be a tier-one analyst job to go behind SOC analysts and do quality control to make sure that the the Alerts and Cases that have been closed out were not closed out incorrectly and that they were either false positives or unimportant Alerts.

Then we'll talk about coordination between teams. So as we said, every SOC is going to have a different size. It's going to have different priorities. Coordinating between teams is very important. You need to define your stakeholders. In other lessons we've mentioned all of the groups that you might want to coordinate with. In an information security group you might have your data-loss people. You might have your firewall people. You might have your endpoint detection and response people, your identity access management, your net proxies, maybe your host-intrusion detection, your network-intrusion detection, your network analyst. All these people you need to have in a Rolodex, ready to be able to be contacted to help you understand the information that's coming from their platforms or help you understand things on the network that you just maybe don't understand that they might.

05:00-06:00
Next, you need to look at your chain of command. Typically the way that the chain of command will go is that you will have a group of tier-three analysts doing your triage and your initial investigations for these Alerts and Cases, and then they will escalate to potentially incident responders if you have incident responders that know how to respond and remediate threats, know how to close things out, know the proper permissions to isolate hosts or block IPs if they need to. Then for escalation of Cases, typically the way it works is that if a tier-three analyst doesn't necessarily understand the Alert and what threat it represents, they will escalate this to a tier-one analyst and have them do the advanced investigation that's required on these Alerts or Cases. They will make the final determination about what needs to happen.

Then this information needs to be communicated to the SOC manager at all stages of the investigation.

06:00-07:00
They are the ones who are going to be taking the fall if something goes wrong, so they definitely need to be looped in at every stage of an investigation when something looks like it might be a legitimate threat. Above the SOC manager will typically be the information security manager. This person definitely needs to be in the loop of all the investigations of a serious nature. They are the ones that are going to be communicating this information to your CISO, and your CISO is ultimately going to be the one that makes the final call on how to remediate these things if there is a serious threat.

Now let's talk about managing triage and investigation. You definitely need to define your capacity. The form that this might take is you might decide, "I have so many Alerts that I just can't get to them all." You need to define a method of getting to the Alerts that represent the greatest threats. You might say, "I have 150 Cases coming into my environment every day," if you had a huge network.

07:00-08:00
"I want to investigate all of the top risk Alerts." I might assign analysts to triage Cases or Alerts that are a risk score of 70 to 100. I want to get through 100% of my 70 to 100. Anything below 70 is just a bonus we can get through that. We'll accept that risk because we just don't have the workforce to get through it. Ideally you want to get through all of your Cases and Alerts. That's going to be the best practice, but sometimes it's just not possible. And the best way to start with doing triage and investigation is to start with Cases. We've discussed this so many times in the other lessons that the Cases because they are aggregated, they're defined with machine learning and analytics that puts these Alerts together if they're related. That allows you to see it in a more holistic way, in a more comprehensive view, in a graphical view in the **Analysis** tab of the **Cases** view.

08:00-09:00
That allows you to knock out lots of Alerts and events at one time to understand the broader context of what's going on to understand how it's unfolding chronologically, and to knock out as many Alerts as you possibly can.

Then move to Alerts. There's a couple of different ways to look at Alerts. We discussed in the Alerts lesson that there are a couple of ways in the **Alerts** table view, it groups all of the Alerts by Alert type And that might be a way that you want to go in and assess things happening on your network. But a better way to do it might be to go into the **Investigate | Threat Hunting** view, and then go through one at a time in the same way that you do with Cases and say, "I'm going to get through every Alert that appears in my system." Check it to see if it has an associated Case first, but then I want to get through every Alert that's between 60 and 100 in a risk score. We want to cover 100% of those. We're going to go back and reevaluate this every so often because it's constantly in flux in your SOC. You have new analysts. You have people leaving. People coming in and there's always going to be different levels of expertise...

09:00-10:00
...so you want to continuously reassess and this is probably a SOC manager or a tier-one analyst job. To make sure that you're getting through the things that you need to get triage and escalated, and make sure those are going to the right people.

Sharing information. It's very important that you create a knowledge-transfer strategy within your organization. That means as soon as there's an Alert that's not fully understood, escalate that to your tier-one analyst and let them take a look at it while you are doing your investigation as well. All of this is going to be specific to the organization in which you work, but it needs to be aligned to your risk tolerance and it needs to be aligned to your capacity so that you're able to get through all the Alerts that you want to get through and decide which ones if they were to fall off the table and you were not able to get to them, is an acceptable level of risk.

Using the tools in the interface, you can share a lot of information with your fellow team members, with other partner teams that you work with, or with management.

10:00-11:00
Some of these tools include Case Activity. That's going to be a log of everything that's been done to a particular Case. The Evidence Locker is a place where you can add extensive notes or you can add PDF files. You can add other types of documents that will allow other analysts to benefit from the research that you've already done. You might want to include visualizations or dashboards in the documents that you're uploading to the system so that it gets reposed, it gets stored within the user interface so that everyone has the benefit of the research that you've already done.

Another thing to take advantage of in your workflows is automated messaging. If a certain type of activity meets a criteria that you want your SOC analysts to all know about, or you want to go to management, or you want to go to your tier-one analysts, you can set up automated messaging to send Alerts via email or some messaging system to let other analysts know or other partner teams know that this activity is going on and they can help take action on it.

11:00-12:00
Dashboards and reports are another great way to share information. Like I said, you can attach those to the Evidence Locker directly in the Case itself. Then of course we talked about the disposition tools within the user interface. Those are very important to give a status and assignee to each of the Cases that you're working on and also include all the Alerts, give them an assignee, give it a status so that you're not duplicating efforts among team members or among partner teams. Then resolution and documentation is a very important part of doing investigations. There are compliance requirements sometimes. Sometimes you might just want to use these documentation resources to train other team members or to store like we talked about in a repository that shows specific types of attacks, what the best stages of remediation could be for those types of attacks, or to define policies and procedures for your SOC and your information security team so that everyone is on the same page and following the same guide book.

12:00-13:00

In this process we have to define our communication strategy. We need to know who to contact and when. We might want to escalate every investigation just for the awareness of our SOC manager and all the tier-one analysts. Then depending on the level of expertise within the SOC analysts they may be able to accomplish those investigations themselves, or they may want to do it in tandem with a tier-one analyst who has more knowledge and expertise to make sure that the correct steps are taken, and the Case or Alert is triaged in the most efficient way.

Then we need to talk about who we're going to contact when certain types of activity occur. Should we contact the user themselves? Should we contact the user of the workstation that's showing nefarious activity? Should we talk to the application owner that runs the server that's hosting a certain application that shows malware or ransomware or some other piece of script or process or account flag that's showing an anomalous behavior?

13:00-14:00
Who do we contact? Do we contact the users themselves? What if this user could be an insider threat? Maybe we don't want to contact them if this activity looks fishy. However, on the other side of that we might have activity that looks like it might just be accidental behavior. In that case, we might contact the user themselves. But if it is nefarious looking, we might want to contact the manager and just verify, is this user? Were they to be disabled? Were their assets to be locked out? Is this going to affect business operations? We can get that information from the manager, and then we're going to contact partner teams. We've talked about this a lot about the different teams that you work with. If you get some anomalous data exfiltration over a web protocol, maybe you need to contact the web proxy team and see if this is anomalous behavior or you might want to contact the team that is doing the uploads and see if that's acceptable behavior. A lot of times we'll have people who do one-off reports for compliance to the government or to some bureau...

14:00-15:00
...or to some management team that requires them to upload a file that is six gigs every three months and it might not be common enough to not show as an anomaly but also as we've said so many times within this course, that knowing all of this information–which teams have to upload six-gigabyte files to the internet every three months–knowing those things and documenting those things is a really great way to build tribal knowledge about your network and to establish a baseline for what's acceptable and what's not. Knowing those teams, having a contact list for them is very important and is one of the most crucial steps in building workflows in practice.

Next you need to ensure follow-up. A system needs to be put in place where you have full certainty that all of the things that get escalated are getting treated. They're getting resolved. Likewise, you need to have a policy to follow when the SOC analysts are following a certain guideline to make sure that they're getting through all their guidelines.

15:00-15:40
If not, push them back into the queue and say, “Hey, these need to be triaged or investigated, we have a set of guidelines that we use, and these guidelines need to be followed.” These are some practical tips and this was a short lesson because we've covered so many of the workflow tools in

other lessons, but these are some of the most critical concepts to be aware of. To be able to build your workflow in practice and to achieve the outcomes that you're seeking to achieve. Thank you for attending, and we'll move on to the next lesson. This lesson is complete. Thank you for watching.

L07 - CASE INVESTIGATION

Part 1 L07B-DEMO: Case Investigation Part 1 (22m:17s)

00:00-01:00

The next lesson in the *Investigations and Workflows* training module is a demonstration of Case investigation. Part 1 of 2. Welcome to the first demonstration of Case investigation in the *Investigation and Workflows* module of the SOC Analyst course. In this lesson we will investigate a real attack scenario. We're not going to presume that anyone attending this lesson has any prior cybersecurity experience. We're going to examine each process and technique to understand the nature of this attack that we're going to pick at random. This investigation will show you a realistic example of the way an investigation evolves, including how information is exchanged between groups or analysts, as well as how to research a not very well understood exploitation method. We're going to show how that would work.

01:00-02:00

As I've said here before, no analyst knows every process, service, account parameter, system configuration, or other elements of information technology. You can't know at all. If you think you know everything you're doing cybersecurity wrong, because it's constantly evolving. Real investigations require research, and we'll explore how to get to the correct conclusion about a cyber incident in this demonstration. Getting to the correct conclusion does two things for SOC operations:

1. It keeps potential threats from being misunderstood and therefore dismissed. This is a suboptimal way of treating cyber threats. If they are dismissed or closed because an analyst doesn't understand what's happening, it often leads to a much greater scope of remediation for this incident. This costs time, money, and potentially damage to the organization's reputation. This result also leads to bad days for SOC analysts and SOC manager's job security.

02:00-03:00

Fortunately for SOC analysts and managers, Stellar Cyber employs advanced security analytics and artificial intelligence to aggregate and correlate this data from across the network, endpoints, applications, and cloud environments. It provides a comprehensive view of the security landscape. By integrating data from diverse sources, it adds context to security Alerts, distinguishing between false positives and genuine threats. It also highlights critical vulnerabilities and attack paths. This enriched contextual information enables cybersecurity teams to prioritize and respond to incidents more effectively, focusing their efforts on mitigating real threats and improving overall security posture. All of this context and aggregation as well as the research resources within the UI, greatly facilitate correct responses to incidents, but at the end of the day–it's necessary to remember this–it's the

choice of the analyst to dismiss, take a response action, or dismiss a Case. The responsibility should be taken very seriously.

03:00-04:00

2. Proper assessment of the nature of a cyber event leads to analysts taking the correct action to contain, mitigate, or prevent further exploitation by bad actors on your network. Responding early to a cyber incident drastically reduces the potential impact in the breach. It limits the amount of data loss and the debt to which malicious actors can penetrate your network. Quick identification and containment of these threats prevents the spread of malware or the escalation of access by attackers. It safeguards critical assets and sensitive information, which is your goal. Early response also allows for timely patching of vulnerabilities and the strengthening of security postures. This prevents similar attacks in the future. Moreover, swift action demonstrates a commitment to security and regulatory compliance, helping to maintain customer trust and avoid potential legal and financial repercussions.

04:00-05:00

One other thing: It's important to note that this example investigation is not the only way to investigate a breach or attack. Every SOC is going to have variations in workforce resources, information security teams and resources, size, and scope of work. This investigation is meant to serve as an informative guideline, and while it contains some prescriptive elements of methodology, individual SOCs will tailor these suggestions and methods to their own unique resource structure. Having said all that, let's get going. We're going to pick a Case at random and I am going to explore it for the first time with you.

Let's get started with this investigation. I'm going to be looking at this for the first time with fresh eyes just as you are. We're going to explore everything from top to bottom and we won't leave **any stone unturned**. We could start our investigation by looking at the Top Cases.

05:00-06:00

One important aspect of this is this assignee field. Let's find a Case that's not assigned to an analyst already. We'll pick this one. First, autosize all columns. Because we're going to be triaging this, the next step is to take note of the severity. We will assign the status of **in progress**, and we will assign the status to me. I am analyst number 01. In this scenario, I'm going to be acting as a tier-one analyst conducting triage on Cases in the SOC as part of my daily investigations and triage.

Let's take a look at this. What can we see here from this initial view? We can see that this is a Mimikatz credential dump and fifteen other Alerts. The name of the Case is determined by the highest-scored Alert. We can see Mimikatz's credential dump is the first one. We will sort this by time.

06:00-07:00

We have initially some uncommon process anomalies, but we see that the credential dump is the most highly scored event in this group of Alerts. It is giving the name to this Case. Our score is one hundred. The "who" is ot-workstation.incident.ad. I'd guess that maybe that's an Active Directory

server. The “what” is credential dumping. There are no tags added to this yet but we might add some as we go through. The “when” is April 5th, 2024 at 10:15. The “where” is unknown. There must not be any geolocation enrichment happening here. Then we've assigned this to analyst01, which is me in this scenario. We'll assign all of these as **in progress**.

07:00-08:00
Apply that and we will also give an assignee of analyst01 so that everyone knows that this is being worked on and other people don't duplicate your effort by working on the same thing that you're working on. The very first thing we could take a look at is this Case Score Breakdown. There are three Kill Chain stages: Propagation, Persistent Foothold, and Exploration. We can see how many Alerts are in which Kill Chain stage. It looks like this person or attacker has already gained access to the network somehow because we don't see any initial attempts here. Later on we may have to go back and investigate how this landed on our network, but the persistent foothold is definitely a problem because then if we eliminate their entry point, they still have access on our network and they're still going to continue to make problems for us. Next, we have two Alerts that are in the Exploration phase. That means that this user is trying to either enumerate the network or to explore the network to find vulnerabilities to exploit.

08:00-09:00
There's also four Alerts that indicate propagation, so they are trying to expand their footprint on our network and gain footholds further out into our network, gain greater privileges perhaps, compromise further accounts, and do more damage. We've already got a serious looking attack. One good thing that we'll notice is that there are no Alerts in the Exfiltration and Impact phase thus far. There's no impact taking place on our network so far. Probably no data exfiltration. There's no compromise. There's no lasting compromise of assets or users, so we can probably remediate this without too much impact, but we need to act quickly because time is money in cybersecurity. Here, in our Case score breakdown, we see the Kill Chain stages. There are four hosts involved. It looks like an AD server here.

09:00-10:00
It looks like a hanjie-attacker, another AD server and an OT PLC. We'll have to investigate what these things are. There are three users: administrator, administrator, and administrator. It's not clear yet if this is three different administrators, or if the same administrator has been exploited on three different assets. We'll have to explore that and see what's going on. There's 11 processes that we can see. Powershell_ise.exe. We'll explore what that is. Mimikatz.exe. We don't know what that is yet in this scenario, but we will explore it. dsregcmd.exe [pronounced d-s-rej-command dot e-x-e]. Not sure what that is just yet. Then WmiPrvSE.exe, which is probably some sort of Windows management privilege service, and then powershell.exe, Project2.exe, ShellExperienceHost.exe, wsmprohost.exe, splunkd.exe, and explore.exe.

10:00-11:00
We're going to pretend that we don't know what any of these processes are. We will explore them all as part of this investigation. We can see the uncommon process anomalies and we could explore this here if we wanted to, but it may be more efficient to go into the **Analysis** view and take a look at it

there. Because in the **Analysis** view, we have lots of resources that we can use to analyze this attack. We didn't see this in the user, but they have escalated to system privileges, which is basically **overlord status**. They have full privileges to exploit our servers, to exploit our workstations, to compromise users, and we'll explore how this plays out. The first step you want to explore is which hosts are involved. We saw this in the overview up top, which processes we've got here.

11:00-12:00
We've got eleven, and we talked about those earlier. Then the users–we have an administrator and here we do see that there's system privileges involved and we know that that's very dangerous because system privileges means that they have full access to our system.

Taking a look at this graphic view of the attack, we can see that the system account is doing something on this incident workstation. This workstation is connecting to this OT server. The administrator's logging into this incident workstation. This is reaching out to the Hanjie attacker, and this workstation is what's spawning all of these executables. We will explore this further, but now we have an idea of what's going on. The most reasonable next step is to take a look at your timeline to see what types of attacks you're dealing with. We will sort this by time.

12:00-13:00
Start from the beginning. We have an uncommon process anomaly. Several of these; we will examine these. We have port scan anomalies, which is very bad when it's combined with a Mimikatz attack. Another uncommon process anomaly, PowerShell remote access so they're gaining remote access to systems on our network. More incoming processes, internal Trojan is clearly bad, suspicious PowerShell script, more process anomalies, PowerShell and then they have finally achieved what seems like their goal which is to dump credentials probably from LSAS and we'll explore all that in time.

Let's go ahead and dig into this. One thing that is important to consider in an investigation like this is that we know that this is bad activity. We know that this is dangerous. Should we isolate these assets?

13:00-14:00
It's possible that we should after an investigation whether this asset would affect or interrupt critical business processes. We'll go through that process eventually. But right now, we will take a look at these uncommon process anomalies and see what we're dealing with. It looks like Windows\SystemApps\ShellExperienceHost has never been observed. We don't know what that is yet, but we'll do the research. Here it looks like we've got this...I think that's Windows management privilege activity. Project two, we're not sure what these processes are just yet, but we will investigate this. We have a host, which is 10.33.4.134. This server is spawning these scans, which is very anomalous.

14:00-15:00
The host has a weighted anomaly score 357. That's really big. This is probably where we need to isolate if this is not a critical server for our business processes. We will investigate that, but that will take some time. This PowerShell access is from a name Hanjie attacker on the Windows host. This is bad activity. This looks really bad. Internal Trojan is probably threat intel information, malware

disguised as legitimate software to gain access to a system or files. All these things are telling us valuable information that can guide our investigation and the signature from IDS is Trojan Go lang/Sandcat Plugin Activity. We'll research that to find out what that is.

15:00-16:00
First we'll go ahead and isolate this. We'll assume that we have received permission from the authorities to isolate this workstation. It's clear that this is a dangerous event and this is the source of the spawning of these events. We're just going to isolate this. We'll go into the Case and in response this particular demo instance doesn't have an EDR solution attached to it, but we will show you how it works. What we would do is just contain this host and pick the target and pick the connector: It's SentinelOne. We're going to pretend that this is our host and we will do this for eight hours just to make sure that we have time to do this investigation. Click **Submit** and that is isolated.

16:00-17:00
Now we have this host on the network isolated so that we can do the analysis. From here we'll pivot into the timeline and start doing this analysis on what this event actually looks like. We want to look at these uncommon process anomalies just to make sure that they're not doing damage to our system. We will **hop in** here and see that this Windows\SystemApps\ShellExperienceHost we will Google this to see what this is. Most times these tactics and techniques will be hyperlinked. This particular one is not, but let's Google this and see what this is. ShellExperienceHost is the Windows component responsible for the Windows display feature of Universal Windows applications. In the context of a hack the Shell Experience Host is a legitimate Windows process associated with the Shell Experience, which is responsible for presenting various user interface elements like the start menu taskbar transparency and visual effects.

17:00-18:00
However, like many legitimate processes, it can be misused by attackers. A technique called living off the land where attackers use built in tools and processes to conduct malicious activities so that's with a little bit more deeper research. Hackers might use this exe in their activities by hijacking or mimicking the process. For example, malware can be disguised as Shell Experience Host.exe to avoid raising suspicion. This takes advantage of the fact that this process is typically trusted and allowed to run on Windows systems. Therefore, attackers exploit this vulnerability in the process or they inject malicious code into it. This leverages the process's legitimate system permissions to carry out actions such as spying, data exfiltration, or further system compromise without triggering security Alerts.

18:00-19:00
This is a technique that's used by a lot of attackers to live off the land, as we say. It's basically using legitimate processes but maybe injecting code into these processes that allows them to escalate privileges or get access to things that they wouldn't normally have access to. It's not clear exactly what they're doing with this process just now, but if we go down here and look through these we can do a quick examination of what these fields contain and what evidence they contain for us. Event_type is exploit. Let's see what we can garner from this. We have the Shell Experience Host as the program name. Let's see. We have it. The task within this is a process create. They're creating

some sort of process and we'll have to dig in and see what sort of process this is, but we know that they're doing badness already.

19:00-20:00
We've got them isolated, so we've got time to take a look at this. Let's look at the next Uncommon Process Alert. This one is WmiPrvSES.exe. We'll Google this to see what it is. It's a process in the Windows operating system that can host one or more WMI providers. With a little more digging we can tell that Windows management instrumentation allows for the management of systems. This might be used as another living-off-the-land technique they're using to maintain persistence or maybe execute malicious scripts. They could use those scripts to move laterally across the network and that may be what's going on here. Another dangerous process that we see Alerted from the rules.

20:00-21:00
Project2.exe might be some sort of hacker tool that they're using. We'll check that out. This looks like it's some sort of worm or virus or spyware potentially to enumerate the network. Sometimes attackers will give their executables generic-sounding names to make them look like they're normal executables on the system so that they don't gain attention from analysts, such as the SOC analyst working in the SOC. Let's look at one more uncommon process anomaly. This one is dsregcmd.exe. Let's look that one up. It says this has never been observed or is rarely seen. We'll Google this.

21:00-22:00
After a little research we find that dsregcmd.exe is a legitimate command-line utility included in Windows. Hackers occasionally use it for information gathering or for credential theft or lateral movement or to bypass security measures. We see these uncommon process anomalies and we have enough information now to escalate this to our tier-one analyst. We need to know that these process anomalies are generated by Stellar Cyber's user and entity behavior analytics. What it does is it creates a baseline on this asset to see what commands typically run. When something abnormal runs, the system will flag it and say this is anomalous for this machine, best take a look at it. Now that we have this information, we're going to go ahead and escalate this, but first we want to gather all the research that we've done and put it in a document.

22:00-22:16
We want to include that in the Evidence Locker so that when we pass it to our tier-one analyst, they have all of the information that we've gathered and they don't have to do the research themselves. We're going to create this document and add it here in the Evidence Locker. This lesson is complete. Thank you for watching.

Part 2 L07C-DEMO: Case Investigation Part 2 (18m:46s)

00:00-01:00
The next lesson in the *Investigations and Workflows* training module is a demonstration of Case Investigation, Part 2 of 2. This lesson is a continuation of a two-part demonstration showing the workflow for handling a Case investigation.

Gather all the research that we've done and put it in a document, and we want to include that in the Evidence Locker so that when we pass it to our tier-one analyst, they have all the information that we've gathered, and they don't have to do the research themselves. We're going to create this document and add it to the Evidence Locker. I've compiled the research that I've done on all these uncommon process anomalies. One thing that we know for sure is that no person in any SOC knows every single executable that goes on, on every asset in their environment.

01:00-02:00
It's just not possible. It's not practical. At this point, we know that this is a breach of some sort because of all these process anomalies. We've already isolated the asset, which means that it can't spread from this asset. If it's reached out to other assets, it may be propagating from there. But we know that we have this one locked down and we can only do one thing at a time. I have compiled all this evidence that I've gathered from these process anomalies, and I'm going to add it to the Evidence Locker. The way I did this was and I'll give this a title of Uncommon Process Anomalies and put the Case number on it. Then I will add my evidence.

02:00-03:00
This file contains the research that I have done. I gathered the tactic and technique from the UI–you find that here. I gathered this information here for context. If we go back into the Evidence Locker, I can look at this document again. It contains the stage, the tactic, and the technique. It talks about what these Alerts are, and a little bit of research about what these processes and these functions within Windows actually do. This is gathered for the tier-one analyst so they don't have to re-create my research. I've done it already. I might as well give that to them so that they don't have to redo this research.

03:00-04:00
It's a really vital resource for them. They may understand it better than your tier-three SOC analyst. But having this information is definitely a benefit to them. It saves time in the investigation. It adds context. It makes you look smart. That's a good thing to add to your report. We'll continue down through these as the tier-one analyst now. Because we've escalated it we'll be acting as the tier-one analyst. We've got PowerShell remote access. For those who don't know what PowerShell is, PowerShell is a task automation and configuration management framework by Microsoft. It consists of a command-line shell and scripting language built on the .net framework. It enables administrators to perform administrative tasks on local and remote systems through its commandlets and scripting capabilities.

04:00-05:00
PowerShell extends its utility beyond traditional command-line shells by integrating with Windows management instrumentation, which we've already seen in this attack, com objects making it a versatile tool for automating a wide range of management tasks. This is command and control. If we take a look through the details we see what this is. Here is the script that they're running here. We can take a look and figure out what they're doing. It looks like they are file Sancat Go download data from the URL. We see that they're downloading a sandcat file and we don't know what that is. We'll

go look it up. What we find out is that hackers use sandcat to orchestrate complex cyber attacks and manage compromised systems within a target network. It leverages its command-and-control capabilities for coordination and control.

05:00-06:00
Its modular architecture allows attackers to customize and extend its functionality to tailor attacks to exploit specific vulnerabilities or to blend in with normal traffic for stealth. Sandcat's ability to dynamically load plugins and scripts enables hackers to adapt their tactics on the fly, facilitating the deployment of malware, data exfiltration, and lateral movement within the compromised environments. We can see that they even go further–that they are looking for SplunkD.exe. It's looking to disable the SIEM It looks here like remove this function and ignore it. They're trying to bypass our controls here. We have no doubt in our mind now that this is some sort of sophisticated attack on our system, and we're going to do our best to mitigate this. We'll continue the investigation so that we can present the entirety of the attack to our auditors or to our compliance people or to our information technology leadership or information security leadership, because they're going to want to know what happens...

06:00-07:00
...because we're going to take this attack and we are going to use it to harden our defenses. You can see that Stellar Cyber is doing a great job of detecting this and displaying it in a way that you can understand it even if you don't know what these things are. Here's the Splunk command that we've already seen. Now we have a Trojan. Let's take a look at this and see what this means. The description of this trojan is network intrusion-detection system and internal traffic discovered a malware trojan. Between 10.33.4.135 that's our asset and 10.33.4.132. With the name of Hanjie attacker, which is very suspicious and convenient to let us know that this person is an attacker, matches the IDS signature trojan Golang Sandcat plugin activity post. It's posting something with an IDS severity of critical.

07:00-08:00
We've seen this activity in one of the other Alerts that the sandcat activity is going on. If we don't know what Golang is, we go look it up and what it is, it's officially known as Go. It's an open-source programming language developed by Google. Hackers use Golang to develop sophisticated malware and tools for cyber attacks because it works across platforms and allows for the creation of binaries that can run on multiple operating systems without having to be modified. Its strong standard library, advanced network handling, and concurrency features make it particularly appealing for routing fast and efficient malicious software that could perform tasks like data exfiltration, network scanning, and encryption with relative ease. We see that this is a sophisticated attack by someone who knows how to script. They are running scripts on our network, and then we have a PowerShell script. Let's see what that is.

08:00-09:00
Executed on our asset that we've isolated already, and it's triggered by a rule with the following description: Identifies when a user attempts to clear console history. Here they're trying to cover their tracks. An adversary may clear the command history of a compromised account to conceal the

actions undertaken during an intrusion. We see that this person is trying to cover their tracks. What we're going to do here is I'm going to pause real quick and I'm going to gather up all the information from the research that I've conducted on what this is and I'm going to add it to the Evidence Locker. Here you can see my document. I've saved it as a PDF. We're going to import this. This is the information that we've got on the Trojan. We'll add this here. This is what it looks like. It talks about what is Golang in case they want to know that this is a Google script that is meant to be malicious and then sandcat, which is going to try and get command and control and exploit vulnerability.

09:00-10:00

We've got this attached. Now we are building a Case. This can be exported after we're done with this investigation. This information could potentially be stored in a repository of knowledge. Maybe you use Confluence or Google documents to aggregate the information that we've gathered on this incident. You may want to record this for future compliance reasons, you may want to record it as a knowledge base for your analyst to analyze this if they've seen it again. If they search this and find a quick summary of what Sandcat is and what Golang means, then you don't have to do this research over and over. It's probably a best practice to create a repository for your analysts in the SOC so that they can go research these things that you've seen on your network before, or you might use these documents to show the types of attacks that have happened on your system and develop a plan to harden your posture so that you don't have to keep defending against these types of attacks.

10:00-11:00

We can see that Stellar's done a very good job of detecting this and showing us what it means. We'll continue on down. We've got a few more events here. We've got a PowerShell script here, and we'll go ahead and see what that PowerShell script is. Detects invoke Mimikatz's PowerShell script and alike. Mimikatz's is a credential dumper, capable of obtaining plain-text Windows account logins, and passwords. If you don't know what credential harvesting is, that means basically they are dumping some file that contains username and password combinations or the hashes of those passwords to replay them and move laterally through the network or escalate their privileges by gaining access to a system or administrator account. That's exactly what they've done here. We're probably going to see that activity here soon.

11:00-12:00

That's exactly what this is. We will go ahead and add this to our document. We've got more internal IP and port scans. Within a five-minute period we went from three to 65,129 on a new IP. It's looking for ways to move laterally through the network. We have a memory dump. This is officially compromised. We'll copy this out. We might want to do some research actually in MITRE. That's what these links are and some of these tactics and techniques and the other Alerts didn't have links probably because we're working on a demo system. You can go find the type of credential dumping that's happening here. We'll see if Mimikatz shows up here.

12:00-13:00

It doesn't show up here, but it may show up in the technique. If we want to find information about Mimikatz we can go here directly into the MITRE ATT&CK framework website, and take a look at what Mimikatz actually is. This is all we need to know about Mimikatz. This is the industry standard of what

types of APTs contain this Mimikatz tool. We can do all this research within the tool and just **hopping out** into the websites that are linked within the UI. The good news is that we've isolated this machine and the bad news is that we've have a potential dump of credentials that we're going to have to mitigate. Let's see what this hacker is doing next. We've got a suspicious Windows Logon event. Let's see what this is. A potentially malicious Windows account log on was triggered on our host with a login name administrator.

13:00-14:00
This makes things more complicated because now they've escalated their privileges to administrator status. This detection was triggered by a rule with the following description: detect successful log on with type nine new credentials, which match the overpass the hash behavior of Mimikatz sekurlsa:pth module. We'll do a little research to see what that's about. Log on type nine means that someone is logging in to a current session or logging in from a current session with new credentials. Essentially it means that it is a new credentials log on, which occurs when a user runs a process with explicit credentials, different from those of the user who is currently logged on. When a hacker generates a log on type nine with administrator privileges, it indicates that they're executing commands or launching processes with elevated privileges.

14:00-15:00
This is potentially bypassing security mechanisms to gain unauthorized access or perform privileged operations. This technique is often used in lateral movement within a network. It allows the attacker to execute code or access resources on other systems under the guise of an administrator. This significantly increases the potential for widespread system compromise or data exfiltration. They've escalated their privileges to administrator status and this is a problem. We want to lock this administrator out because this is an attack and they've gained access to this administrator's account. We'll go into the Alerts, make this bigger. We'll go in here, and then we'll take an action. Because we don't have an EDR agent, or we don't have an EDR connector on this particular test demo system, we're going to use a different one...

15:00-16:00
...but what we would want to do is go into Actions, but we'll show you an example of how this works if it had isolate the user or contain. That's what you would want to do. You would want to lock that administrator out–have your Windows team lock that user out and force a password change because they have access to this administrator's passwords and it's clear. We'll take a look at how you lock a user out. Take a look at a connection that does have an EDR connector. We want to disable a user. We want to choose our target, administrator, Windows ID. We're going to do this for two days and we can always go back and re-enable them. But we'll click two days, and then submit this.

16:00-17:00
We'll get the Windows security team to force a password change, and at least we've gotten this administrator's credentials back where they belong, which is with the administrator and not with this attacker. We'll move back into our attack. We have one more event that we need to look at. This is a potentially malicious Windows process created on our host, with the login name, “administrator.” This

is using administrator privileges to create some sort of process. The rule was a common hacking tool was detected being used on this machine. It's also a common indicator while we're performing additional reconnaissance. Take a look and see what this process actually is under the **Details** field here. The process name is Mimikatz again running as an administrator...

17:00-18:00
...on this OT workstation and LSA dump, which is the file that contains credentials for users in Active Directory, desync. This is the user KRBTGT and it looks like Benjamin DELPY. We've got users administrators desktop. We've got a login to the administrator's computer, and it's dumping credentials. We have another example. We need to isolate this OT workstation. Refer back to the way we isolated the other host in the EDR demo, and we'll isolate that one as well. As long as we're locking these down at least we know where the malware is located. We've locked that down, and we've disabled users, and forced user passwords.

18:00-18:46
We have contained this one Case. This is how you contain it. We have a description of what's going on. We'll document these extra Mimikatz dumps and who's involved, and then put this in the Evidence Locker for review by anyone who wants to know exactly what this attack consisted of. We'll add this here, or we could add comments in the Case Activity to show what this attack actually means and pass it to the relevant security stakeholders who have an interest in this and they can take action. This is how it works. We'll continue demoing Cases in further demonstrations. This lesson is complete. Thank you for watching.

L08 - ALERT TRIAGE AND INVESTIGATION FUNDAMENTALS

L08A-PRES: Alert Triage and Investigation Fundamentals (28m:46s)

00:00-01:00
The next lesson in the *Investigations and Workflows* training module is *Alert Triage and Investigation Fundamentals*. We'll begin by looking at the centrality of Alerts in the user interface to conduct triage and investigation on security incidents. Then we'll talk about ways to understand what you're looking at in these Alerts. Next, we'll look at some triage and investigation fundamentals. We'll explore how Interflow works. Interflow is critical to the entire system because it normalizes your data and you need to understand what you're looking at when you're performing investigations or triage. Then we'll look at ways that you can use Alert tagging to streamline your investigations to get to the information you need to see first. Lastly, we'll take a look at a demonstration of triage and investigation in the user interface.

01:00-02:00
We won't dive too deeply because we have other demonstration lessons, but we will take a look at what the data looks like within the user interface. Now that we know what we're going to explore, let's get going.

The importance of Alerts. Alerts play a crucial role in the Stellar Cyber platform, serving as fundamental components for ensuring the efficacy and responsiveness of cybersecurity measures within an organization. Here's why Alerts are important in the Stellar Cyber ecosystem.

- Early detection of threats. Alerts in Stellar Cyber provide early warnings about potential security threats. By promptly notifying security teams about suspicious activities, such as unauthorized access attempts, malware detections, or anomalous behaviors, Alerts enable faster identification of potential threats, reducing the time attackers have to cause harm.

02:00-03:00

- Prioritization of incidents. Stellar Cyber assigned severity levels to Alerts, helping organizations prioritize their response efforts based on the potential impact of an incident. This allows security teams to focus on the most critical threats first, ensuring that resources are allocated efficiently and effectively.

- Creation of Cases. Stellar Cyber automatically aggregates and correlates related Alerts to create Cases, allowing security analysts to handle complex incidents efficiently. Each Case consolidates relevant Alerts providing a comprehensive view of a potential security threat or incident. This streamlines the investigation and response process. This approach not only enhances the organization's abilities to manage and respond to incidents, but also aids in identifying patterns and trends over time, improving the overall security posture.

03:00-04:00

- Enhanced incident response. Alerts in Stellar Cyber often contain detailed contextual information about the nature and scope of the detected activity. This information can include data about affected assets, users involved, and the tactics, techniques, and procedures, or TTPs, used by the attackers. Such rich detail enables security analysts to respond more effectively and tailor their actions to the specifics of each incident.

- Facilitation of investigations. The information provided with each Alert not only aids an immediate response, but also facilitates deeper investigations into security incidents. Analysts can use data from Alerts to trace the origins of an attack, understand its progression, and identify all affected systems and data. This comprehensive understanding is critical for remediating vulnerabilities and preventing future attacks.

- Automation of security operations. Stellar Cyber's platform supports automated responses to certain types of Alerts, which can significantly accelerate the mitigation of threats. Automation can include actions like isolating infected endpoints, blocking suspicious IP addresses, or applying security patches. All of this helps reduce the window of exposure to attacks.

04:00-05:00

In Stellar Cyber, Alerts or notifications generated by the system to indicate suspicious activities, potential threats, or security incidents that may require attention or action from the security team. Alerts in Stellar Cyber are designed to provide actionable intelligence. They help security analysts

quickly understand and respond to potential security issues. Here's a detailed look at how Alerts function within Stellar Cyber.

- Alert generation. Alerts in Stellar Cyber are generated based on the analysis of data collected from various sources within an organization's network. This includes data from endpoints, networks, applications, and other security tools. Stellar Cyber uses advanced analytics including behavioral analysis, anomaly detection, and signature-based detection to identify activities that deviate from the norm or match known threat patterns.

05:00-06:00

- Types of Alerts. Alerts can range in type depending on the nature of the detected activity. For example, security threats are Alerts related to malware, ransomware, phishing attempts, or unauthorized access attempts. Policy violations are Alerts triggered by actions that violate organizational policies or compliance requirements.

- Anomalous behavior. These are Alerts for unusual activity that could suggest a security breach such as abnormal data transfers or login attempts at unusual times.

- Severity levels. Stellar Cyber assigns severity levels to Alerts, helping prioritize them based on potential impact. Severity levels include low, medium, high, and critical. These are determined by factors such as the potential damage of the threat, the likelihood of exploitation, and the sensitivity of affected assets.

06:00-07:00

- Alert details. Each Alert in Stellar Cyber includes detailed information to aid in investigation and response. This typically includes the time stamp when the activity occurred, source and destination, information about where the activity originated and what was targeted, type of threat or anomaly, what kind of issue was detected, and contextual information. Additional data points that provide context, such as user behavior patterns, network traffic details, or correlations with other security events.

- Response capabilities. Stellar Cyber not only notifies but also facilitates response actions. Analysts can use the platform to investigate Alerts by drilling down into detailed data and analysis tools provided by the platform, or to use automated response actions configured with the platform to quickly mitigate threats such as isolating affected systems or blocking malicious traffic. You should collaborate and annotate within the platform for team-based analysis and response.

07:00-08:00

- Integration and correlation. Stellar Cyber can integrate Alerts from third-party security tools creating a comprehensive security Alert ecosystem. It correlates data across different sources, helping to reduce false positives and providing a holistic view of security threats across the entire environment.

Alerts in Stellar Cyber are central to its role in enhancing the efficiency and effectiveness of security operation centers. It provides the necessary insights and tools to manage and mitigate potential security threats proactively.

Triaging and investigating Alerts in Stellar Cyber involve a systematic approach to ensure that potential security incidents are handled efficiently and effectively. Here are some best practices for triaging and investigating Alerts in Stellar Cyber.

08:00-09:00

- Prioritize your Alerts. Not all Alerts are created equal. Use the severity ratings and confidence levels provided by Stellar Cyber to prioritize Alerts. High-severity Alerts that indicate a potential breach or critical vulnerability should be addressed first. This is going to be a process that is unique to your organization because your organization will have different priorities and desired outcomes for your cybersecurity operation. You should take into consideration which Alerts are going to do the most damage and prioritize them first whether by severity, criticality, Alert score, or other factors. Stellar Cyber helps you prioritize Alerts for triage in a number of ways. It employs a variety of mechanisms to assign risk scores to Alerts. Risk scoring is based on several common principles in cybersecurity threat detection and response. Here's an outline of how risk scoring is prioritized to save you time and energy. The following factors in risk scoring are important to be aware of:

09:00-10:00

- Severity of the Alert. The base severity level for the type of threat detected plays a crucial role in the risk score. For example, detection of a potential ransomware attack will carry a higher base severity than a less harmful event like an Adware detection. You should take that into consideration when you're deciding how to prioritize these threats, especially in the Alerts table view as we'll see in the demo.

- Confidence level. This refers to the probability that the detected event is genuinely malicious. Stellar Cyber's algorithms assess the accuracy of the detection based on various indicators and historical data, which contribute to the risk score.

- Third-party Alert prioritization. Here's how scoring third-party Alerts works. Third-party Alerts are converted from their native platform into a risk score of one to one hundred assigned by Stellar Cyber. For example, if an Alert comes from a third party as an integer, say the Alert level is one to five with five being the highest...

10:00-11:00

...it's assigned an appropriate risk score of zero to one hundred in the Stellar Cyber platform. Similarly, if an Alert comes from a security vendor product that is assigned a string value, such as low, medium, high, that value is assigned a value of zero to one hundred in Stellar Cyber as well. This risk score is integrated into Stellar Cyber and standardizes scoring regardless of the many different scoring systems found in other platforms.

- Asset value. The importance of the affected asset to the organization can affect the risk score. Critical systems such as servers containing sensitive information can increase the risk score if they are involved in an Alert.

- Threat intelligence. Integration with threat intelligence feeds can provide context that influences the risk score. If an Alert involves IP addresses, domains, or hashes known to be associated with malicious activities, this can raise the risk score.

11:00-12:00

All these should be factored in when you're using risk score to create workflows that allow you to prioritize the most noteworthy events in your system to your organization, and you should use this accordingly.

- User behavior. Anomalies in user behavior that deviate from established baselines can also impact the risk score. For example, if a normally low-activity user suddenly starts accessing a high volume of data, this will increase the risk score.

- Historical context. If the system has encountered similar incidents in the past, this historical context can influence the risk score, especially if previous incidents led to confirmed breaches or were false positives.

- Combination of events. Sometimes a single Alert might not seem particularly dangerous, but when combined with other concurrent events, the risk score can increase. Stellar Cyber can aggregate and correlate multiple lower-severity events together to indicate a higher risk.

12:00-13:00

- Compliance and policy violations, events that violate regulatory requirements or internal policies can also receive higher risk scores due to the potential legal and compliance implications. The risk score assigned by Stellar Cyber ultimately helps prioritize Alerts so that analysts can focus on the most critical issues first. It's important for platform users to periodically review and adjust the scoring parameters to ensure they align with the organization's specific security posture and risk tolerance.

All these elements can be used to prioritize the Alerts that you want to look at first and we will look at it in the demo how they're grouped in certain ways and certain views in the tool and how we can get to all the Alerts to assess which ones we need to get to first and which ones represent the highest risk to our organization.

How Interflow Works: Interflow is a key feature in the Stellar Cyber security operations platform. It functions as a data normalization and transformation engine that facilitates the interoperability of security data across various sources and tools within the security structure.

13:00-14:00

It's important to understand this particular concept so that you can tailor queries to get to the exact data you need to get so that you know the fields that you need to query to find what sorts of data. Here's how Interflow works.

It starts with data collection. Inflow starts by collecting data from a wide range of sources. These can include network traffic, logs from endpoints, cloud environments, and data from security tools such as firewalls, intrusion detection systems, and others. Stellar Cyber is designed to be agnostic to data types and sources, enabling it to ingest and process information from virtually any security data provider.

Next is data normalization. After this data is collected, Interflow normalizes this diverse set of data into a standardized format. This normalization process is crucial because it allows data from different sources and in different formats to be analyzed together seamlessly.

14:00-15:00
The normalized data includes various fields such as time stamps, source and destination IPs, user information, process details, and more, depending on the type of data. A key benefit of Stellar Cyber is standardization of all incoming data sources to a common data model. This is the Interflow record. That includes some fields based on the elastic common schema. Values from the incoming raw data are mapped into standardized fields in Stellar Cyber. And these are the fields that you'll need to know about so that you can search effectively in the tool. In some cases, the original data is still saved with the Interflow record. This normalization allows Stellar Cyber analytics and machine learning to perform complex analysis and identify related events from disparate ingestion sources. Here's an example of this normalization.

CrowdStrike.event.LocalIP is mapped to Stellar Cyber's host.IP field so that it is common across all platforms no matter what type of data you're ingesting, it standardizes and normalizes this data so that it's searchable.

15:00-16:00
Deduplication. In mapping third-party native Alerts and security events, Stellar Cyber uses a variety of methods to identify and eliminate potential duplicates for each applicable Alert or event type. In particular, Stellar Cyber identifies a combination of fields and values to be key characteristics and uses those to identify duplicates. An example method is to compare the values in that combination for each new third-party Alert. If the same value set occurs within a time threshold that record is considered to be a duplicate and only the original record is mapped. This process is a critical mechanism to eliminate noise and reduce Alert fatigue. This is very important in operations because we all know that SOC work is sometimes tedious and you don't want to look at the same Alerts over and over.

16:00-17:00
Enrichment. Stellar Cyber's data framework requires certain fields to help identify this data source, the category of data, the type of event to support scoring calculations and certain other activities. In

some cases, the ingested data can be directly mapped into these fields. In other cases, Stellar Cyber generates that data. Examples of this data enrichment are:

- If you have no incoming source field, message_origin.source is created for you and populated with the vendor names such as CrowdStrike. An incoming data source field Crowdstrike.metadata.eventtype field exists and its value, such as Crowdstrike_detection_summary, is mapped to the field message class. Incoming data source field event.technique.name field exists, and its value is either directly or algorithmically standardized to populate the Stellar Cyber field XDR.event_name. Knowing how this works allows you to create tailored queries so that you can get to the data that you want to see or that you can pivot out of your Alerts view into just the specific type of data that you want to analyze at any given time.

17:00-18:00

Alert Tagging: In Stellar Cyber tags are automatically assigned to Alerts to help categorize and manage them effectively based on their characteristics, sources, severity, or other relevant criteria. This tagging mechanism enhances the ability of security analysts to filter, prioritize, and respond to Alerts efficiently. Here's how the automatic tagging of Alerts generally works within the Stellar Cyber platform.

- Rule-based tagging. Tags can be automatically assigned based on predefined rules and policies configured within the Stellar Cyber system. These rules are usually defined based on types of threats. Different tags from malware, ransomware, phishing, etcetera.

- Severity level. Tags such as critical, high, medium, and low based on the assessed impact and urgency of the Alert.

18:00-19:00

- Source of Alert, tags reflecting the origin of the Alerts such as network, endpoint, cloud, etcetera.

- Behavioral patterns, tags related to specific user or network behaviors like suspicious log in, data exfiltration, etcetera.

- Contextual tagging. Stellar Cyber uses the contextual information available from the integrated data sources to assign tags. This may involve asset information, tags based on the criticality or role of the affected assets, such as critical infrastructure or executive device.

- Geolocation. Tags based on geographic locations, such as external or specific country names.

- Threat intelligence. Integration with the threat-intelligence feeds can trigger tags like known malware or APT group name, if the Alert is associated with known malicious entities.

19:00-20:00

- Anomaly detection. For Alerts generated by anomaly-detection mechanisms, tags might be assigned based on the nature of the anomaly such as unusual activity, anomaly detected, or specific descriptors like unusual time of activity.

- Correlation tags. When Stellar Cyber correlates multiple Alerts to identify a broader campaign or multistage attack, it might assign correlation specific tags. These could include multistage attack, campaign ID, or tags identifying a specific attack vector being used across different Alerts.

- User-defined tags. While Stellar Cyber provides robust mechanisms for automatic tagging, it also allows users to define their own tagging rules. Security teams can create custom tags based on their specific operational requirements or insights derived from past incidents. This flexibility helps in tailoring the Alert management process to the unique environment and security posture of the organization.

20:00-21:00

- Machine learning. Over time, Stellar Cyber can enhance its tagging accuracy and sophistication using machine-learning techniques. By learning from past tagging decisions and their outcomes, the system can adapt and refine how it automatically assigns tags to new Alerts.

Automatic tagging is crucial in managing the large volume of Alerts that modern security operation centers have to handle. It not only saves time, but it enhances the precision with which security incidents are categorized and addressed leading to more effective and timely responses. These tags can be custom assigned to specific types of events as a method of assigning it to specific groups. Certain groups might want to handle ransomware attacks or certain groups might want to handle malware events or brute-force attacks. Tagging these or having the automatic tags assigned helps you to group these together to assign them to analysts and get the job done quicker.

Demonstration: In this part of the lesson we're going to engage in a little triage and investigation in action mini demo. We're not going to go super deep because we're going to have an Alerts demo lesson in this module.

21:00-22:00

We also discussed the Alerts views in a prior lesson. We're going to look at these Alerts in the context of how you build workflows to conduct your triage and investigation in the tool. We talked about the difference between the Alerts table view here. Which is all your Alerts. We'll go ahead and autosize these columns. These are all your Alerts, but they're grouped by Alert type. And so it may be that you have enough personnel to assign a certain type of Alert to a certain group or a certain analyst and you may want to do that. That's a perfectly valid workflow. Likewise, we talked about the **Investigate | Threat Hunting** view, which is all your Alerts and you can sort these by Alert score and attack them that way, assign analysts or groups to attack these Alerts by Alert score. All this is in the context of you probably want to triage and investigate your Cases first...

22:00-23:00

...because they will knock out a lot of Alerts that are related in a broader context with a larger narrative at one time and then what Alerts are left you can send analysts in to do the investigation of these Alerts and make sure that none of them are serious threats, or you may have enough personnel to assign people to do certain types of Alerts. You might give them Alert type to go investigate, you might give them a certain task to go into the Alerts and triage them one at a time by their Alert score. It all depends on your workflow and how much workforce you have, how many Alerts and Cases you have on a daily basis depending on your IT environment and your network. In this one we're going to briefly look at how you might go in and investigate these Alerts. We'll start with the Alerts table view, which is grouped by Alert type.

23:00-24:00
A best practice is to go in like I did and autosize all columns at the beginning of your session. If you're giving these Alerts to a group, you might ask, "How many Alerts do we have here?" We've got 387 Alerts. We'll select all these and either add them to a Case if that's the way you want to do it or set the status to **in progress**, apply that, and then give it an assignee, we'll give it to me, and then that's mine to attack. That's one way you might assign triage an investigation to an analyst or group of analysts if you have an alias here. But that's the way that you will assign that. Then you have to decide how you want to assign them. Do you assign them by Alert type? You create a Case out of these so that they can all be examined together even though they might not share identifiers that group them together. It might not be the same event, but it might be the same Alert type you put in a Case. That's a valid workflow if you want to do it that way.

24:00-25:00
Remember that you want to attack the Cases first so that you have someone investigating the Cases, knock out as many Alerts as you can that are related so that you have that extra context built into your investigation. You're obligated to decide how you want to attack these whether you want to start them with their criticality, their fidelity. The total number of Alerts is always going to be a factor. If you have many Alerts you might want to skip the Alert types that have lots of Alerts and go straight to the ones that are higher in risk score because they will represent a higher threat. We also talked about Alert taggings. You might search on an Alert tag. Go ahead and assign these to a certain person. Give them all the ones that say you've given a tag of immediate ransomware investigation or whatever tag you give to certain types of events and we talked about how to do that in this lesson. All these are valid workflows.

25:00-26:00
We'll go in and we will look at a certain type of Alert. Let's look at this one. It doesn't have too many Alerts, so it should be manageable to demo. It's important to take a look at these from the drop-down menu view. This has all your fields that you can do your triage and see what exactly is going on with this Alert. An equally valid workflow is that you might want to pick a certain field in here that is valuable to you. Say if you had a tactic ID that you were looking for, like TA0009, and we'll see what that is. We'll copy this as a query and look at all these Alerts at one time. That might be the way that you want to assign these depending on what your priorities are in your security investigations. Here we'll have the results that these were the only two with that particular tactic. We can look and

see what that tactic is here–collection. We'll click into this and see collection is a technique used by adversaries to gather information and sources of information that are relevant.

26:00-27:00
The goal is collecting data to steal and exfiltrate the data, so obviously that's bad stuff. You might want to pick these tactics as we're going through and we talked about this in the *Building a Risk Matrix* lesson. You might use these tactics as your method. If you have a list of prioritized tactics, you might want to go in and just like we've done here, create this query. It's automatically created for you within the tool. You don't have to look it up in Interflow and find out how to create this query. You've got it all built out for you just by one click by clicking in these metadata fields here and adding them as a query. Tactic ID is here, and you just either show the column. This is also a valid way to look at it. You can filter in and filter out this tactic. You can copy to the clipboard if you have a reason to copy this out to send to someone or make this as a query. All these are valid workflows.

27:00-28:00
Now we have these, the two tactics that we're looking at. A best practice is to check and make sure that they're not in a Case. If they are in a Case, check them out in the Case because that's going to give you a greater context when you have all this information at a glance in a graphic view and you can see exactly what's happening and examine these one at a time. If you don't have a Case for these Alerts, you can go back and look at it in this particular view. Investigate the Alerts one at a time if they're not associated with the Case. Let's see if this one is too. This one happens to be two. If this were closed out by an analyst, you wouldn't see these here. It would already have been triaged or investigated in a Case. In this investigation we want to see who is involved in this Case. We already looked at the Case that this is in...

28:00-29:00
...but assuming this was not in a Case, we might look at what this destination IP actually is. If this is a SQL dump, who is getting this dump? We want to know where this SQL dump file is going. We need to look at what exactly this destination IP is. We'll pivot out into the **Asset Detail** view. We explored this in the *User and Entity Behavior Analytics* lesson. Let's see. We can tell here that we are looking at Los Angeles. We're looking at the sensor is Red team AWS Ubuntu. We can see that this is red team activity. We've tracked down that this is red team activity. It's going on one of their VMware assets. This would be the method that you drill down on these Alerts. You want to follow the chain of the attack to the source and look at any connections that are outgoing to external IPs or hosts, and make sure that you're not losing data in these Alerts.

29:00-29:46
This is basically the method that you will follow to track down Alerts. We'll go into deeper detail about this in the Alerts demo. That's essentially the way that you should think about Alerts in terms of triage and investigation for these Alerts. This is the broader concept of how to think about it. In the Alerts demo we'll take a look at exactly how you would pursue an investigation of an Alert from start to finish, and try to build context on your own if it's not automatically involved in a Case. This is the way you would do it. This concludes this lesson. Thanks for attending. This lesson is complete. Thank you for watching.

L09 - ALERT HANDLING

Part 1 L09B-DEMO: Alert Handling - Command Anomaly (23m:00s)

00:00-01:00

The next lesson in the *Investigations and Workflows* training module is a demonstration of Alert handling using a command anomaly. Welcome to the Alerts demo 1 lesson of the *Investigations and Workflows* module of the SOC Analyst course. In Alerts demo 1, we're going to be investigating a command anomaly. What we'll do here is add an Alert to a Case to do a comprehensive investigation of the contextualized Alert. Welcome to our in-depth demonstration on how to effectively investigate Alerts using Stellar Cyber's security operations platform. In today's rapidly evolving cybersecurity landscape, staying ahead of threats is crucial.

Stellar Cyber empowers security analysts with its intuitive and powerful interface designed to streamline the investigation process and enhance threat-detection capabilities.

01:00-02:00

In these demo sessions, we'll explore the essential steps to navigate the platform, analyze Alerts, and derive meaningful insights that help in proactive defense. Whether you're a seasoned security professional or new to cybersecurity, you'll discover how Stellar Cyber tools can make your security operations more efficient and effective. We are not assuming any cybersecurity knowledge or expertise on your part during these demos. We'll be examining these Alerts with brand new eyes. We'll walk through the methodology of understanding different types of security Alerts. We'll talk about how to get an understanding of some fairly complicated technical Alerting. We'll explore how to document the research you've done and how to pass this information between team members using the documentation and memorialization features in Stellar Cyber's user interface. Sometimes cybersecurity operations can be undertaken with a sense of uncertainty or a lack of clarity in how to proceed. In these demos, we'll discuss how to learn to ask the right questions, perform efficient research on threats, and pass derived intelligence from Alerts to the proper stakeholders.

02:00-03:00

By the end of these demonstrations, you'll have the knowledge and skills to confidently manage and investigate Alerts, ensuring your organization's digital assets are well protected. Demo 1 involves a command anomaly Alert that shows up in the system. You're likely to encounter lots of anomaly Alerts in your days in the SOC. So it's important to understand how they look and how they are generated in Stellar Cyber. So how do command anomalies get generated? Stellar Cyber's platform uses advanced machine learning algorithms to monitor command-line activities across network environments. Identifying patterns that deviate from established baselines. It generates command anomaly Alerts when it detects unusual or suspicious commands that could indicate a potential security threat or breach. The system compares these activities against the comprehensive database of known malicious commands and unusual sequences, enhancing detection accuracy.

03:00-04:00

By continuously learning from network behavior, Stellar Cyber dynamically adapts to its Alert thresholds, ensuring timely and relevant notifications about potential cyber threats. Let's get started on this journey to enhance cybersecurity with Stellar Cyber. Here we go.

Alright. So let's jump into the Alerts demo. So we will pivot into the **Alerts** view. And this is going to give us the Alerts grouped by Alert type. We'll autosize all these columns. In this scenario, we're going to be looking at Alerts from the standpoint of in theory we have triaged all of our Cases and we've gotten all of the Alerts closed out in our Cases. But here we're going to look at if an analyst or a set of analysts were assigned to triage and investigate the Alert types by type, we'll take a look at that. And we'll choose a command anomaly. There's 386 of these. So it's not an unreasonable amount. It's a lot of Alerts, but not so many that we can't take a look at them, and we'll pivot into these command anomaly Alerts.

04:00-05:00
And we'll just choose the first one. So here we have an Alert score of 93. That's pretty high. And then we have what looks like a command of user bin ENV python user bin ALS CLI tech support and we don't know what that means. So we'll take a look at what that is. It looks like because it says Aella CLI that's going to be a proprietary command that's used potentially by tech support within our organization. It's not going to be something that we can go on Google and find out what this command actually means probably because this is a Python script that is basically used by our tech support. And then here this is our organization here Aella. So we'll take a look at the description here. The command has been executed an anomalously large number of times–six compared to normal one of itself or other commands, measured in 5-minute intervals. We will take a look here at the relevant fields.

05:00-06:00
And what we'll do is we will begin to make a document that contains the information that memorializes the work that we've already done so that if this does become some sort of event that we need to involve other teams or other analysts, we can do that. It's not going to be difficult to do that. So what we will do is take this anomaly ID. We'll copy this query just so that we can get back to this If this does become an event and we will copy this query in here.
That will allow us to anytime we need to go back to this, we can refer to this document.
And once we're done with it, if this does become something that needs investigation, we will export this as a PDF, we will go into the Evidence Locker, and we will put this document in so that other analysts can see what work we've already done. So let's take a look at this event.

06:00-07:00
First thing we'll want to do is take a look at the relevant information that's given in this information view. So we saw this before that the command has an abnormal number of executions and we don't know exactly what this is but the system already tells us that this is in the stage of persistent foothold. So it looks like what this is trying to do–possibly because it classifies it as persistent foothold–is that allowing an attacker–if that's in fact what it is because this could equally be legitimate tech support activity. In that case, we're not going to want to isolate hosts. We're not going to want to block IPs, but we need to do this investigation so that we know what it is we're looking at. So we'll take a look at

the key fields here. We've got root tenant. We've got the command. We've got how many times it happened. We've got the fidelity of this, which is 99, which is very high. And then we have a host IP, and the host name is the same as the host IP. So we'll take a look at details and see what we can garner information-wise from the details.

07:00-08:00
And we're looking at this command. And then we'll know it's a Linux Ubuntu. It's happening on some sort of Linux server. It looks like maybe a domain controller. We've got command anomaly. Happening in the United States. We have the host IP reputation as a brute forcer, which is good information to have. It may not be that this is actually a brute force attempt. But we have this host IP reputation that gives us an indication of maybe this is bad stuff happening here. And then this is an audit rule. And we've got the process name as command-line interface for our organization. And the reputation source reputation source is from Stellar Cyber. We looked at the command earlier. So this automatically tells us the tactic and technique from the MITRE ATT&CK framework and we'll take a look at that real quick.

08:00-09:00
So the tactic is execution, and this tells us exactly what we need to know about this Alert. Execution consists of techniques that result in adversary controlled code running on a system, which is theoretically bad. We just need to find out if this actually is bad and is happening. These are techniques that run malicious code. They're often paired with techniques from other tactics to achieve broader goals, like exploring a network or stealing data. So this remote desktop access, if that's what this is, might be an attempt for this user to either move laterally within our network. It might be an attempt to escalate privileges to an admin account or a system account so that they can accomplish the things that they want to accomplish with the proper privileges. And we'll take a look at the command and scripting interpreter just so that we know what that means. So command and scripting interpreter basically shows us that these are techniques that
adversaries may have used these interpreters to execute command scripts or binaries, these interfaces, and languages provide ways of interacting with computer systems that are a common feature across many platforms.

09:00-10:00
We have the potential for badness here. We just need to investigate whether this is actual badness happening on our network. And we will do that by taking a look into the asset details of this particular asset and see if there's anything else going on with this particular asset that we need to investigate. So it may be that we don't have the fields that we need in the view that we're looking at for command anomalies. So we just want to make sure that we've got the source host the destination host the source IP the destination IP. And the user if it shows up and in most environments, the Active Directory will populate the user that is involved in this. But we just need to have the source IP and the source host and we do have this in our table view here We've got the source IP. So what we will do is we will take a look at this source IP. It looks like we've got a lot of Alerts that are happening on this particular IP.

10:00-11:00

And we want to take a look at them as a whole. We don't want to take a look at them one at a time if we can help it. So what we'll do is we'll just go into the asset detail view of this source IP and see if there are any other Alerts that show up on this source IP that might tell us whether this is a one off attempt at tech support helping out a user on our network that needs help or if this potentially is combined with other events that tell us that there is something nefarious going on. And that's one thing you need to keep in mind when you're investigating and triaging Alerts, is that it's not just one Alert happening. You need to follow the attack chain from start to finish. This is one good way to do it is to go look and see if there are any other Alerts going on on this particular IP or source host because the source host shows up as an IP in this particular view.

11:00-12:00

So we'll sort this by time. And it looks like we have lots of Alerts with this IP. We'll auto size all these columns. So we have 462 Alerts. So we'll expand this and look at the first two hundred. So just in the last twenty four hours. So we're looking at the last twenty four hours here. We have a lot of Alerts happening on this source host. And these are going to fall into the category of login failures. So we saw before that this IP had a reputation of brute forcer, internal login failure anomalies is a good sign that this is some sort of brute-force attack potentially happening. We've got lots of command anomalies. We've got more login failures, command anomalies, all of this tells us that something is happening on this host that is not normal. There's a lot of things going on.

12:00-13:00

Command anomalies: This looks like it should be nefarious behavior. And we need to examine exactly what's going on with this. So when we will deal with such a large amount of Alerts, we might want to get all the fields that we need to have in the view, and then export this as a CSV. And then we can track the timeline of this event as it is. And if we need to add this to a Case so that we can investigate as a Case and have it all in one environment that we can add information to, add our investigation information into Evidence Locker, and have an Activity Log that other analysts can take a look at to tell what work has been done and what analysis has been done that yielded what findings on this. Is this bad behavior or is this normal tech support behavior? So what we'll do is we will export this as a CSV. We'll export all columns just so we can do that analysis.

13:00-14:00

So here we have all of the fields in this information and we can do a little triage. We could do this in the UI, but it might be a better practice to take a look at every field, every key value pair, that we have in this information because it may be that we want to take this information and determine based on the Alert types what fields we want to appear in our Alerts data table. So we'll just expand all these and see what fields contain the useful information to inform how we want to create our data table. So here we've got login failures. We looked at those command anomalies. We've got abnormal parent child processes, more login failures, and this tells us that this is probably more than just tech support behavior because otherwise you wouldn't have lots of login failures. So this is probably some sort of malicious attack to get access to our network.

14:00-15:00

So we have command anomalies and this is a lot of command anomalies to look at. It's just not going to be normal for a tech support agent to have so many command anomalies at one time. So we'll take a look at what these command anomalies are by scrolling right. So we have lots of commands here. And each one of these commands were not...unless we are bash script gurus or Windows PowerShell gurus...we're not going to know what all of these processes are that are being generated by these command-line commands. So it may be that we have to go through all of these to figure out what is going on on this particular asset. We might get a good idea by looking at the commands that are being generated. It looks like we've got update, notify, reboot, check for new releases...

15:00-16:00

...oh it looks like "get ransomware." That's ransomware, all different types of ransomware. This is clearly bad. So based on these Alerts we definitely know we need to isolate this host right now and do this investigation. It's probably going to be that we need to contact this user and or their manager and or their upper management and let them know that we are going to lock this asset, find out if there are any critical business processes that need to be allowed to run on this, but we have ransomware here. So the likelihood of this much badness going on on one asset is worth locking it down especially given that we have these indications of ransomware going on.
So we need to lock this asset down. But what we'll do is we'll take another look at some of the other descriptions that we have.

16:00-17:00

We've got abnormal anomalies and we may want to arrange this so that we see what the Alert type is and then what the description tells us because between the Alert type and the description, we can tell a lot about whether this is actual badness. I think we've made that determination at this point that this is badness on our network. We have all of this information that we can look at. All these command anomalies, all these failed logins. We have these indications of ransomware. This is probably an attacker using some sort of kit to execute all of these processes to see what works and what doesn't work. Stellar Cyber is telling us very clearly that there is badness going on on this asset. We're just taking a look at all of these: events login failures, command anomalies. We've seen that before uncommon processes for that environment. That's part of the user and entity behavior analytics, functionality within Stellar Cyber. It's telling us some very important information.

17:00-18:00

If we wanted if we had time to and we don't here because this is clearly an urgent event to organize this into a really intelligent worksheet to tell us exactly what the progress of this event is, but we've got three hundred and some odd Alerts going on on this one IP, whether that be a source or destination IP, but we don't have time to investigate three hundred and fifty some odd Alerts. We need to go ahead and lock this IP down. Lock this host down because it's showing us as an IP, but we'll go ahead and lock it down. So we'll go back to the list of Alerts for this user.
We'll go into Actions. We'll block any incoming or outgoing connectivity for this IP. And we'll set this for eight hours just to give us time to do the investigation on it.

18:00-19:00

We will submit this. Also we'll disable the user. So if access is enabled elsewhere within our network we'll disable the user in Active Directory, we'll put eight hours again. Then we'll disable the user. This is a test system so we won't do that now, but that would be two actions that you could take to isolate this. You could contain the host if you have some sort of platform that enables that functionality. We want to get this isolated so that this can't spread, especially given the fact that we have some commands that look like ransomware and we definitely don't want ransomware spreading on our network. That's the thing we need to get this isolated so we can do this investigation. And then find out where else this has spread.

19:00-20:00
One way we might want to do this is to add this to a Case. We'll go ahead and add the status of in progress so that no one else takes this on and we will assign it to an analyst. But one way we might want to do this is we might want to create a Case out of this. Then we can investigate this all at once and add all of the information into the Activity Log and Evidence Locker. We'll add this to a Case. New Case. Okay. So now that we've got this Case created, we'll go ahead and give it a name so that we know what we're investigating here.

20:00-21:00
Then we can take a look at this in a graphic view to see what hosts are affected, so the hosts here. Let's see in our observables. We've got a slider range of 10.30.2.0/26. The other host we have here is a Fortinet public DNS server. It looks like we have badness here, but it's contained to these particular hosts. Since we've got this locked down, we know that we're not dealing with a greater campaign. We can go back to the Alerts and see what the timeline holds. This is the way we would investigate this now.

21:00-22:00
We need to make sure that there's no other source hosts that are involved. We've already got our source host locked down. This is locked. What we'll want to do is go back into our spreadsheet that we created and view again all of these command anomalies. We'll want to force a reset for this host, and this should be contained. What's left to do is to document this.
What we'll do here is we will take our document that we have compiled here, and we'll save it as a PDF. We'll export this. That's a PDF and we'll attach it in the Evidence Locker.

22:00-22:56
We will also add our spreadsheet that we created and add this document as well. We will pass this to the relevant stakeholders for this particular Case that we created. That way, the people who have a stake in this investigation will be able to see the work that's been done. Thanks for attending this Alerts demo. This lesson is complete. Thank you for watching.

Part 2 L09C-DEMO: Alert Handling - DNS Tunneling (36m:38s)

00:00-01:00
The next lesson in the *Investigations and Workflows* training module is a *Demonstration of Alert Handling with DNS Tunneling*. Today we're going to be taking a look at investigating an Alert from a

little bit different perspective. We're going to be looking at a scenario where the Cases have been cleared out, and we go in to **Investigate | Threat Hunting** to see all of the Alerts that remain, and we're going to triage the highest risk score Alert, and pick one random Alert and do the investigation from start to finish. So this particular Alert is going to be a DNS tunneling attempt. If we don't know what DNS tunneling is, we're going to explore that in-depth and find out how we find out exactly what threat a DNS tunneling attack represents. We're going to go start to finish. We won't assume any prior knowledge, but we're going to investigate this in a way as if we'd never seen it before.

01:00-02:00
We are going to learn what values in the metadata we need to look at, learn what questions we need to ask for this investigation, and learn how to remediate this threat. We're going to do all the research in the tool and maybe pivot out of the tool and do the research and add this to our Case in the Evidence Locker so that other analysts can share in our research. We're going to document all this comprehensively, make sure it exists in the UI so that others can benefit from the research that we've already done and also help teach our other analysts what is going on with the DNS tunneling and basically generate some more knowledge, some more experience for our analysts, and show the direction that this investigation needs to go. We'll also talk about the stakeholders that we need to keep informed in a typical Alert investigation and we'll talk about how to resolve this at the end so that we see that we've actually remediated this threat.

02:00-03:00
We have cleaned up any vulnerabilities that we happen to have if we allow a certain type of protocol to go out of our network, and we'll talk about working with other stakeholders in order to remediate this threat and make our security environment more secure going forward. So let's get started.

Alright. Welcome to another Alerts demo. In this demonstration we are going to take a look at a scenario in which we are assigned to go in after an analyst has cleared the Cases out and all the associated Alerts with those Cases and triage the highest risk score Alerts in our environment. To do that, we discussed before that you can look at Alerts by Alert type. These are grouped by Alert type in this view. But what we're going to do here is go to **Investigate | Threat Hunting**.

03:00-04:00
In this view we have every single Alert that exists in one view. It's not grouped by Alert, but we'll take a look at these as individual Alerts. We'll pick this DNS tunneling anomaly, and we'll go ahead and give it a status of in progress. In this scenario we will assign it to me, and then everyone knows that I'm working on it. We're starting with this DNS tunneling anomaly. We are going to presume that we don't know anything about this protocol DNS. We're going to have to do the research. A lot of this demo is going to be around the mentality to take when you start researching an event that you maybe don't understand fully. Because getting the context of the event correct is a major portion of your chance of success in investigating these events...

04:00-05:00
...whether they be anomalies or whether they be rule-based Alerts, whether they be third-party Alerts, it's really important to understand what the actual Alert is telling you. Stellar Cyber does a really

great job at showing you what exactly this means. It gives you the tactic and the technique. We can see here that this is an anomalously large amount of tunneled high entropy traffic through DNS, and it gives the domain. The typical volume of traffic transmitted through this is .02 bytes missioned in a five-minute interval, and we've got two bytes here. This may be an attempt at tunneling information over a port that's generally open in most corporate environments because DNS serves as the phone book for the internet. It translates your domain name, it translates your URL into an IP, so that that traffic can flow over the internet.

05:00-06:00
What we're going to do in this demo is show the process of how you document this information so that you can pass this information back and forth between security stakeholders, between other analysts, between other teams. It may be that in your environment you have a workflow that escalates things and a set of tier-three analysts that do the triage. We're going to start with the triage and take a look at this Alert and see exactly what this means because we're just going to assume that we don't know what DNS tunneling is. We're going to document all these findings that we see in here. First, we're going to take a look at the metadata associated with this Alert. So we have a DNS tunneling anomaly. We have the job ID here. We have App ID. We have the location. We have DNS tunnel is what this is showing. An anomalous amount of connections have been made.

06:00-07:00
We have information telling us that this is some sort of query. We can see that the sensor is red team AWS SDS, which might indicate that this is red team activity. That's going to give us a clue that maybe this is not as dangerous as we might assume it is if someone was trying to DNS tunnel information and exfiltrate this data from your network. We also have the tenant. We have the tactic and technique. We can see here the event history. And then we have in here indication that there is some DNS to TCP activity going on, which is typically not allowed in corporate environments just for the damage it can do. Here it is: detected value is DNS to TCP dot aellatunnel dot com.

07:00-08:00
Someone has set a URL up to funnel this information out to a domain where they can store it in a database or they can exploit it however they need to exploit it. We're going to do some research on what DNS to TCP is and whether this is allowed on our network. It probably shouldn't be. Even if this is red team activity, we can work with the red team to close that as a gap in our protection because DNS to TCP is a way that you can convert DNS data to TCP and basically export all of this data in packets that look like DNS and if they're encrypted you can't really see what they are. We want to shut down this vulnerability that we have in our network. We're going to document all this. If this is not associated with other activity, we will create a Case out of this one so that we're able to use the Evidence Locker and the Case activity information to track all of the things that are going on with this investigation.

08:00-09:00
Because as we've said so many times, transfer of knowledge is a critical area of operations for SOC operations because you're not probably going to be the only person that touches this. If it is well documented, when it is passed to another set of analysts or another team, then they have all this

information that you've already done. They don't have to do the research themselves. We don't want to assume that they know what this is because like we've said so many times, not knowing what an actual attack represents is a good way to let things slip, let things get through to your network and cause problems for you later on down the road. We want to research this extensively. We're going to talk about how to do all this. One thing to know and one thing that's very useful in the UI is that you have a link right here to the Knowledge Base. You can get lots of resources that you need to understand the tool better from here. We'll go to Knowledge Base home.

09:00-10:00
We mentioned that this App ID is number 32, but we don't really know what that means. We'll go in here and go to the Chat GPT function that's within the Knowledge Base and ask, "What does App ID refer to?" This should give us a good answer to know what this App ID is. Anything that you have regarding questions about the UI, things that you see, metadata fields, all of this stuff can be found in the Knowledge Base. It's a very good resource that you can get to directly from the UI. We'll see if we can find out what App ID means. What this App ID means. Here we can see that App ID refers to the ID of an application identified by the DPI engine. We don't know what the DPI engine is so we'll ask that.

10:00-11:00
Here we see that DPI engine refers to the data processor component in the Stellar Cyber platform that's responsible for analyzing and investigating all Alerts across IT and OT together automatically. Hopping back into the UI we can see that the App ID is 32. App ID family is network. App ID name is DNS. We don't have to bother looking up this App ID as 32; it is DNS. It also tells us is this app ID on a standard port? Yes. A lot of times, people will take advantage of standard ports that remain open to do some sort of data that doesn't belong on that port. In that case, you are looking at a way that you could have people exfiltrating data from your network to some remote server or remote location that's not allowed. This is all good information. It's right here in the UI for you. It leads you down the path of how to conduct your investigation.

11:00-12:00
This is a very good reference. You refer to this as much as you need to to understand what is in the UI. You should find most of your answers here. Make sure and use this Chat GPT function in the Knowledge Base and you can link to it directly from the UI. It's a really useful tool. Next what we'll do is we will just take a look at the Information field. Here we have the tactic and technique that's being used. If we don't understand what exfiltration over alternative protocol means, we can take it here and see what the options are. Here it tells us that FTP, DNS, SMB (server message block) can all be used to exfiltrate data. These will give you good reference information to understand what's going on, right in the tool.

12:00-13:00
We'll take a look at the key fields.The top-level domain is quite long so we could copy this out and research it if we wanted to. The request query is here. This doesn't tell us much, but it potentially could. We'll take a look at it. It's in a Case and we're going to pretend that it's not so we can build our own Case looking at it through the **Asset Detail** view. We have our details here which might give us,

again it tells us the DNS to TCP across this domain that was created. That's not very cleverly named because we can see it's a tunnel out of our network. This is mostly the same information that shows up in this metadata field here. But just for ease of access, it's nice to look at in this field. Then we have the Interflow data here which might be useful to find the fields that you need to search on if you wanted to go do a search. Then you have the actions associated that you can actually take on this particular Alert.

13:00-14:00
What we will do from here is we will go into our Alert here and look at the source IP to see if there are other events happening on this IP in the date range that we've selected, which is 24 hours. We get a little bit of information here solar winds, and the IP tags, RH test one test two. We don't know what that means but we might have meaning if we had talked to the people who assigned those tags. Here are all the Alerts. So we've got 23 Alerts here, all with the same source IP. Well, the destination IP will probably appear if we add that field, so let's do that. We can go in here and look for the destination IP. The destination IP is here.

14:00-15:00
We'll look for the source IP or the source host so that we have the source host and the destination host. Source host is here, but that's showing a little bit something different. Source IP is what we'll want to add to this column. Now we have source IP and the destination. This has a source reputation of brute forcer which is not a good thing. It's not a good thing on your network to have a brute forcer reputation on there. Move the source IP over here and add a destination IP from here. We just put destination host. Now we have a source host and a destination host.

15:00-16:00
We'll add the destination host to this column and put it somewhere where we can see the source near the destination, just for reference source, host destination host. Now we've got all of these that involve at least one side of the communication is from our host. What we want to do here is create a Case out of this, and we'll pretend like there's not a Case already, but we'll add this to a Case. Alright. We've got our Case here. We're just going to go ahead and give this a new name, demo since we're running a demo here. We're going to go down and find our Alert. Let's see. We don't see it here. That's probably because we have 24 Alerts, and it's only showing 20. Let's see if it's in here somewhere.

16:00-17:00
Alright. Here is our tunneling anomaly. Since we've got the Case we need to remember first we need to assign this. So I'm going to as this in progress and I'll assign it to me. Then the Case is assigned. Likewise, we'll want to go assign all of these. It's a status of in progress. Apply that. We're going to put the assignee as me. Apply that. Now we know that it's me doing this Alert, doing this Case, but we're going to focus on the Alert because that's what this demo is for. With the DNS tunneling anomaly, what we're going to do is we're going to assume that we don't know anything about this. What we're going to do, after we autosize all of the columns, is
we are going to look at this tunneling anomaly.

17:00-18:00

Now it looks like in the big scheme of things in our analysis and our timeline what we've got is brute force, Adware, malware we've got port scanning, we've got SYN Flood Attack, which we might want to research as well. We have scanning behavior, handshake failures, lots of those. That means they're trying something and failing. We've got a Trojan, we've got SQL file dump, which could be credentials, shell commands, lots of stuff going on but we're going to focus on this anomaly since that's the one that we're researching for our Alerts demo. Here we have information we can get to it straight from the timeline. If we want to examine this, we can see that all this originates from this central asset that we are examining with this Alert. It also gives us the context of we have this user Frank at Stellar Cyber dot ai.

18:00-19:00

There's a lot of ways that we might be able to attack this investigation and response that have to do with Frank. If there's something going on–and this is clearly bad behavior this is malicious action you can tell because Frank probably is a guy; we don't know where he works but If he's not some sort of IT guy or a pen tester–then all of this behavior that he's engaging in is going to be bad stuff I mean. This is not stuff that happens on your network without some kind of red teaming going on unless it's malicious behavior from a bad actor outside of your network that's gotten access into your network and is exploiting vulnerabilities, doing scans, putting in malware where you can find vulnerabilities to exploit. All this stuff is just going to be bad. Whether it's red team or whether it's not, if it is red team it's a little bit less risky. However, you want to take the findings the red team has and close those gaps. We're going to take a look at the DNS to TCP activity that we saw earlier and see if that's bad.

19:00-20:00

That might be a finding that we have with this investigation that allows us to close that loophole in our security posture and make our environment safer. That's ultimately the point. Right? That's how you become a SOC superstar is that you are the person who understands the vulnerabilities on your network whether it's through vulnerability scans, whether it's through seeing things in your activity, seeing these Alerts come through like in Stellar Cyber, or whether it's doing advanced threat hunting where you're looking for signatures that you find in places like on forums or on threat-intelligence platforms. All of these things allow you to tighten up your security posture, and it adds value not only for you and your SOCs, but also for your organization. We will hop back into the DNS anomaly and talk about how we...and remember this defaulted back to twenty...we've got to go back to thirty.

20:00-21:00

Another thing is you want to if you have any filters or search search filters here. You want to clear those just to make sure that you are seeing all the things you're supposed to be seeing. But we're going to start with this DNS tunneling anomaly. We're going to assume that we don't know anything about DNS tunneling at all. We're just going to explore the process of investigation from start to finish because like we say so many times, no one knows everything about cybersecurity and if they do, if they tell you that they do, then they're probably lying. So you have to approach this with a little bit of humility, and you have to approach it with a little bit of resolve because there's a lot of data to analyze here, and you need to be doing this quickly because the longer you wait, especially since we've got trojans and internal ransomware going on there's not a lot time to waste. If we're evaluating this one we're going to first take this as our baseline of this is what we're investigating.

Right now the DNS tunneling anomaly. What we're going to do is we're going to take a Microsoft Word file and make a new document.

21:00-22:00

For this particular anomaly, we're going to just save in this document a way to get back to this anomaly and we could put the Case in there as well if we want to put the Case URL. Actually, let's do that. That's the URL for the Case. We don't know anything about DNS protocol. We're just going to pretend that we don't know anything about it. Let's do a little bit of research online and see what we can find out about what DNS actually does and add it to this document. DNS protocols domain name system. It's essentially the phone book for the internet. It translates names like Stellar Cyber dot ai into an IP, which is what DNS uses to pull the website for you. The thing about it is and another thing that we should know about this port is is this port typically open in corporate environments or is it not?

22:00-23:00

With DNS it almost always is, which is why attackers exploit it because you really have to have DNS open for your internet in your corporate environment to work at all. It's port 53. It's almost always open for the reason I just said is if you can't convert these domain names into IPs, you can't get the websites that you need. You can't have the interactions with websites or business processes or applications that you use for work. DNS is basically the backbone of how you find things on the internet and that's why it's rarely closed. So attackers will use DNS specifically because it's almost always open. We have this DNS tunneling anomaly so we want to ask the right questions. You know like a lot of investigation is just asking the right question. Maybe the right question to ask here is, "Is DNS tunneling ever allowed for a legitimate business purpose?" and do that research.

23:00-24:00

We're going to do that research real quick offline and then put it here. I'm going to go do a little bit of research and then I'll be right back. Alright. I'm back. I found what DNS tunneling anomaly really means. I asked the question, "Is DNS tunneling ever allowed for legitimate business purposes?" and found there are some legitimate business purposes, but in most corporate environments, there is not a reason for people to be using the DNS protocol for anything other than DNS-type activities. Here are the things that I found that DNS tunneling is used for: Number one circumventing internet censorship in the countries that we operate in. This is probably not going to be something that's allowed on your network. It's basically a hack that allows you to get around the protocols and the policies and the security guidelines that are presented by your company and you just don't want to be circumventing that because even if you're doing it innocently, it looks bad. When someone sees it in Stellar Cyber they will see that you're doing this and shut it down.

24:00-25:00

Network troubleshooting and testing is the only semi-legitimate reason that you would have DNS tunneling on your network. Sometimes the red team will use DNS tunneling as a way see what ways they can get data out of your network that a user or a malicious actor might be able to get data out of your network by disguising it as DNS packets and sending it out port 53, which is going to be typically open. That's the distinction you need to make with network troubleshooting. Is this legitimate

red teaming activity or is this malicious activity? Then providing connectivity and restricted networks in some countries it may be that you
have restrictions that you need to get around, but it's always going to be against the policy of your corporation, so it's not recommended. Some legitimate applications use DNS to transmit small amounts of data to and from internet-connected devices. But this is also going to be a one-off isolated use case probably not going to show up.

25:00-26:00
Even if it does show up you want to be aware of it so that you know if there is this type of activity if it's allowed. Otherwise, DNS tunneling is exactly that–it's tunneling. It's putting it putting
the data inside something that can't be seen so that you can get data out of your network. That's almost always a bad thing. Unless it's your red team doing exercises trying to find vulnerabilities, it's almost all going to be a bad thing. We know that DNS tunneling is bad and what we'll do is we will save this and we will convert this to a PDF file and attach it. We're going to save it as a PDF and then we'll attach this to the Evidence Locker. That way, whoever else is working on this Case will be able to see this. We'll add evidence.

26:00-27:00
Alright. Now everybody that interacts with this Case will have this reference document that tells them whether DNS tunneling is ever allowed for legitimate purposes, what purposes it might be, what DNS actually is, which port it is, why it's open. All of this information is very valuable. Especially when you're starting off in the SOC, you will not understand everything. It's just not going to happen that you'll understand every activity that's going on your network. It just doesn't happen. And the minute you think you understand everything that's happening, automatically you're doing cybersecurity incorrectly, because you have to approach this with humility and you have to understand what these Alerts are. Otherwise, you'll miss something and it will come back on you. And it's just not a it's not a good day for an analyst when you miss an attack. Having this information in here and maybe even creating a central repository for these types of data, so that if something happens...

27:00-28:00
...I've already got a really nice summary to show analysts that tells them what this is. If you wanted to create a full repository of DNS tunneling or other types of Alerts so that you have this as a reference it might be a good idea to do that. Alright. Now that we've got our DNS tunneling PDF for other analysts to take a look at, we'll go look at the relevant metadata in this Alert to see if there are other questions that we should be asking. The first thing that pops up is this DNS to TCP protocol being used on aellatunnel dot com. We may not know what DNS to TCP means. TCP we know is transfer control protocol, one of the ways that the internet transfers information. And so we might want to ask ourselves what is DNS to TCP? We'll do a little research online and see if we can find some good information about it.

28:00-29:00
We'll create a document that we'll attach to the Evidence Locker that tells us what it is. After a little research we found that DNS to TCP is actually a network tool designed to tunnel TCP traffic over DNS. We've already established that this is bad behavior. Even if it's legitimate information we need to

be aware of this traffic. Because there is the potential that people could funnel out information as DNS packets, reconstructed on the outside of the network, and they could have things like credential databases or password hashes, anything that they could use to further exploit your network. Now that they've got a foothold on your network can be used. So we want to see what DNS to TCP is. We know it's bad. It should not be allowed or at least we don't think it should be but we might want to make a document. We might want to add to this document to say I want to explain whether or not this should be allowed.

29:00-30:00
Here we see, after some research, that DNS to TCP is not generally allowed in corporate environments for the threat that it introduces to your environment. It allows users to go around firewalls or malicious actors to circumvent firewall protocols and procedures to circumvent firewall protections, and, basically this should be blocked. We need to figure out who the people are in our network administration team that we need to talk to. This is part of what we talked about in the workflow section where you need to identify the stakeholders that are going to be able to take actions for you. We could go ahead and block this IP. We could block the IPs that it's talking to within Stellar Cyber, but from a larger framework of how do we protect our network going forward–and that's part of your job as a security practitioner–to know and to inform others how you get rid of this type of activity.

30:00-31:00
It adds value to your SOC and your SOC operations to know how to do it. We might ask the question, "What's the best way to detect DNS to TCP?" and add this to this document. So we'll do that. What's the best way to detect DNS to TCP? So it might be traffic analysis. We have those tools in Stellar Cyber, deep packet inspection. That's already available. User and entity behavior analytics, that's available. Endpoint monitoring: If you have an EDR agent on your system that's one way to do it. DNS Gateway is another way. Log analysis. All this stuff is built in Stellar Cyber. Maybe not collaboration to ISP with ISPs, but that might be an avenue that you pursue. But this gives information to other analysts on your team on how do you detect it.

31:00-32:00
Then we might also ask the question, "How do we block DNS to TCP?" If we don't know who the stakeholders are in our organization, we might ask that question, "How do we block DNS to TCP on our network?" We can give this information if we have a small security team, this is good information to give to your network guys to say, these are ways that you can detect and restrict it. They will probably already know how to do this and it should already be implemented in your network, but all of this information is really valuable for your investigation to pass to other analysts, especially if you have junior people working on your network or if you happen to be the person that does it all yourself. We'll go ahead and save this as a PDF and attach this to the Evidence Locker again. We'll name it DNS to TCP information. I'll save this as a PDF. Then we will add this to our Evidence Locker again.

32:00-33:00

We will add it to Evidence Locker one more time as the PDF. This DNS to TCP Intelligence document that we've created. Now they have all the information that they need to take the action that they need. For this particular Alert, and we do have lots of other Alerts associated that we would need to tackle as a Case, especially since we know that this is very dangerous behavior we need to probably isolate this host. We need to reimage this host. But the other types of Alerts that we have give us the full picture, and we can see this in the **Analysis** view. Look at it in the timeline.

33:00-34:00
All of these hosts that it's connecting to will take action on that. But in the framework of this demo, we have done what we need to do as far as isolating this particular Alert. We'll reach out to the network security team, tell them to implement the things that we have put in the Evidence Locker, block DNS to TCP in all Cases, and if someone does have a legitimate business use to use DNS to TCP, we want to have that documented and approved by the network security team. All of these things over time build up layers on your security posture where you as a SOC analyst, in this tool that aggregates all these different types of data, you understand better in lots of ways than the other security professionals that are working on your network working on your endpoint detection and response, working on your firewall, working on your identity access management, or your file integrity management, any of these tools data loss protection, any of these teams.

34:00-35:00
If you have a large information security team, you have a more holistic and comprehensive view of what's happening in your network because you have all these aggregated Alerts and events that are showing up in Stellar Cyber, and it makes you, over time, a subject-matter expert on your network. In real terms we would look at the rest of these. We would look at all of these Alerts in time. But for the purpose of this demo, we just wanted to show that this is how you gather all the relevant information and take the appropriate action. It's mostly about asking the right questions and not skipping steps. If you see some type of behavior on your network and you don't fully understand it, the takeaway here is basically to do the research and find out what these types of activities are.

35:00-36:00
There are plenty of resources and we discuss some of these resources and other lessons. To investigate these things, and a simple search online will get you a lot of information about what you need. One thing I would advise though is just be careful when you look at vendor results. If you're looking at results from vendors, you may get a little bit of a biased view of the way this type of activity is handled. You want to make sure that you're looking at an objective source of information for doing your research. We've done our due diligence on this one. If we contact the network security team and get them to lock down this protocol we have done what we need to do for this particular Alert. In the context of the Case, there's a lot more work to be done. But in the context of just this Alert which is the purpose of this demo, we've done what we need to do. We have saved the day in a very small way.

36:00-37:00
Then we'll attack the Case and make sure that we've locked down all of the vulnerabilities or potential backdoors or any sort of executables or services or account flags that they've changed.

We'll do that research and make sure that we mitigate this and remediate this in the proper way. That's how you think about triaging and investigating this type of Alert. This methodology goes for any type of Alert. This concludes this demo. Thanks for attending. This lesson is complete. Thank you for watching.

Part 3 L09D-DEMO: Alert Handling - Privilege Escalation (28m:00s)

00:00-01:00
The next lesson in the *Investigations and Workflows* training module is a demonstration of Alert handling for privilege escalation.

Welcome to the Alerts demo 3 lesson of the *Investigations and Workflows* module of the SOC Analyst course. Today's Alerts demo is going to involve a phishing attack follow-up investigation involving privilege escalation. Here's the scenario. You are a tier-three analyst and your SOC leadership has tasked you with triaging Alerts related to privilege escalation. A phishing attack has occurred on our network and has been sufficiently contained. However, it was clear from the investigation of the activity after bad actors gained a foothold in our network that their intention was to attempt to escalate privileges and gain access to a customer database on our network. While we thwarted the attempt initially, the possibility of some foothold in the network still exists.

01:00-02:00
You are tasked with performing some investigation to see if any of the Alerts in your system show attempts at privilege escalation. You search through the Alerts in the **Alerts Detail** view and find some privilege escalation Alerts. You decide to triage the privilege escalation Alerts you see in Stellar Cyber from your CylancePROTECT platform. We've never heard of CylancePROTECT before in this scenario, being as we are new in the SOC and just had our foundational training from the training team. There's a specific type of privilege escalation Alert that stands out to us. Let's take a look.

In our scenario, we are new in the SOC and we want to find evidence of privilege escalation in our Alerts. What we'll do is we'll go to our **Alerts** view. Like we said several times, this is all Alerts grouped by Alert type. Here we're just going to search for privilege escalation in the name of the Alerts and see what we can find.

02:00-03:00
Alright, we've got some options here. This looks like the lowest hanging fruit. What we'll do is we'll take a look in here and see what we can find. I can go down. We can see that there are 12 results here. We can see them all. We've got some stack pivot events, some overwrite code, some malicious payload, and some stack protect events. Alright, we're just going to start with the first one and we are going to look at these stack pivot Alerts and try to understand what that is because we've never heard of that before. We don't necessarily understand what the threat to our network is with the stack pivot Alerts. We are going to do the research and find out what this is and hopefully enlighten other analysts and other infosec stakeholders that are working with us on this particular investigation.

03:00-04:00
We can see that there are some stack pivot Alerts here and we want to know what those are. What we're going to do is we're going to take all of these Alerts–even the one that says stack protect–because it has stack pivot in it somewhere because that's what we're searching on. We're going to add this to a Case. Now we've got this Case. We can take a look at these and we also have the additional benefit that we have Case Activity, which shows us everything that's happened. This shows that I created this Case from the CylancePROTECT exploitation for privilege escalation Alerts.

In the Evidence Locker, what we're going to do is do some advanced research on stack pivot attacks and find out what that means. Because as new analysts we're not going to know everything on our network. We need to do the investigation and find out what stack pivot is. Hopefully, along the way, we'll help out other analysts by submitting our information into this Case.

04:00-05:00
Other people can learn at the same time we can. Potentially after this investigation, maybe we gather up all the evidence and all the research that we've done and we give a presentation to our SOC or to our infosec stakeholders to show them what we've learned about these types of attacks. Maybe we set up a workflow to monitor for these types of attacks going forward so that we have a dashboard that shows us whenever these types of Alerts show up if in fact they are important. We're going to do that investigation now. The first stage in any investigation with a type of attack that we don't understand fully is to go in and take a look at the metadata that we have. We're doing this in real time. We see here that Cylance has blocked it, which is good news. The event name is blocked, also good news. We have the Cylance IP address. We may or may not need that. It's an exploit attempt.

05:00-06:00
Stack pivot is the type, and here we have these detected values that we don't understand just yet, but we'll do some searching and find that. The event provider is CylancePROTECT and we're not really sure what Cylance is just yet, but we'll find out. We got this from Syslog, from an endpoint, from the root tenant, and this memory exploit violation matches the stack pivot type of attack. It says that the tactic name is privilege escalation so we can see that this is privilege escalation and the kill chain stage is propagation, which means we're trying to find attempts of people to escalate their privileges so that they have the permissions to go in and exploit the database that they're looking for. We saw that they were on this database before. We want to make sure that this is not happening in this particular event. Fortunately, it was blocked.

06:00-07:00
We'll go check all these, but we want to add the outcome to our table so that we can see anytime that it was allowed. If it was allowed, we are definitely going to want to take action more quickly. We'll see if any of these were allowed. Blocked. Okay, so we have none. These are ones we want to investigate because we don't know what the outcome with these is exactly, so we're going to do this investigation. But first of all, we're going to take a step back and ask ourselves the relevant questions that we need to ask ourselves for this type of investigation. What are they? Let's back out of the UI now and take a look at what these questions might be that we need to ask in order to get to the right

outcome the most efficiently in this investigation on privilege escalation. First, let's ask ourselves what are the questions we need to answer to most efficiently investigate and close out this Alert?

07:00-08:00

First of all, we need to know what is CylancePROTECT? We don't know what that is, so we need to figure out what that is to know what we're looking at. Next, we need to ask what is a Cylance stack pivot violation type? What does that mean and how grave a risk is it to our network? Next, we'll ask how does stack pivoting work so that we can understand the metadata that we're seeing around this particular Alert type. Next, we'll ask what are the proper steps to respond to a stack pivot attack? We'll go through this as a presentation rather than as a demo. Then we'll jump back into the UI and see what we need to do, what steps we need to take to investigate this Alert to properly assign it to give it a status and assignee, and make sure that everyone knows that we're working. We should assign an assignee and give a status to the Case that we've created and to the Alerts themselves. We'll do that when we jump back into the UI. But first, let's examine what exactly it is we're looking at here.

08:00-09:00

The first thing we need to be aware of is what is CylancePROTECT? CylancePROTECT is an endpoint security product developed by BlackBerry Cylance that utilizes artificial intelligence and machine learning to predict and prevent malware infections and attacks. Instead of relying on traditional signature-based antivirus approaches, CylancePROTECT analyzes the behavior of programs and files to identify threats before they can execute. It operates in real-time, continuously monitoring and responding to potential threats without requiring frequent updates or causing significant system slowdowns. By preemptively stopping malware, phishing attempts, and zero-day vulnerabilities, CylancePROTECT provides robust security measures that help safeguard endpoints across diverse operating environments. Essentially, we're working with an EDR product here. Now that we know that we can take a look at a little bit deeper in the details of the actual Alert.

09:00-10:00

We have a stack pivot attack. What is a Cylance stack pivot violation type? A Cylance stack pivot violation type refers to a specific kind of security Alert generated by CylancePROTECT, a cybersecurity product from Cylance. This Alert is associated with the detection of unauthorized or suspicious activity related to stack pivoting in a system's memory. Stack pivoting is a technique commonly used in exploit development, particularly in scenarios involving buffer overflows or other memory corruption vulnerabilities. It involves manipulating the stack pointer to point to a controlled area of memory, often containing shell code or other malicious payload. We saw some of those Alerts too—malicious payloads in these privilege escalation Alerts. This manipulation enables the attacker to redirect program execution flow to their code, bypassing security mechanisms like data execution prevention, or DEP.

10:00-11:00

In CylancePROTECT, a stack pivot violation indicates that the software has identified an attempt to change the stack pointer in a manner that suggests a possible exploit attempt. Here's how Cylance detects and handles such a scenario. Behavioral analysis: CylancePROTECT uses machine learning

algorithms to analyze the behavior of programs and processes. If a process exhibits behavior that deviates significantly from normal or expected operations, such as manipulating the stack pointer unusually, it triggers an Alert. Memory protection: The system is configured to protect certain areas of memory or monitor access patterns that involve critical memory operations, including stack manipulations. Alert generation: When a suspicious stack pivot is detected, CylancePROTECT generates an Alert categorized under a violation type such as stack pivot violation.

11:00-12:00

This informs the security team of the potential threat in Stellar Cyber and allows for rapid response and investigation. Response and mitigation: Depending on the configuration, CylancePROTECT might automatically take action to stop the process involved, isolate the affected system, or require manual intervention for further analysis. This allows us to take those steps within Stellar Cyber as well. The effectiveness of such a feature is crucial in preventing more sophisticated exploits that could lead to more system compromise, data breaches, or other security incidents. If you're using CylancePROTECT or another security system, it's important to understand these Alerts and configure your security policies and response plans to effectively handle potential threats in Stellar Cyber as well. So the next question we might ask ourselves is how does stack pivoting work? Because in order to understand the data being presented in the Stellar Cyber UI in the metadata fields...

12:00-13:00

...we need to understand how it works to understand how grave a risk it is to our network. Stack pivoting is a technique used in exploitation, particularly when an attacker needs to bypass certain security mechanisms and execute arbitrary code or code that they have designed to exploit some vulnerability. It's commonly employed in scenarios where direct execution of injected code is not possible due to security protections such as data execution prevention. Here's a step-by-step explanation of how stack pivoting works. First, it's important to understand that the stack is a region of memory used for storing temporary data such as function parameters, return addresses, and local variables. The stack grows downward on most architectures, and the stack pointer register points to the top of the stack. The goal of stack pivoting is to manipulate the stack pointer so that it points to an attacker-controlled area of memory.

13:00-14:00

This manipulated stack can then be used to control the execution flow of a program by setting up what appears to be a legitimate stack frame containing return addresses, function arguments, etc., which actually lead to malicious payloads. Steps in stack pivoting: Buffer overflow or other vulnerability. Typically, an exploit begins by taking advantage of a vulnerability such as a buffer overflow. This allows the attacker to overwrite adjacent memory areas, including function return addresses. Injection of payload: Along with overriding control data, the attacker injects a payload somewhere in the memory, which could be shell code or other malicious code sequences. Manipulating the stack pointer: The crucial part of stack pivoting is to manipulate the stack pointer. This can be achieved using gadgets found in the program itself or in loaded libraries.

14:00-15:00

A gadget is a small sequence of executable code ending in a return instruction that can be used to perform specific operations. In the Case of stack pivoting, the desired gadget would perform an operation like MOV ESP, Eax or similar, where Eax, this is just an example, has been loaded with the address of the controlled payload. Execution redirect: Once the stack pointer is manipulated and points to the attacker-controlled stack, the normal execution of the program will resume, but instead of following legitimate program logic, it will follow the execution flow defined by the attacker. This typically involves executing the previously injected payload. Bypassing security: This technique is particularly used for bypassing DEP which we talked about before. This prevents the execution of code in non-executable regions of memory. Since the injected code is executed via the stack, which is generally executable, it can run even despite DEP.

15:00-16:00

Stack pivoting is a powerful and sophisticated exploitation technique that requires a deep understanding of system architecture, memory layout, and executable code within a process. It highlights the importance of using additional security layers, such as address space layout randomization or ASLR, which makes predicting the memory addresses needed for successful pivoting much harder. So we'll take a look at this in the Stellar Cyber user interface in just a moment. Now as part of our research process, we have compiled a set of steps that we need to do based on industry recommendations of how to respond to a stack pivot attack in our network. So what are the proper steps to respond to a stack pivot attack? We're going to look at these general guidelines and then we're going to assess how Stellar Cyber has already done some of this heavy lifting for us. Let's take a look at this general overview and then we'll look in the UI and see how we would respond in real-world terms.

16:00-17:00

Responding effectively to a stack pivot attack involves a series of coordinated steps that are designed to contain the attack, mitigate any damage, and prevent future occurrences. Here's a response plan example. This is based on industry standards, and we will talk about how much Stellar has already done for us. First, detection and identification. We should monitor for indicators of compromise and use intrusion detections, security information, and event management tools (SIEM tools), and antivirus software to detect unusual activities that may indicate a stack pivot or other exploitation techniques. So in this Case, we already have had this IOC presented to us in the Stellar Cyber user interface in the form of a Cylance Alert.

17:00-18:00

Alerts: We should configure Alerts to notify security personnel when potential exploitation patterns, such as unexpected stack changes or suspicious behaviors typical of stack pivoting, are detected. Once again, we got this Alert from CylancePROTECT so this has already been done. Initial containment: We should isolate the affected systems. We should quickly isolate these affected systems to prevent the spread of the attack within the network. This can involve disconnecting the system from the network or shutting it down if necessary. And we can take these actions and the Stellar UI will do that during the demo. Preserve evidence: Before conducting any further analysis or cleanup, we should ensure that logs, memory dumps, and other relevant data are preserved for

forensic analysis. We can save these types of information that we find in the Evidence Locker as we go.

18:00-19:00
Investigations: Forensic analysis, we should have someone conduct a thorough investigation to understand the scope of the attack. We should analyze how the attacker gained access, what vulnerabilities were exploited, which systems were affected, and what the attacker did within the network. Root cause analysis: We need to identify the vulnerability or security weakness that allowed the stack pivot attack to occur in the first place, such as a buffer overflow or insufficient input validation. Eradication and recovery: Patch and update. We should apply patches to fix the vulnerabilities that were exploited and update all software to the latest versions to protect against known vulnerabilities. In this case, we might end up reimaging the asset to make sure that there is nothing left on it. No artifacts. Remove malware and backdoors: We should use malware removal tools and manual techniques to clean all affected systems and ensure that no backdoors or other malicious tools remain.

19:00-20:00
Restore the systems: We should restore the affected systems from backups if we have them after ensuring that the backups are clean and free of any malicious code. Post-incident actions: Strengthen security posture. We need to review and enhance security policies and practices based on the lessons learned from the incident. We need to improve the endpoint protection, harden network defenses, and update incident response protocols. We saw that at least one of these Alerts was blocked by CylancePROTECT. We're going to go in and look at the other ones and make sure that no damage was done by the actual exploit itself. Security awareness training: We should provide training for developers and IT staff on secure coding practices and common exploitation techniques such as stack pivoting and train all employees on recognizing phishing attempts and other common attack vectors.

20:00-21:00
This may be a little bit out of the scope for a new SOC analyst, but it is a best practice to share the information from exploits and vulnerabilities that you've found with other people that work in DevOps or people that develop these types of applications and might leave some sort of vulnerability in their application. It might be our job in the SOC to pass this information on to them. Continuous monitoring: We should implement continuous monitoring strategies to detect and respond to future incidents more effectively so we should document this as well. Incident report: We need to document the incident details, impact, how it was handled, and what measures were taken to prevent similar attacks. We can do this all in the Evidence Locker, and we need to share this report with relevant stakeholders. Legal and regulatory compliance: We should notify authorities and affected parties. Depending on the nature of the data involved in the jurisdiction, legal requirements may take reporting security breaches to government authorities or notifying affected customers.

21:00-22:00
By following these steps, we can not only respond effectively to a stack pivot attack but we can also enhance our overall security posture to mitigate the risk of future attacks. We're going to see how

this looks in the UI and we're going to try to implement all these steps because all of these are very important steps. Some of these steps may be outside of the scope of your SOC workflow, but these are best practices and we'll see how this looks in the UI itself. Okay, now we'll jump into the UI and see what these look like in real terms. We'll look for privilege escalation in Alerts. We have a few here. Let's auto-size all these columns. So we have these privilege escalation Alerts. Let's see how many we've got. Looks like we've got quite a few and not all of them are stack pivot violations. So we'll filter out just the stack pivot violations. Now we have one, two, three, four, five, six Alerts. And we can see the metadata here is CylancePROTECT. We'll auto-size this again. Privilege escalation. We've got blocked, blocked, and then none. Scrolling over, we can take a look at the host IP and see what we can find. Exploit attempt. Fidelity is ninety. That means we're fairly certain that this is real. So the host IP here is ten dot ten dot one dot two twenty. Let's see what that is. We'll copy this as a query. Then we'll hop into a new window and paste this query. So we'll paste this here. Host IP.

23:00-24:00

We'll see if there are any other Alerts on this IP and maybe even pivot into asset analytics if we need to. This is the only one that appears on here. So what we're going to do is we're going to go in here and we're going to block this IP using our Fortigate. We'll choose both ways. And we will do this for the next eight hours while we do this investigation. We'll click submit. I won't do it here because of the test system. I don't want to mess anything up for other people, but we have this Alert that we're investigating now. So now we've got the IP blocked in both directions so we're not dealing with data coming in or going out from this IP. We'll hop back over to all these. What we'll do is we'll make a Case out of all these so that we can add information to the Evidence Locker. We'll give this a status of in progress. We'll give this an assignee of me.

24:00-25:00

Apply that. Now we have a Case. So we'll go into our Cases here. We'll get there from here. This is in this Case. As we mentioned before, it's named after the highest Alert score Alert type. So we've got this here. Alright, we'll add through to your Case. We're running into a problem in the demo system that they're all in the same tenant but we really only care about this Alert anyway. Now that we've got it in the Case, we have the ability to add things to the Evidence Locker. We'll just go in here, look for our Cases. Alright, so this is the one we're looking at here. Look at this Case.

25:00-26:00

We've got three Alerts in here. This is ours. So we're going to go ahead and take all of the evidence that we have generated in one document. The things we talked about earlier: how does stack pivoting work, what's a Cylance stack pivot violation type, what are the proper steps to respond to a stack pivot attack? We have all this information that we can share with our team members or partner teams. We're going to go ahead and save this or export this as a PDF. We're going to save it as PDF because that's what type we can attach here. Now that we've got this file, we want to attach this evidence to our Case.

26:00-27:00

That way everyone knows that we've got this information already researched and it is all easily accessible to them here. We've even got the anomaly ID so if they want to run a query on it they can. And we will start with the investigation of this Alert. So this one's blocked. Once again, we can take a look at the metadata here. It's a good thing that it's blocked. We've isolated this asset so that it cannot communicate in or out. We're probably going to want to go through the process of contacting this user's manager, letting them know that their computer has been locked out and that we're probably going to be reimaging this computer to make sure that there's no backdoors, no artifacts of any sort of malware that might have been used because we didn't see how this got onto the machine in the first place. Here we have all the information. So now that we've got this isolated, we are going to request a password reset. We're going to request a reimage.

27:00-28:00

We'll go ahead and put this Case to me again here so it's assigned to me. Because we were able to go ahead and do all this research, we know what this Alert actually is telling us. We've isolated the asset. We're going to request a reimage of this machine to make sure there's no artifacts on it. This will conclude our investigation with this one. That was very easy. But the research that we've generated with this thing is intended to show you the process of if you do not understand what the Alert is telling you, it's worth going into Google or to any sort of AI generation tool that you trust to have some context generated on these Alerts. Now we found an incident. It was blocked. We know we're good. We'll have this re-imaged, and we'll be good to go on to the next Alert. This lesson is complete. Thanks for watching.